Assignment 1 - Hands-On

Sam Peller

August 12, 2024

ISM 4323

Project 1-1: Examining data breaches visual

Objective: Explain the security concerns associated with various types of vulnerabilities

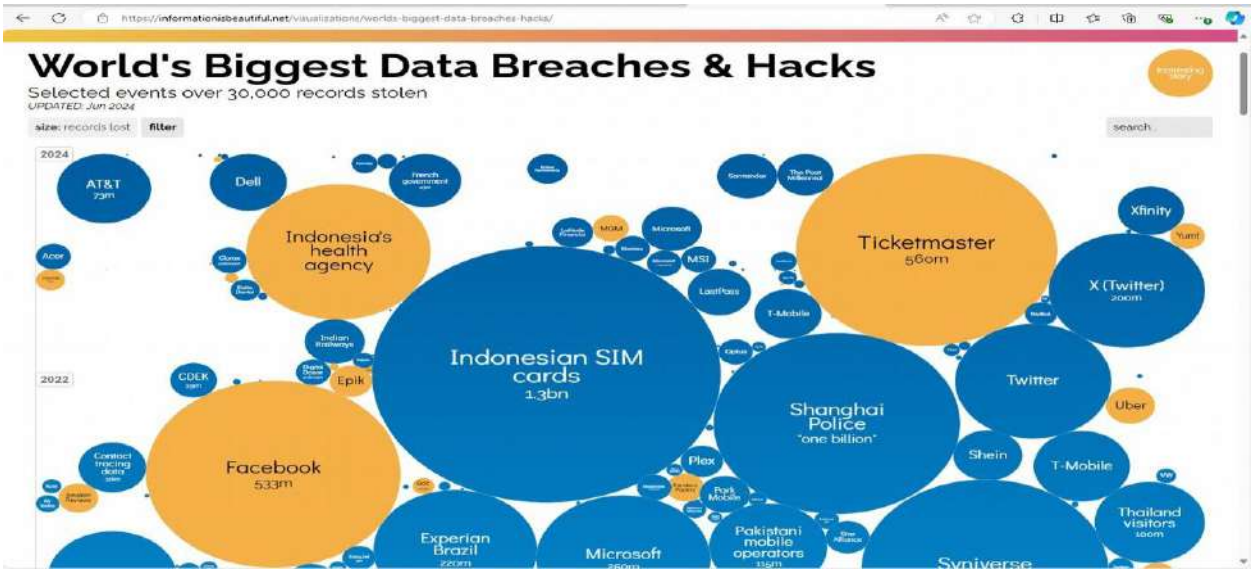
Description: In this project, you use a visual format to view the biggest data breaches resulting in stolen information.

Introduction

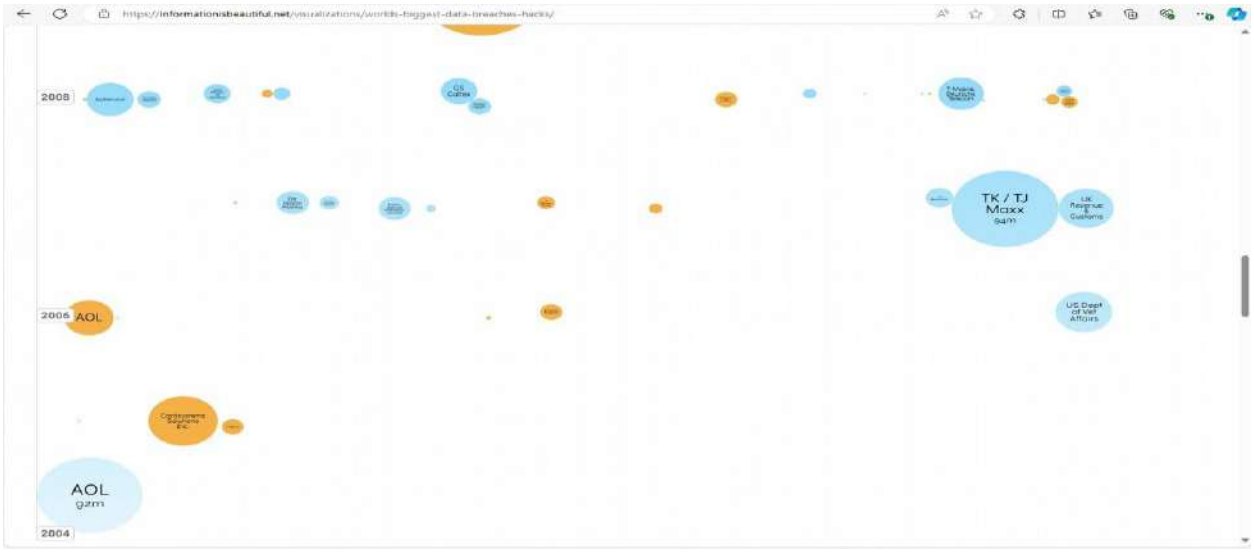
When it comes to Network Security there are many avenues' people will take to try and gain access to sensitive information. This also comes with many associated security concerns and vulnerabilities that consistently need to be monitored to keep private information private. As a result of some massive data breaches, companies can lose their futures, and people can lose their privacy as well as their money. This will go over some of the biggest data breaches and the resulting information stolen.

1. Open your web browser and enter the URL www.informationisbeautiful.net/visualizations/worlds-biggestdata-breaches-hacks/ (If you are no longer able to access the site through this web address, use a search engine to search for “Information Is Beautiful World’s Biggest Data Breaches & Hacks.”)

2. This site will display a visual graphic of the data breaches, as shown in Figure 1-7.

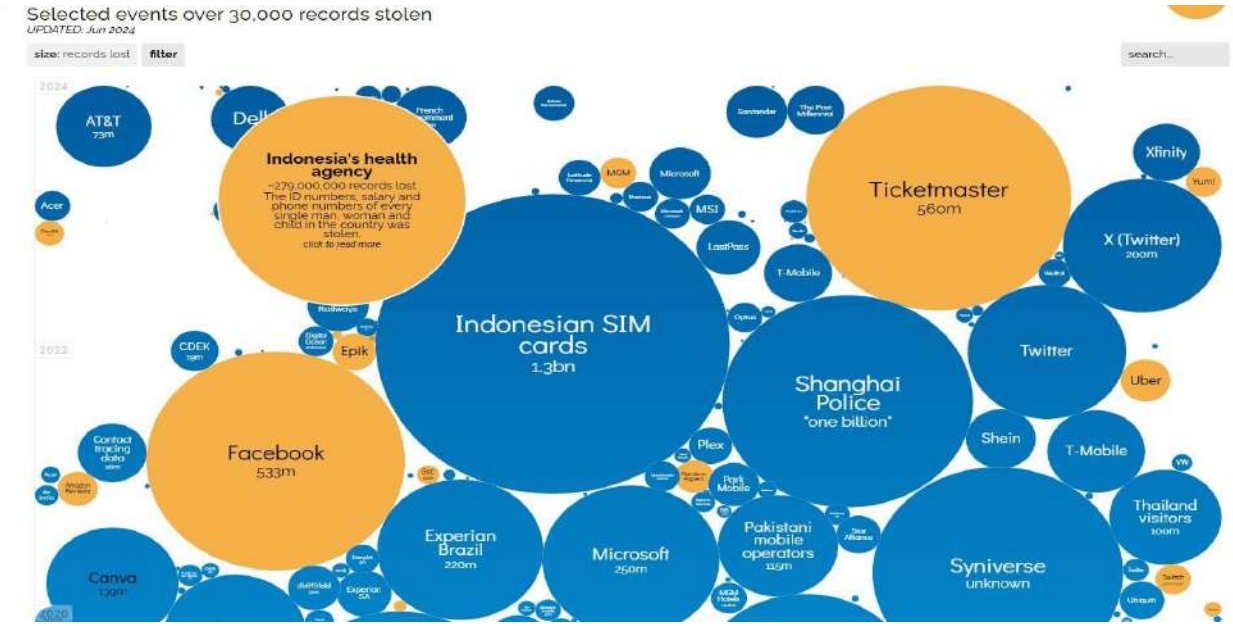


3. Scroll down the page to view the data breaches by year. Note that the size of the breach is indicated by the size of the bubble.



4. Scroll back up to the top.

5. Hover over several of the bubbles to read a quick story of the breach.



6. Note the color of the bubbles that have an “Interesting Story.” Click one of the bubbles and read the story. When finished, close only the interesting story tab in your browser.

Uber Suffers New Data Leak After Third-Party Vendor Gets Hacked

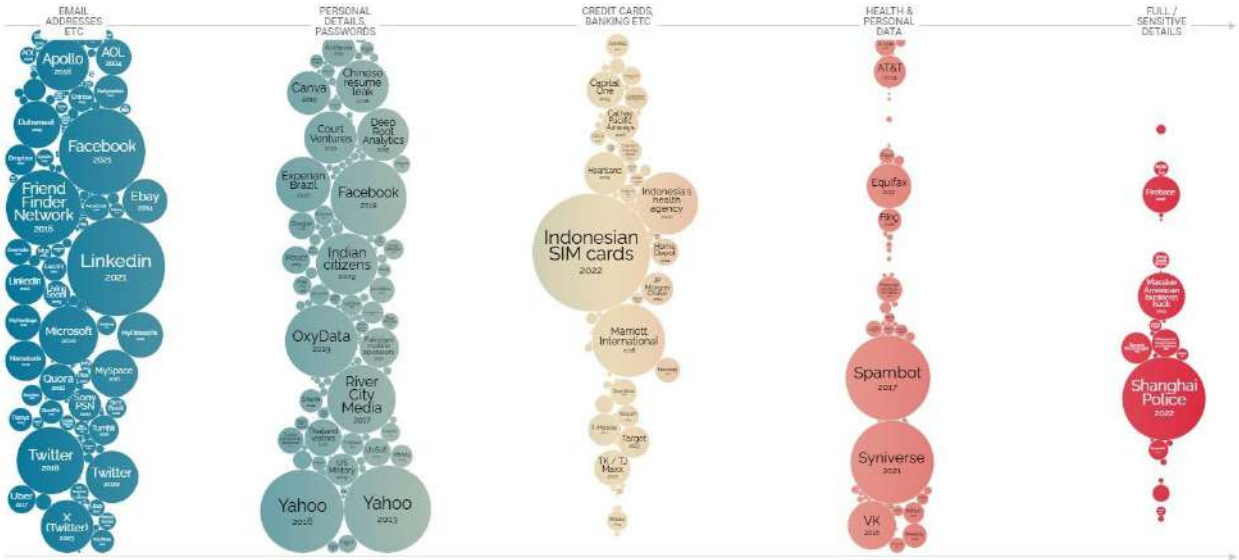
December 12, 2022 *By* Heinrich Long — **4 Comments**



A large collection of internal data was dumped over the weekend on a hacking forum and now Uber has confirmed a new data leak to RestorePrivacy that is unrelated to the September breach. Uber is blaming a third-party vendor. We analyzed the data for this report.

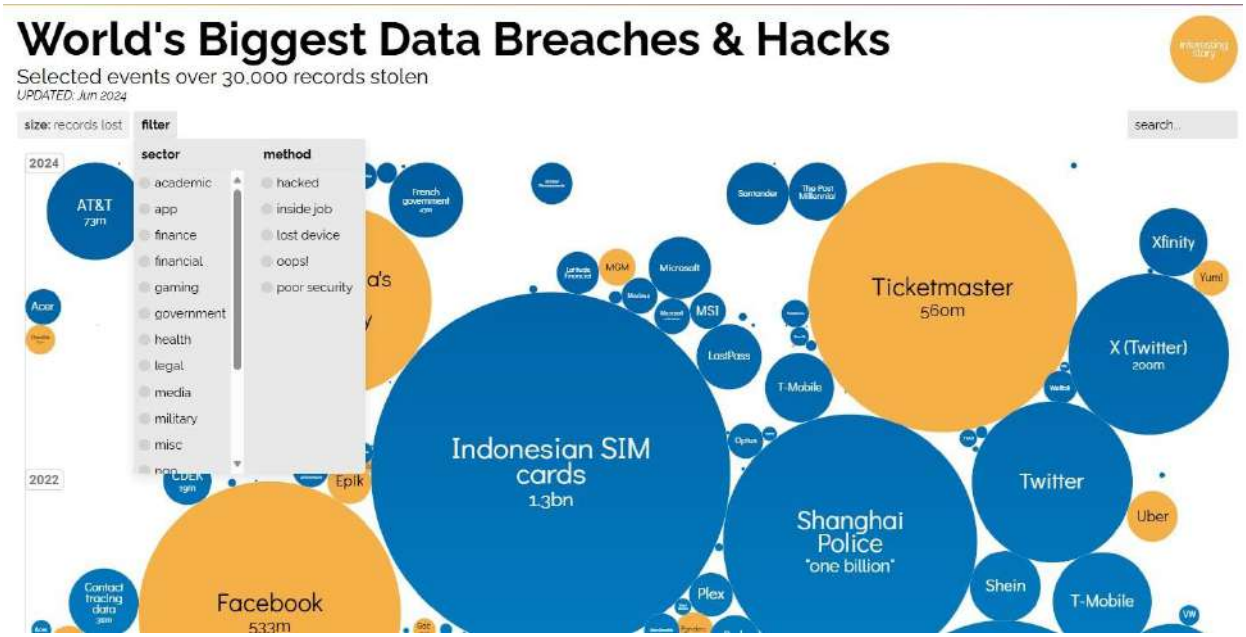
Update: Uber has now confirmed to RestorePrivacy that Teqtivity was the third-party vendor that was

7. Click the Data Sensitivity button on the World's Biggest Data Breaches & Hacks page. Note the color legend from Low to High that indicates how sensitive the data was.

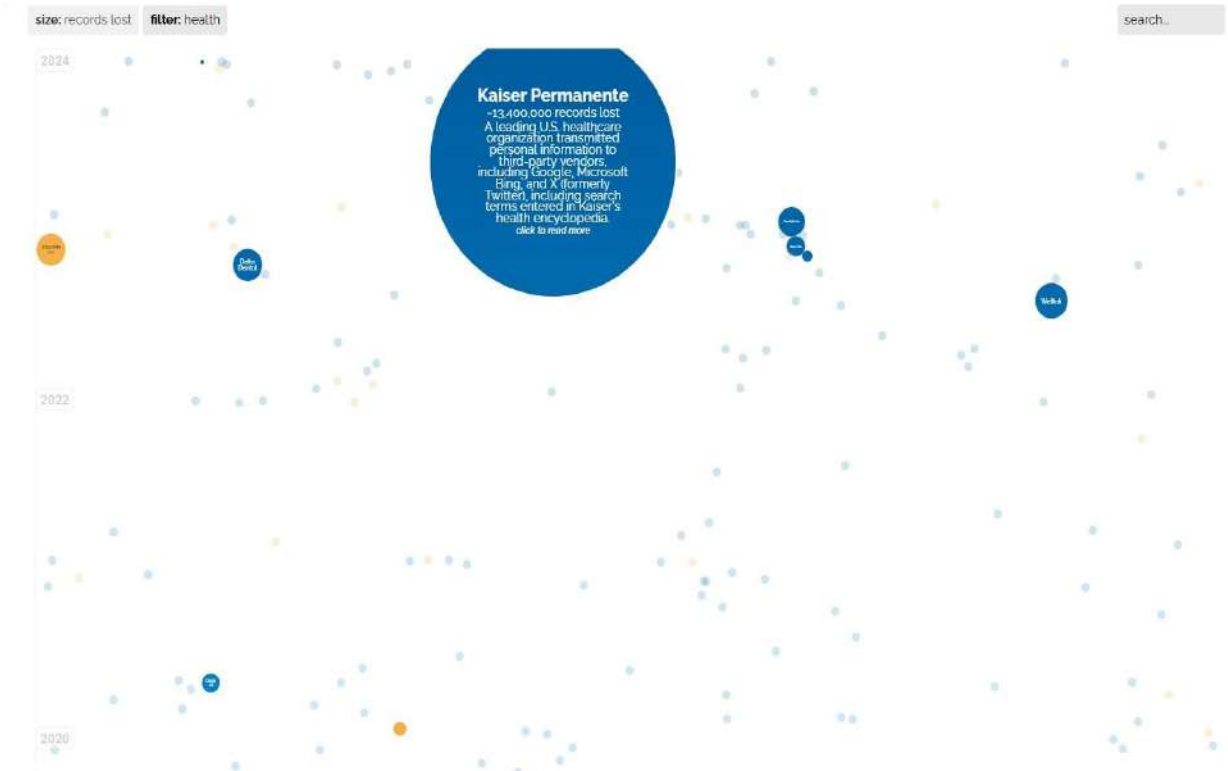


8. Click the Year button to return to the original screen.

9. Click the Filter button to display the filter menu.



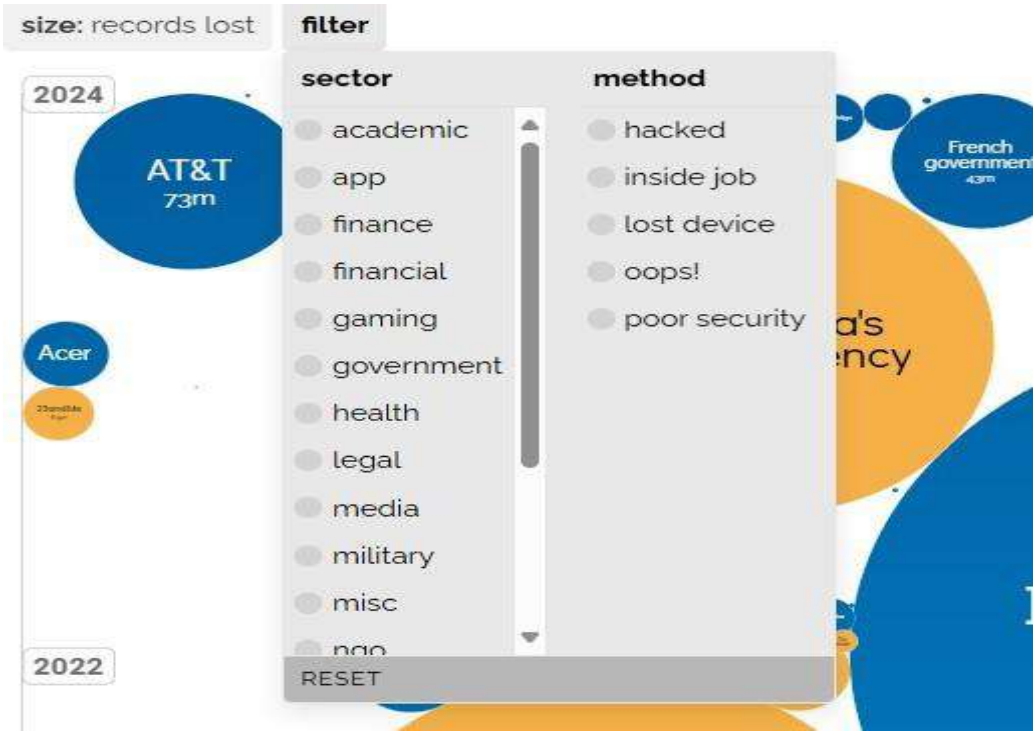
10. Under Sector, click healthcare to view those breaches related to the healthcare industry.



11. Click one of the bubbles and read the story.



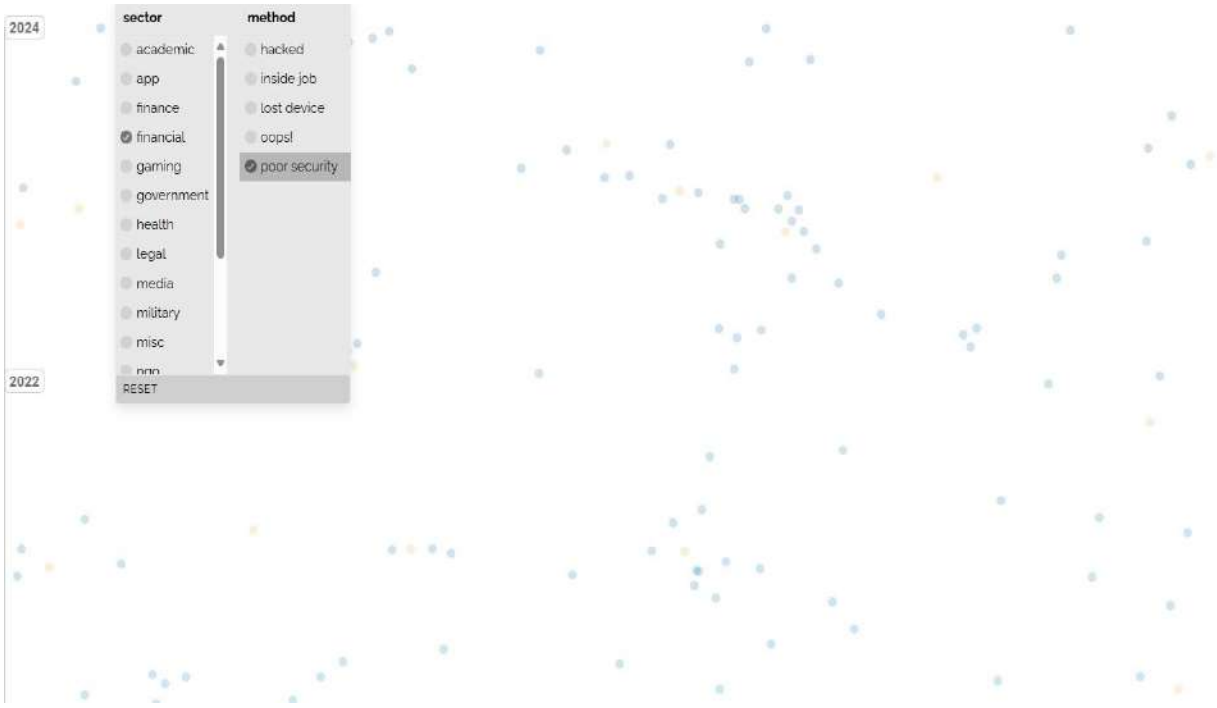
12. Click Reset in the filter menu.



13. Select the sector financial.



14. Select the method poor security.



15. Click one of the bubbles and read the story.

Programmer who stole drive containing 1 million bank records gets 42 months

News
Mar 25, 2008 • 3 mins

Cybercrime | Financial Services Industry | Security

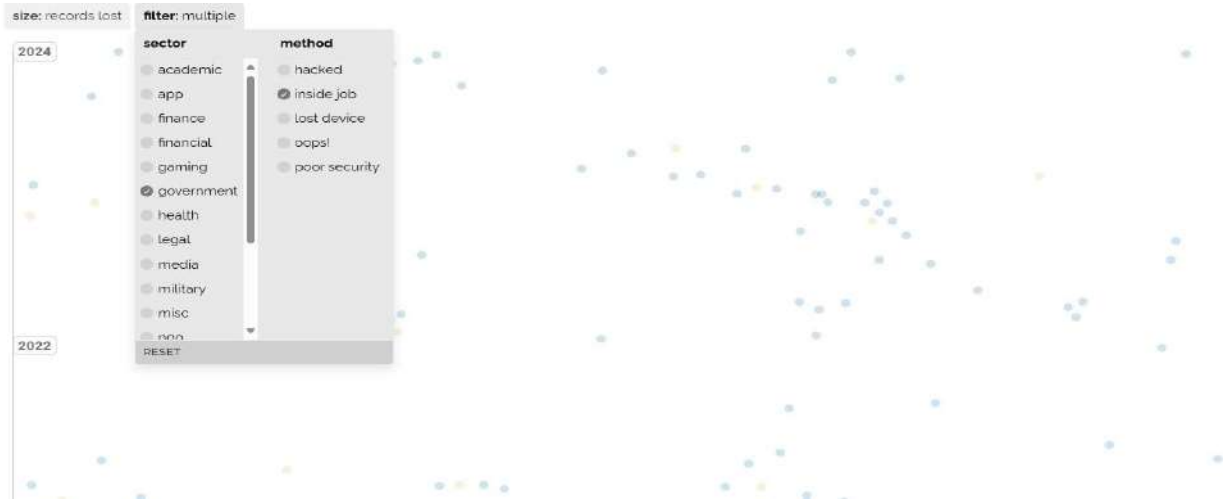
Only 250 customers notified of massive breach

A former programmer at Birmingham, Ala.-based Compass Bank who stole a hard drive containing 1 million customer records and used some of that information to commit debit-card fraud was sentenced last week to 42 months in prison by an Alabama district court judge.



James Kevin Real was also ordered to pay back the more than $32,000 that he and accomplice Laray Byrd fraudulently withdrew from customer accounts between May and July of last year using those counterfeit debit cards.

16. Create your own filters to view different types of breaches. Does this graphic convey a compelling story of data breaches?



17. How does this visualization help you with the understanding of threats?

It helps you see what sectors/methods are most likely to be used for certain breaches, as well as the size of the breaches relative to the sector and data sensitivity.

18. Close all windows

References

Belanger, A. (2023, December 4). *Hackers stole ancestry data of 6.9 million users, 23andMe finally confirmed*. Ars Technica. https://arstechnica.com/tech-policy/2023/12/hackers-stole-ancestry-data-of-6-9-million-users-23andme-finally-confirmed/

Long, H. (2022, December 14). *Uber suffers new data leak after third-party vendor gets hacked*. RestorePrivacy. https://restoreprivacy.com/uber-data-leak-breach-third-party-vendor-hacked/

McCandless, D. (2022, June 1). *World's biggest data breaches & hacks*. Information is Beautiful. https://informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/

Siddiqui, Z. (2023, October 5). *Casino giant MGM expects $100 million hit from Hack that led to data breach | reuters*. Casino giant MGM expects $100 million hit from hack that led to data breach. https://www.reuters.com/business/mgm-expects-cybersecurity-issue-negatively-impact-third-quarter-earnings-2023-10-05/

Vijayan, J. (2008, March 26). *Programmer who stole drive containing 1 million bank records gets 42 months*. Computerworld. https://www.computerworld.com/article/1570372/programmer-who-stole-drive-containing-1-million-bank-records-gets-42-months.html

Project 1-4: create a Virtual machine of Windows 10 for Security testing—Part 1

Objective: given a scenario, implement host or application security solutions.

Description: If you were unable to install the Windows Sandbox in Project 1-3, a different virtual machine can be created in which new applications can be installed or configuration settings changed without affecting the base computer. In a virtual machine environment, the “host” computer runs a “guest” operating system. Security programs and testing can be conducted within this guest operating system without affecting the regular host operating system. In this project, you create a virtual machine using oracle Virtualbox software.

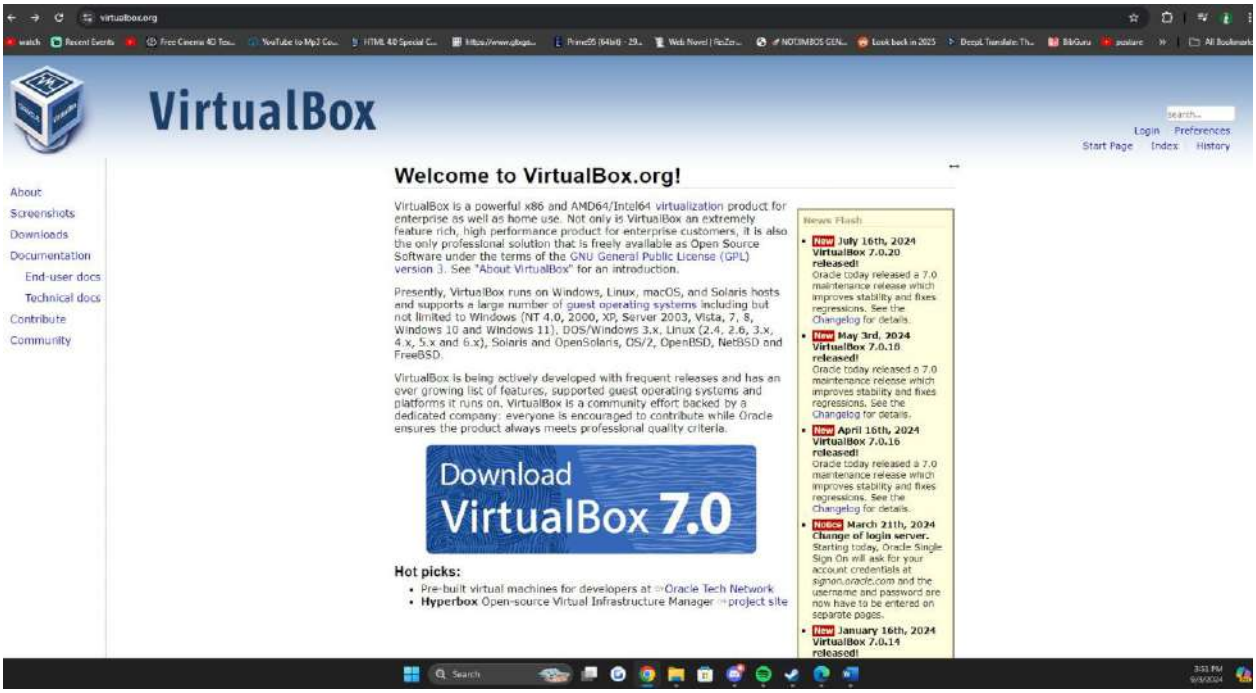
INTRODUCTION

VM or Virtual Machine's are an act of isolating an operating system on your operating system. According to Scale Computing (2023),"VMs will enable you to create a virtual environment on your computer"[CITATION Sca23 \l 1033]. The act of using a Virtual Machine is a cost efficient and secure way to run things in that isolated sandbox. It works, according to Microsoft by creating a "virtual" version of a computer via virtualization and dedicating resources from your own machine to run it. It is also used to build and deploy apps on the cloud, trying out new operating system releases, accessing virus-infected data or running older applications, and more[CITATION Mic \l 1033].

---

1. Open a web browser and enter the urL www.virtualbox.org (If you are no longer able to access the site through this web address, use a search engine to search for "oracle Virtualbox download.")

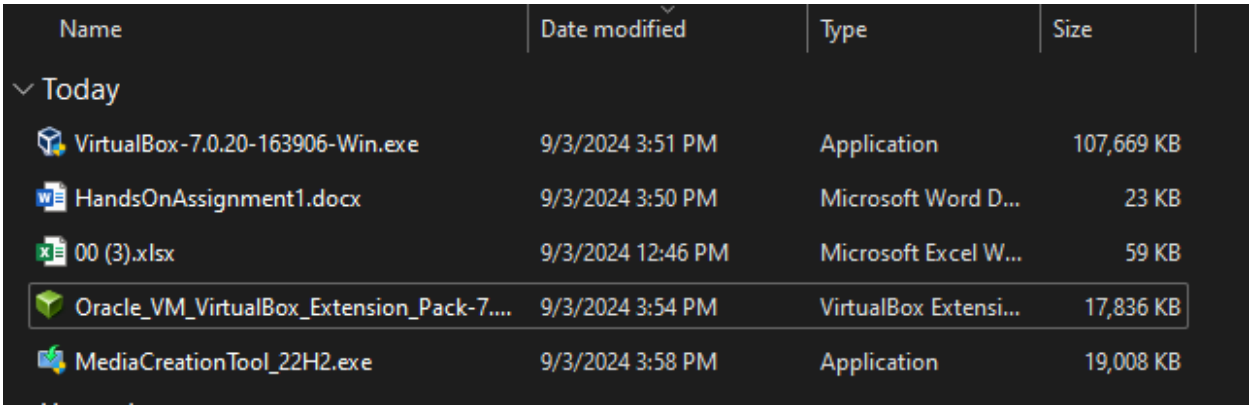
2. Click downloads (or a similar link or button).

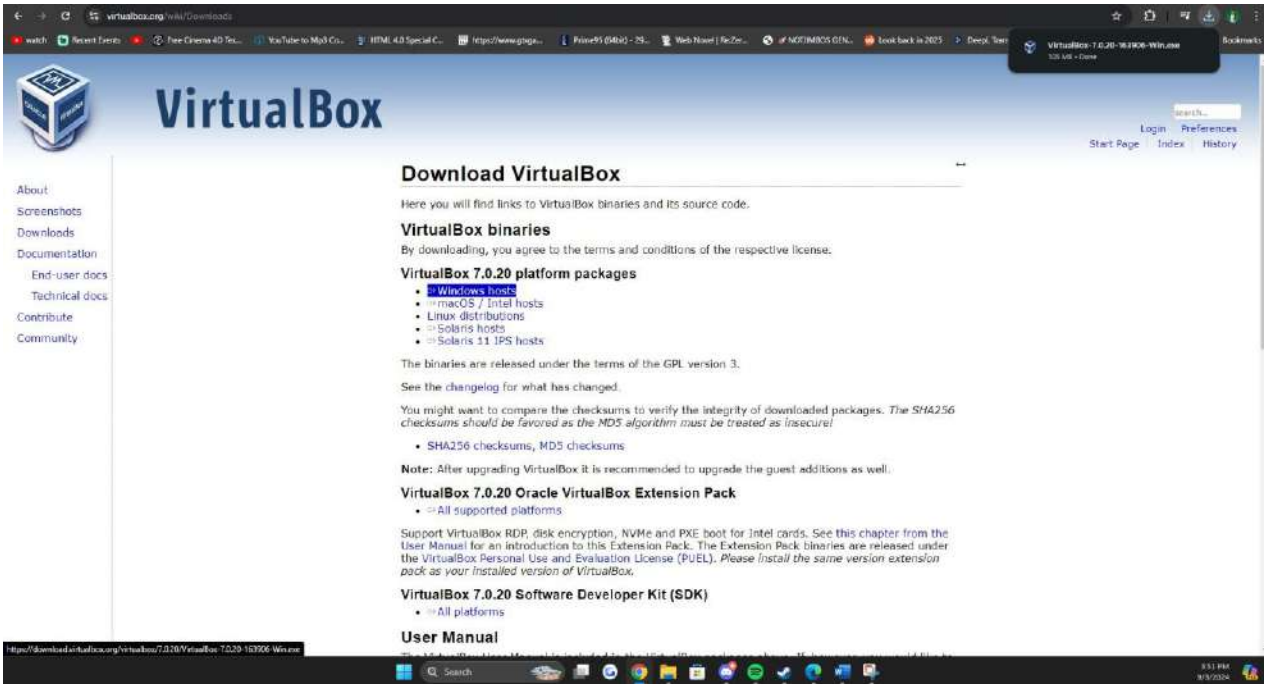


3. under Virtualbox binaries, select the latest version of Virtualbox to download for your specific host operating

system. For example, if you are running Windows, select the version for "Windows hosts."

4. under Virtualbox x.x.x oracle VM Virtualbox extension Pack, click All supported platforms to download the extension package.





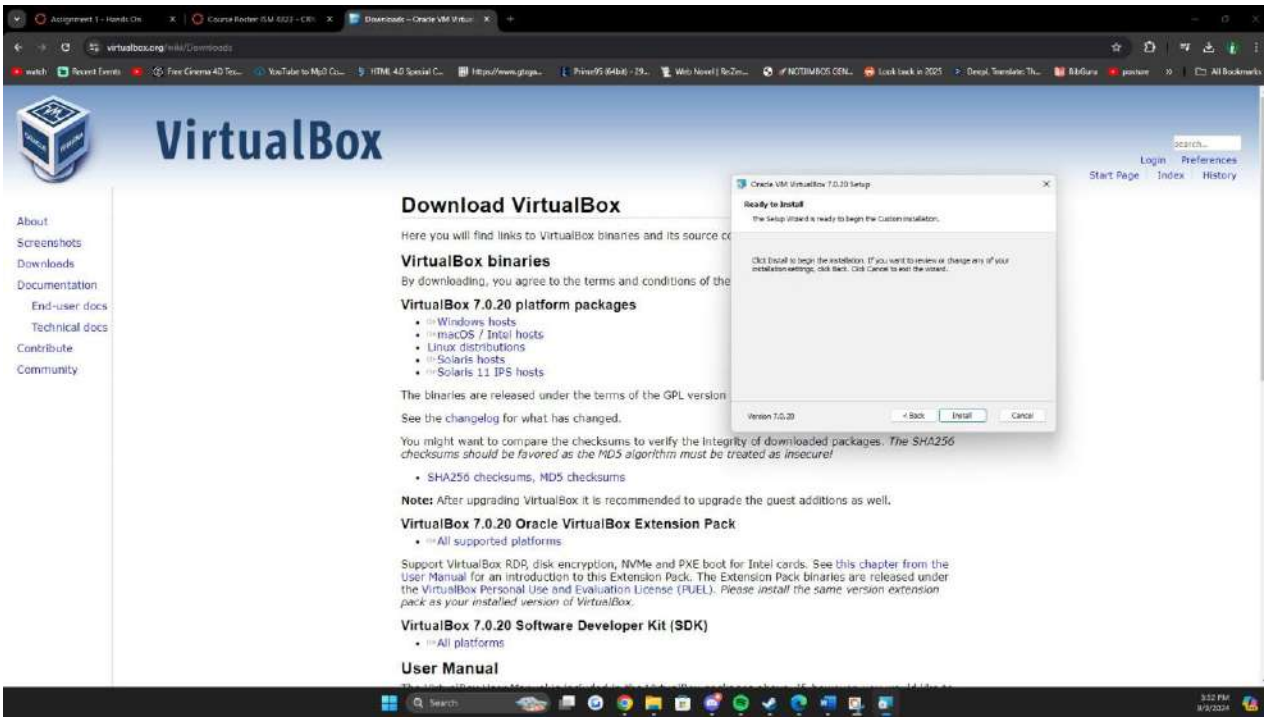
5. navigate to the folder that contains the downloads and launch the Virtualbox installation program VirtualBox

xxx-nnnnn-hhh.exe.

6. accept the default configurations from the installation wizard to install the program.

7. If you are asked “Would you like to install this device software?” on one or more occasions, click Install.

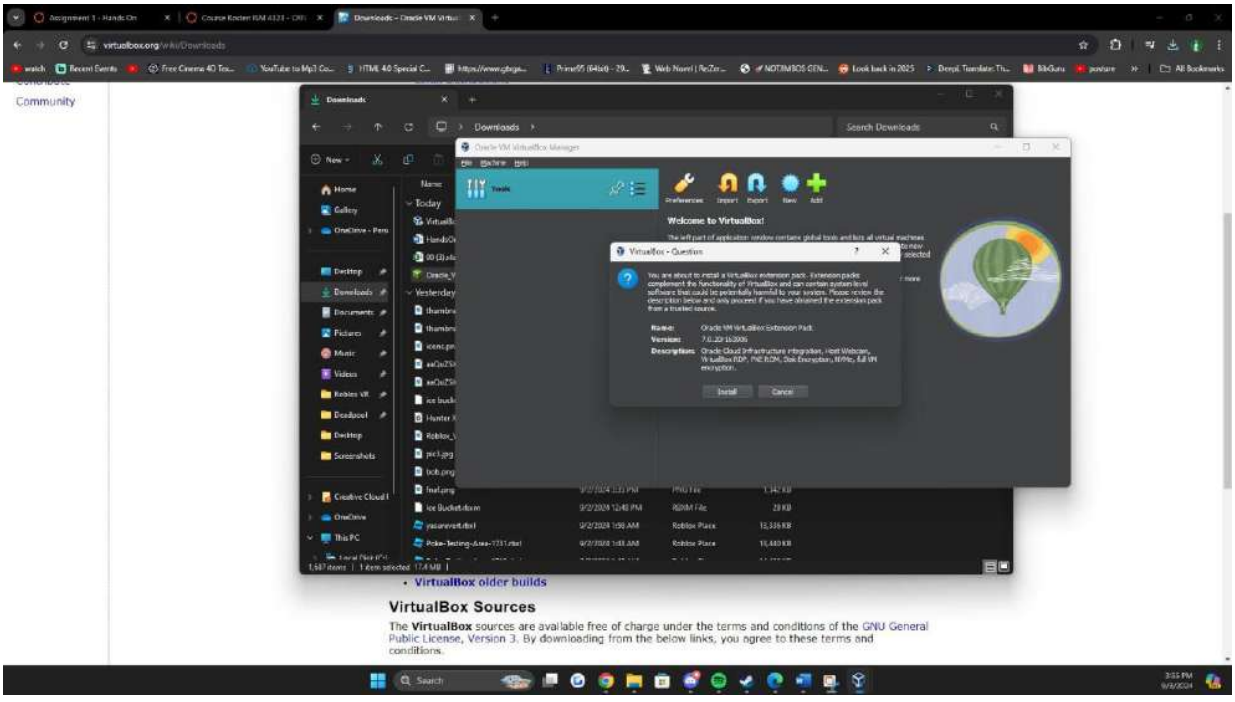
8. When completed, click Finish to launch Virtualbox.



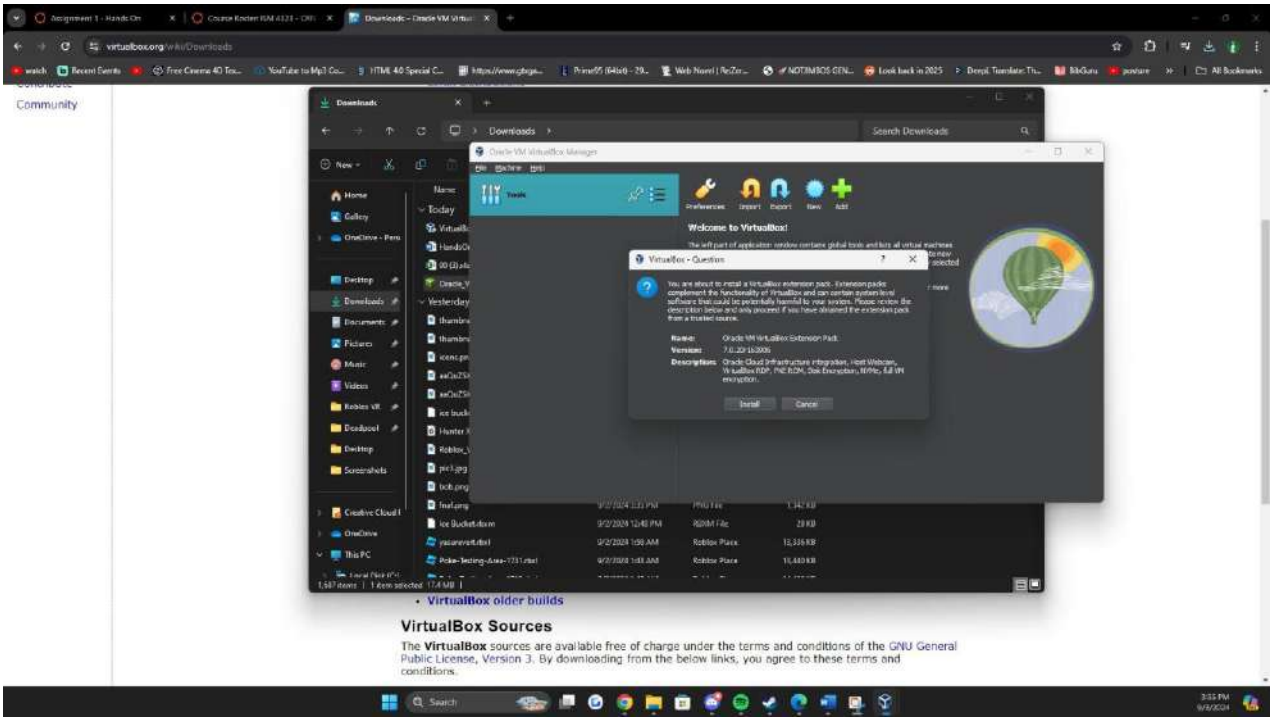
9. now install the Virtualbox extensions. click File and then click Preferences.

10. click extensions.

11. click the Add a package icon on the right side of the screen.

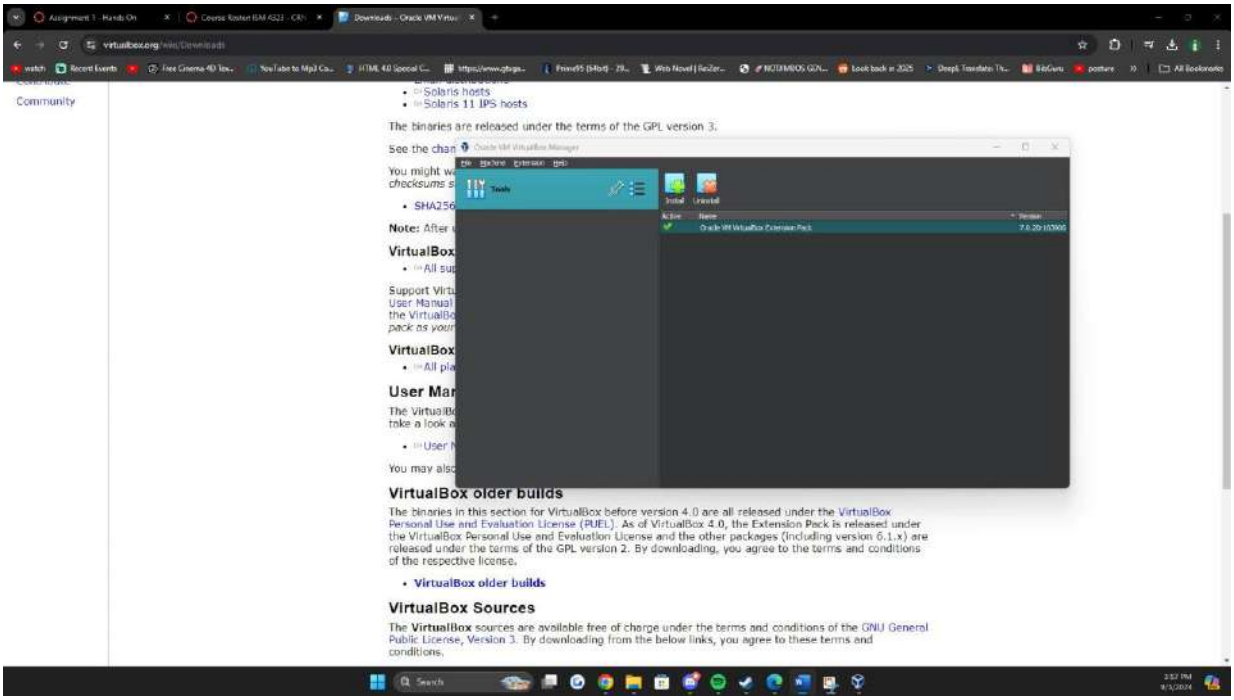


12. navigate to the folder that contains the extension pack downloaded earlier to select that file. click open.



13. click Install. Follow the necessary steps to complete the default installation.

14. remain in Virtualbox for the next project to configure Virtualbox and install the guest operating system.

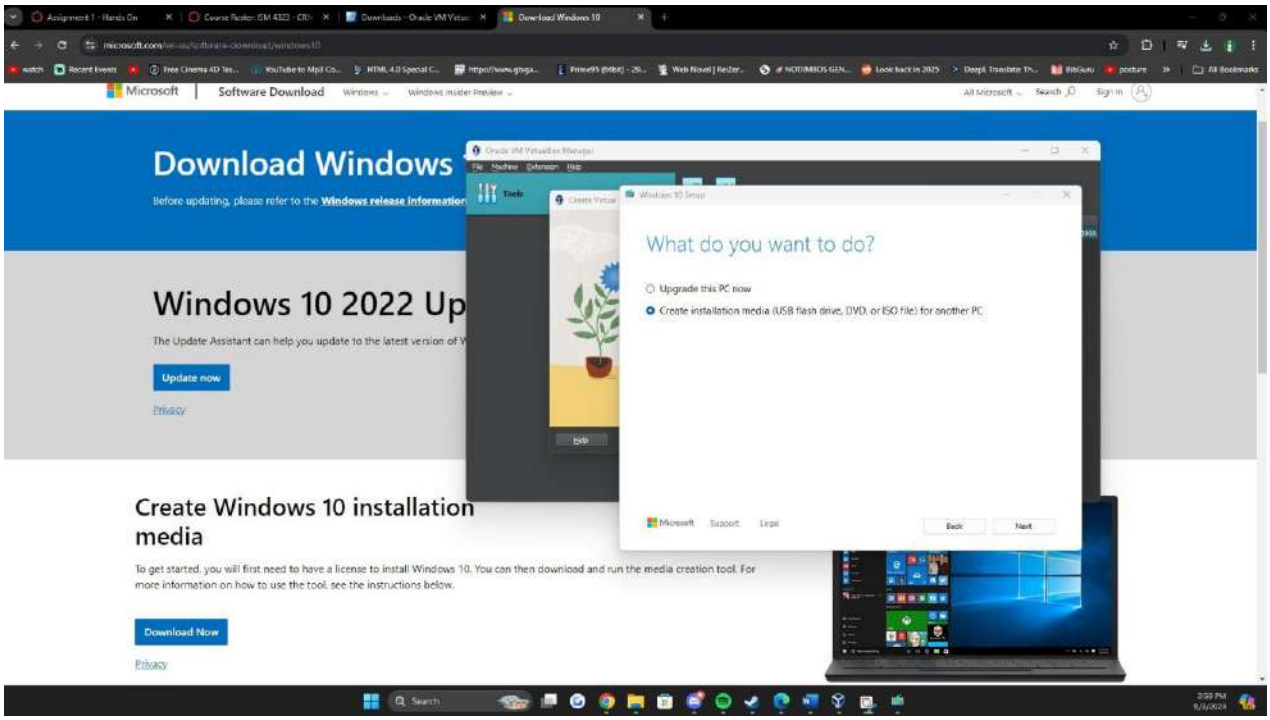


Project 1-5: create a Virtual machine of Windows 10 for Security testing—Part 2

Objective: Given a scenario, implement host or application security solutions.

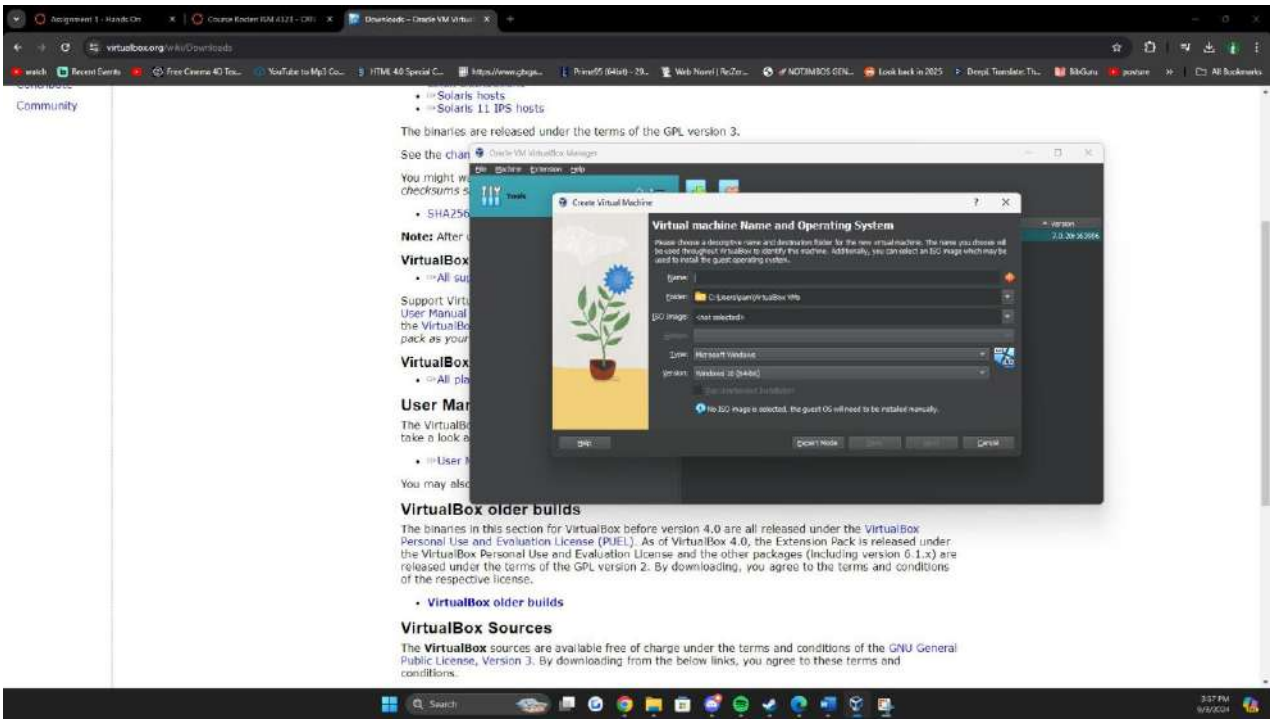
Description: After installing Virtualbox, the next step is to create the guest operating system. For this project, Windows 10 will be installed. different options are available for obtaining a copy of Windows:

1. obtain the ISo image of Windows 10 using one of the preceding options and save it on the hard drive of the computer.



2. Launch Virtualbox.

3. click New.

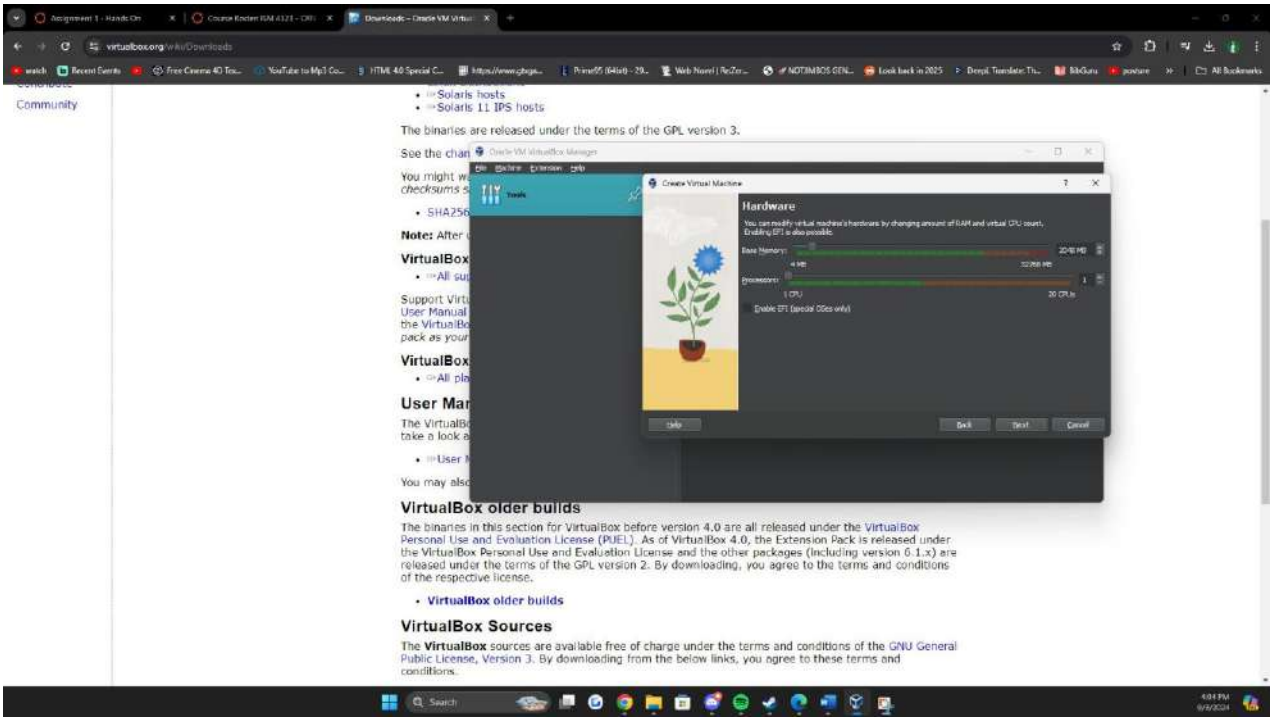


4. In the name: box, enter windows 10 as the name of the virtual machine.

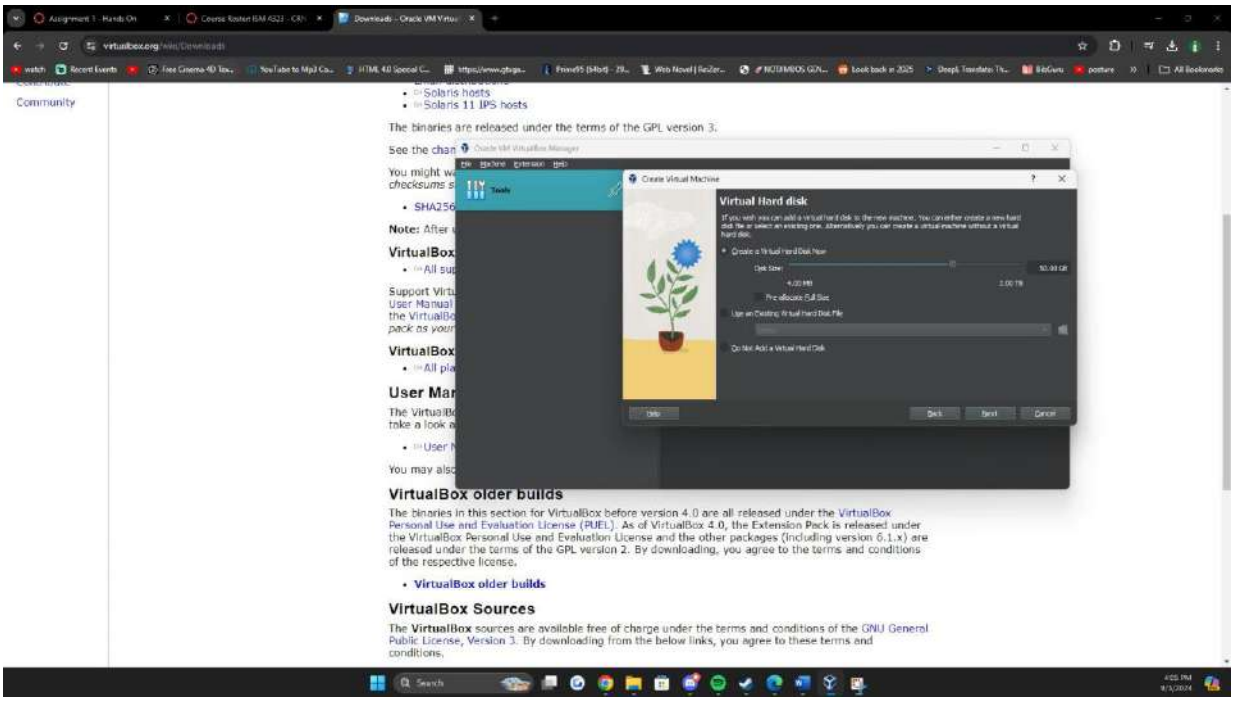
5. be sure that the Type: box displays Microsoft windows and the Version: box changes to windows 10 (xx-bit).

click Next.

6. under Memory size, accept the recommended size or increase the allocation if you have sufficient raM on your computer. click Next.



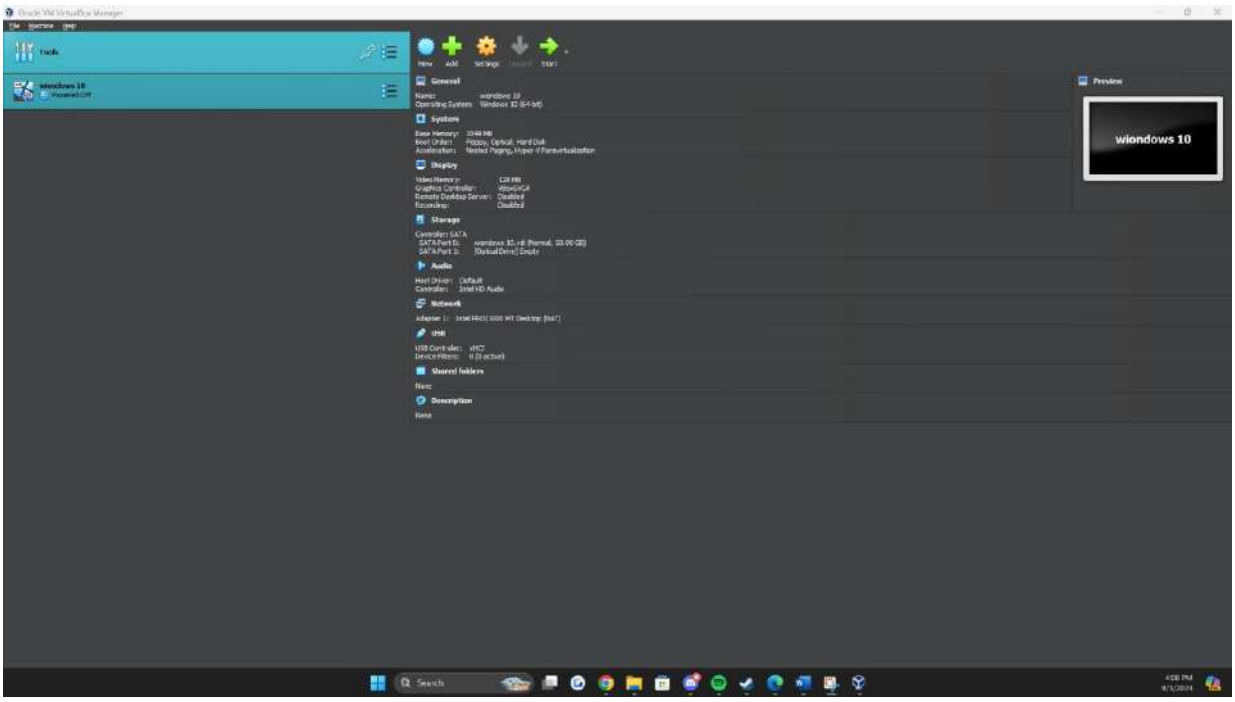
7. under hard disk, accept Create a virtual hard drive now. click Create.



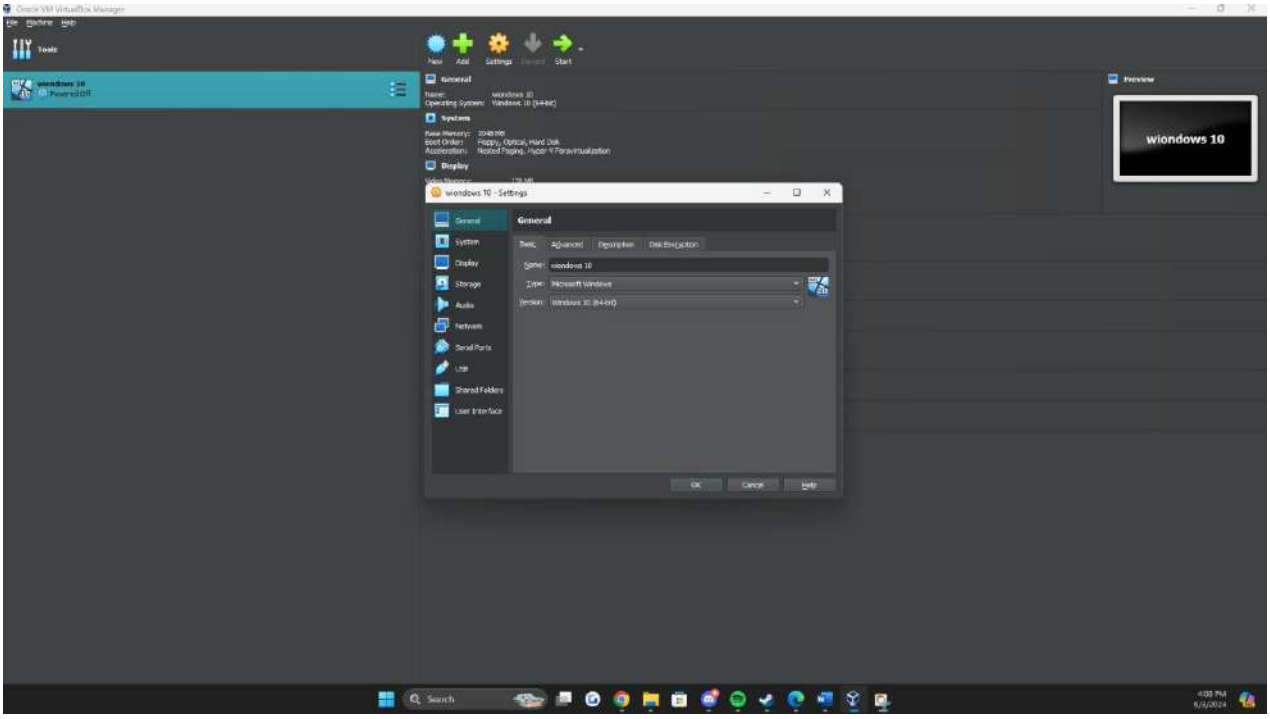
8. under hard drive file type, accept the default VId (VirtualBox disk Image). click Next.

9. under Storage on physical hard drive, accept the default dynamically allocated. click Next.

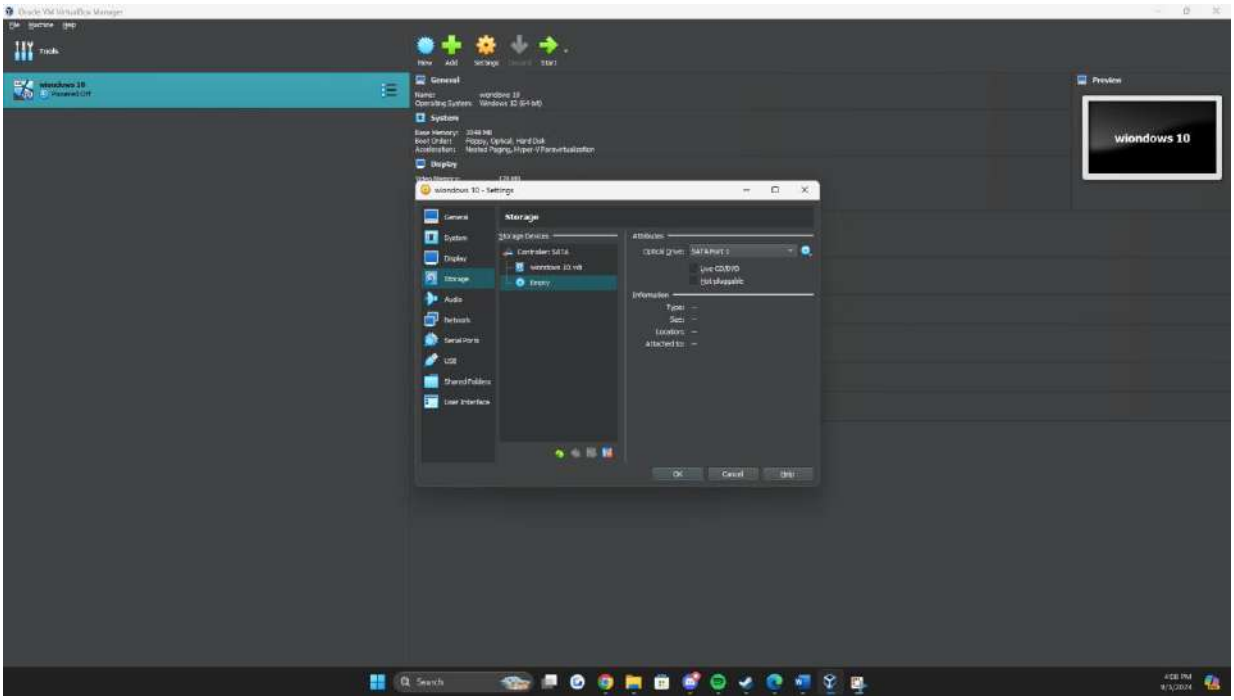
10. under File location and size, accept windows 10. click Create.



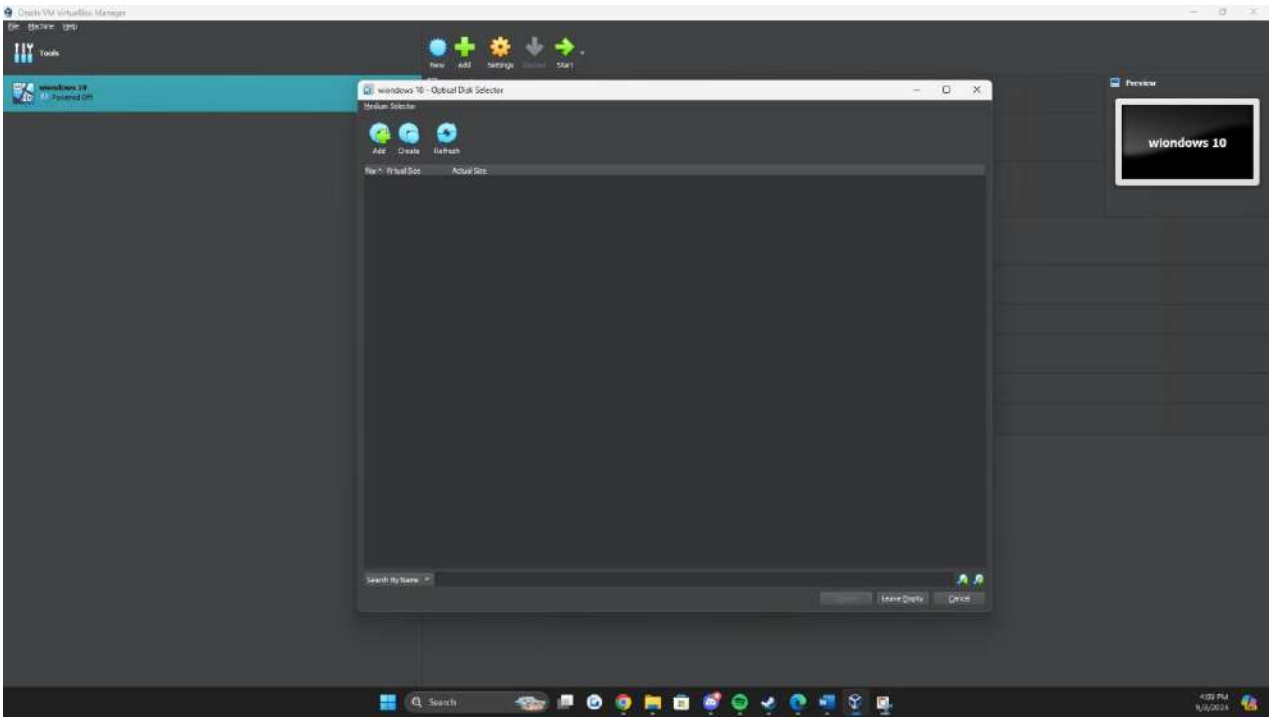
11. now the configuration settings for the virtual machine are set. next you will load the Windows 10 ISO image. click Settings.



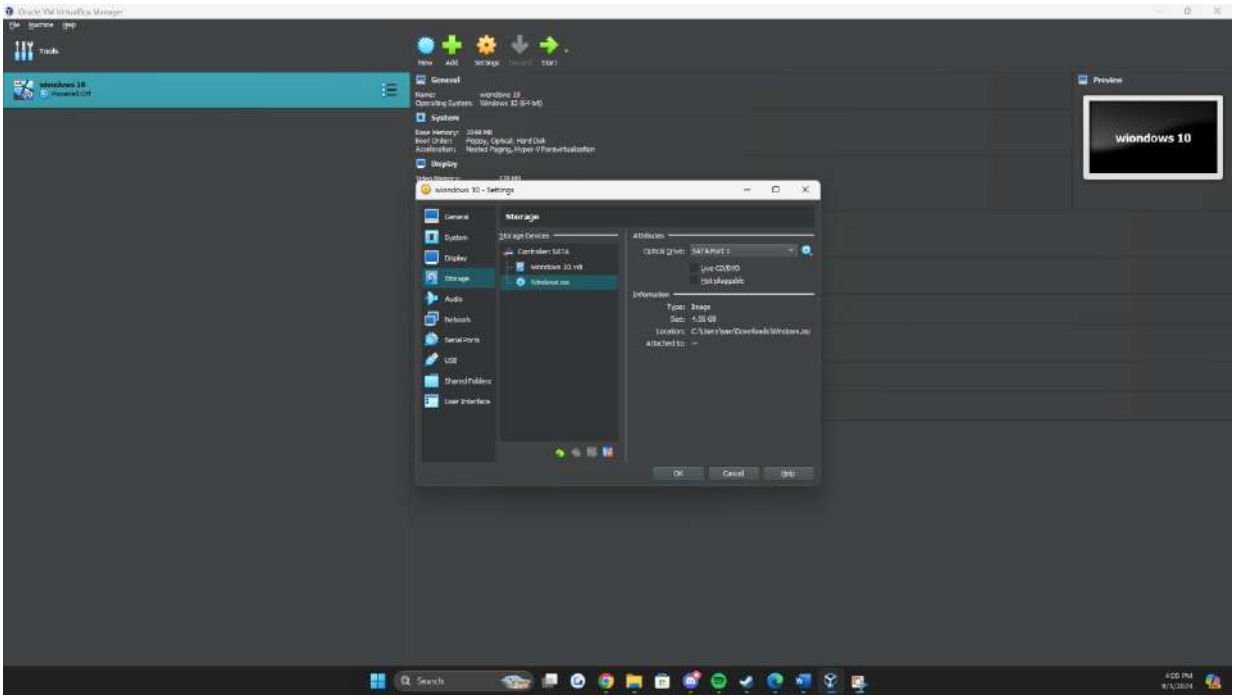
12. In the left pane, click Storage.
13. under controller: click empty.



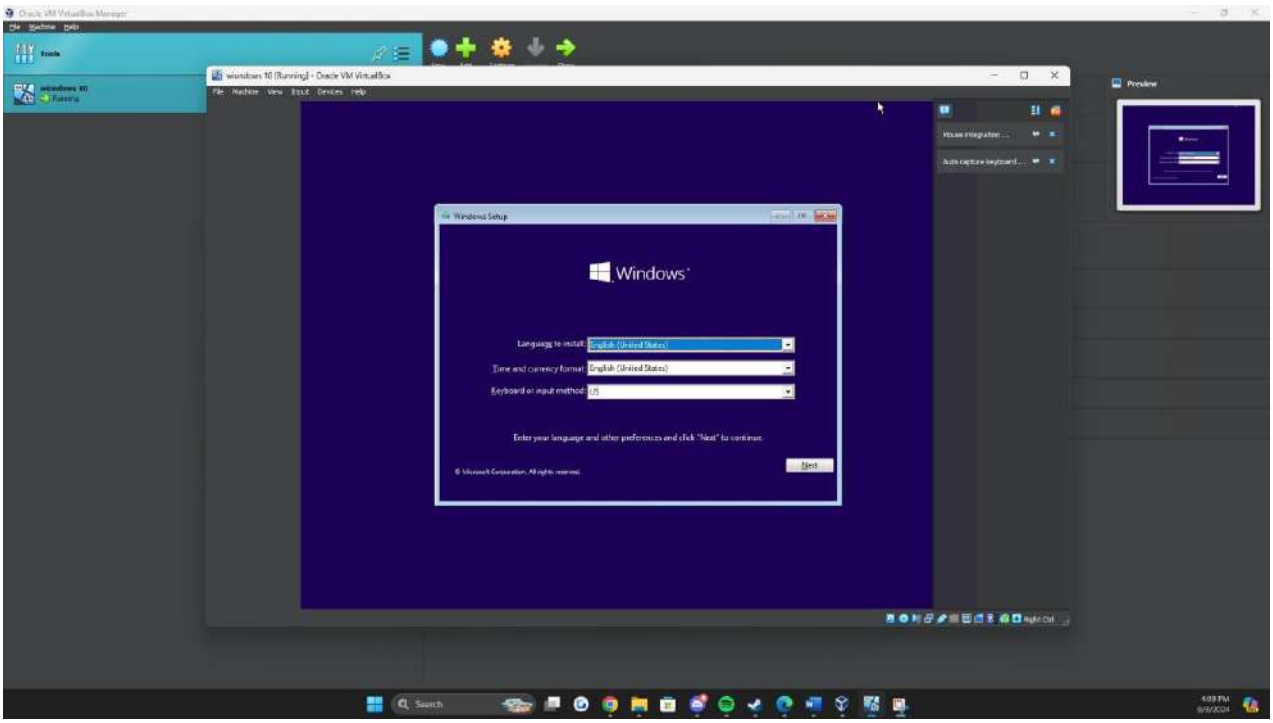
14. **In the right page under attributes, click the icon of the optical disc.**
15. **click Choose Virtual optical disk File.**



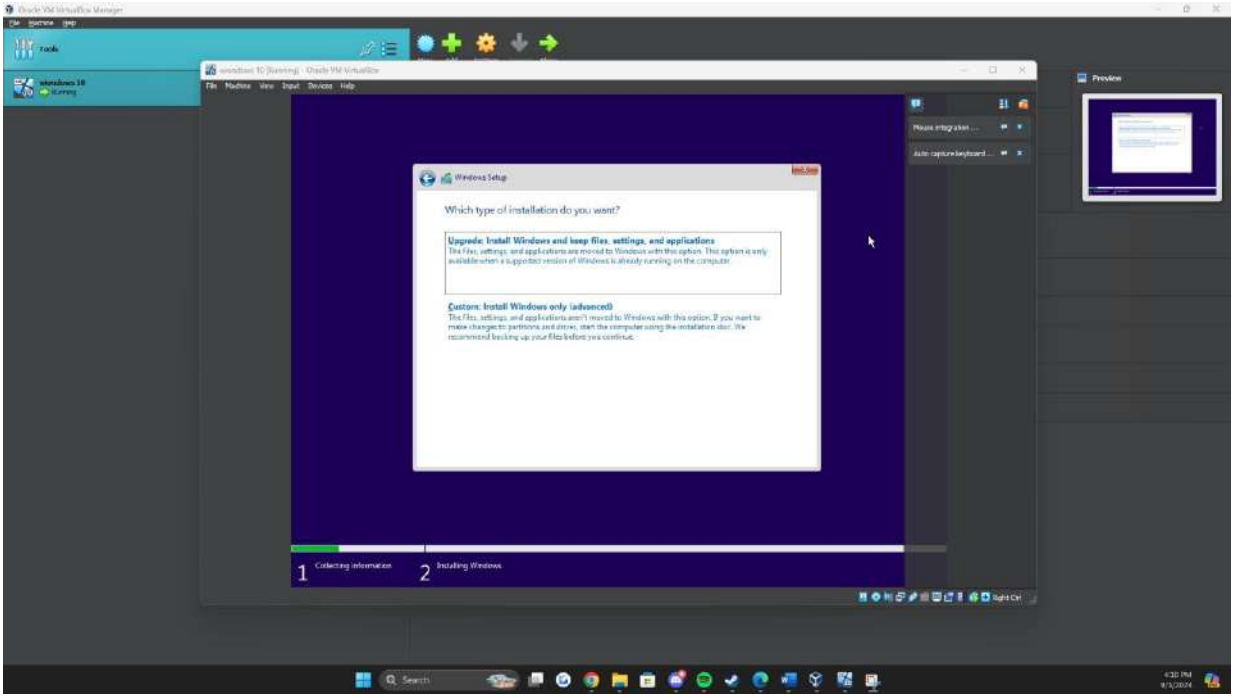
16. **navigate to the location of the Windows 10 ISo file and click open.**
17. **click ok.**



18. click Start to launch the Windows 10 ISo.



19. Follow the Windows 10 installation wizard to complete the installation.



20. **To close the Windows 10 guest operating system in Virtualbox, click File and then click exit.**

21. **close all windows.**

References

Microsoft. (n.d.). *What is a virtual machine (VM)?* Retrieved from Microsoft: https://azure.microsoft.com/en-us/resources/cloud-computing-dictionary/what-is-a-virtual-machine

Scale Computing. (2023, September 25). *Understanding Virtual Machine Advantages and Disadvantages*. Retrieved from Scale Computing: https://www.scalecomputing.com/resources/understanding-virtual-machine-advantages-and-disadvantages

Project 2-1: Exploring Common Vulnerabilities and Exposures (Bonus)

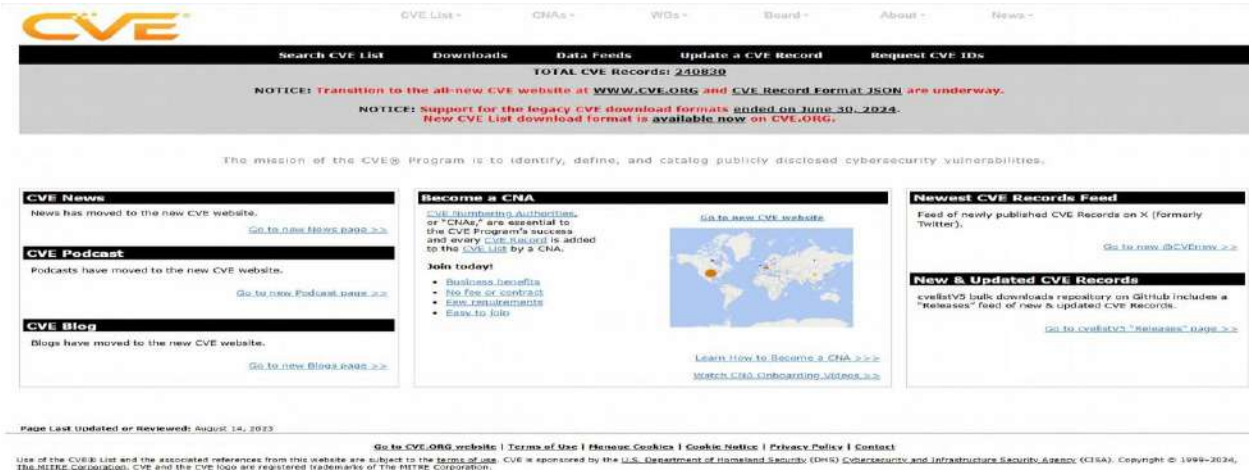
Objective: Summarize the techniques used in security assessments.

Description: Vulnerability feeds are available to provide updated information to scanning software about the latest vulnerabilities. One of the most highly regarded vulnerability feeds is the Mitre Common Vulnerabilities and Exposures (CVE). Feeds can also be manually examined for information on the latest vulnerabilities. In this project, you will learn more about CVE and view CVE information.

Introduction:

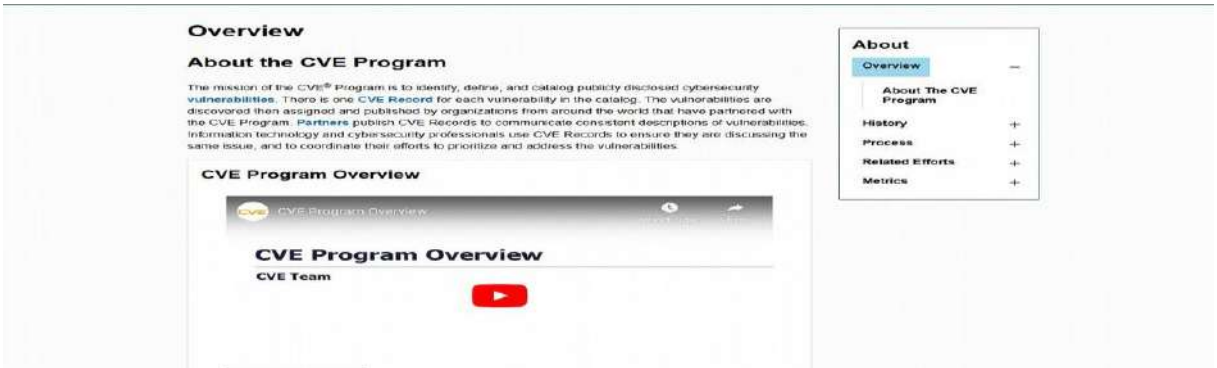
Vulnerabilities are a common reality for anyone in cybersecurity. The CVE allows anyone to monitor what these vulnerabilities are, when they occurred, and their severity, as well as the organization they occurred in. The monitoring and communication of this information can be essential in keeping everything safe and making sure vulnerabilities are patched promptly.

1. Open your web browser and enter the URL https://cve.mitre.org/ (if you are no longer able to access the site through this web address, use a search engine to search for “Mitre CVE”).



2. Click About.

3. Click About CVE.



4. This page gives a brief overview of CVE. Read through the information regarding CVE. In your own words, how would you describe it? How does it work? What advantages does it provide?

It identifies, catalogs, and defines cybersecurity vulnerabilities. When vulnerabilities are discovered, they are assigned and published by organizations around the world that have partnered with the program. These vulnerabilities can then be used to communicate consistent descriptions of vulnerabilities which can be used to coordinate efforts addressing vulnerabilities

5. Point to About.

6. Click FAQs to display more detailed information on CVE. Who is behind CVE? Who owns it? How is it used? How does CVE compare to a vulnerability database? How would you answer the argument that threat actors could use CVE?

It's owned by the “Mitre” corporation, which has been sponsored by a multitude of government agencies and is used to take in information and monitor vulnerabilities for agencies/companies. The CVE is very similar to the NVD and other vulnerability databases, but from what I've gathered it has a more governmental focus. I would say it's a valid argument that threat actors could use the CVE, which is why vulnerabilities should be posted a little bit after the agency/company has been notified of it. I also thinking having this posted promotes promptly fixing issues

7. Scroll down to CVE Entries. Describe the three elements that make up a CVE Entry

CVE Identifier (CVE-ID): This is a unique identifier assigned to the vulnerability or exposure. It usually follows a format like CVE-YYYY-NNNNN, where "YYYY" represents the year, the vulnerability was disclosed or assigned, and "NNNNN" is a sequential number. For example, CVE-2024-12345.

Description: This section provides a concise summary of the vulnerability or exposure. It includes details such as the nature of the vulnerability (e.g., buffer overflow, SQL injection), the impact it may have (e.g., remote code execution, information disclosure), and the affected software or hardware. The description aims to give a clear understanding of what the issue is and why it is significant.

References: This element includes links and citations to additional resources related to the vulnerability. This may include advisories from vendors, patches, or other relevant documents. References help users and security professionals find more detailed information and guidance on how to address the vulnerability.

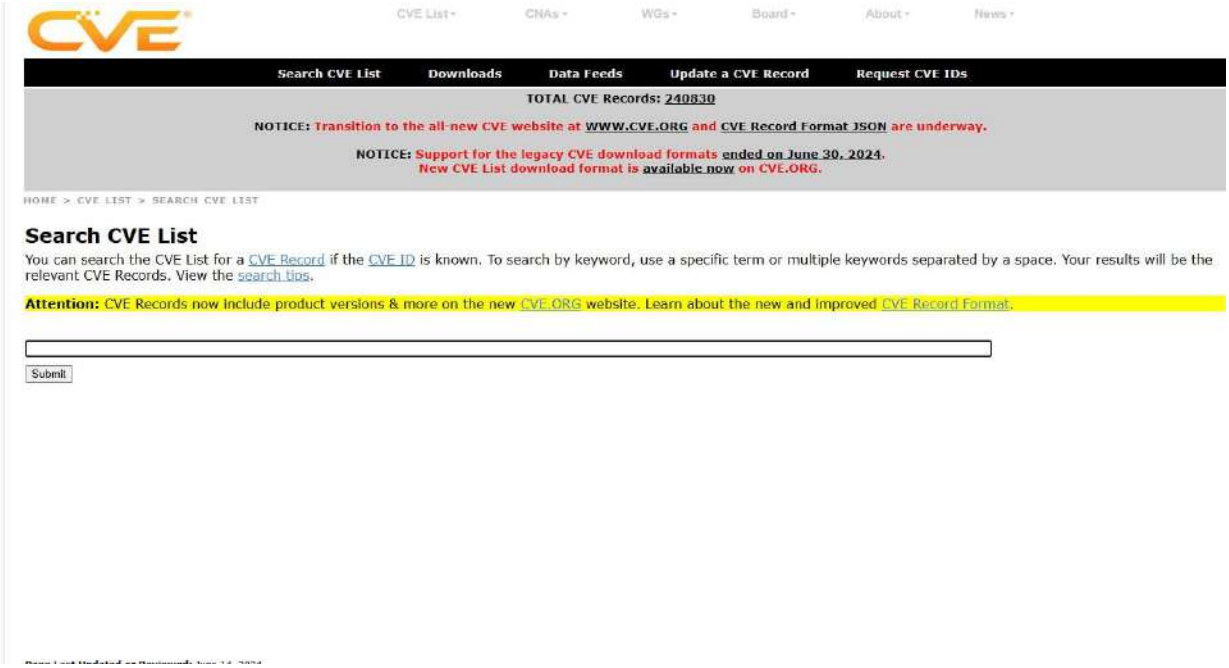
8. Scroll down to CVE List Basics. What is the process by which a vulnerability becomes a CVE listing? Who is involved in this process?

There is identification, reporting, review and assignment. This is then followed by drafting a description, compiling references, and then updating the database. The parties involved are CNA's, vulnerability reporters, Mitre, and affected vendors.

9. Click the link CVE Data Feeds. Scroll through the newest CVE entries feed. Were you aware of these vulnerabilities? How does the CVE distribute its information? Would you consider it sufficient? How can this be used by security personnel?

I was not aware of these vulnerabilities. The CVE distributes its information mainly by year from what is seen. I would consider it a decent way of distributing information, but not completely optimal. This can be used by security personel to see how vulnerabilities have evolved over time and from company to company so that they can prepare for what to expect

10. Click Search CVE List.



11. Enter a generic vulnerability such as passwords to display the CVE entries. How many are there that relate to this topic?

8610 results

There are **8610** CVE Records that match your search.

Name	Description
CVE-2024-8692	A vulnerability classified as critical was found in TDuckCloud TDuckPro up to 6.3. Affected by this vulnerability is an unknown functionality. The manipulation leads to weak password recovery. The attack can be launched remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2024-8687	An information exposure vulnerability exists in Palo Alto Networks PAN-OS software that enables a GlobalProtect end user to learn both the configured GlobalProtect uninstall password and the configured disable or disconnect passcode. After the password or passcode is known, end users can uninstall, disable, or disconnect GlobalProtect even if the GlobalProtect app configuration would not normally permit them to do so.
CVE-2024-8580	A vulnerability classified as critical was found in TOTOLINK AC1200 T8 4.1.5cu.861_B20230220. This vulnerability affects unknown code of the file /etc/shadow.sample. The manipulation leads to use of hard-coded password. The attack can be initiated remotely. The complexity of an attack is rather high. The exploitation appears to be difficult. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2024-8579	A vulnerability classified as critical has been found in TOTOLINK AC1200 T8 4.1.5cu.861_B20230220. This affects the function setWiFiRepeaterCfg of the file /cgi-bin/cstecgi.cgi. The manipulation of the argument password leads to buffer overflow. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2024-8428	The ForumWP – Forum & Discussion Board Plugin plugin for WordPress is vulnerable to Privilege Escalation via Insecure Direct Object Reference in all versions up to, and including, 2.0.2 via the submit_form_handler due to missing validation on the 'user_id' user controlled key. This makes it possible for authenticated attackers, with subscriber-level access and above, to change the email address of administrative user accounts which can then be leveraged to reset the administrative users password and gain access to their account.
CVE-2024-8369	The EventPrime – Events Calendar, Bookings and Tickets plugin for WordPress is vulnerable to unauthorized access to Private or Password-protected events due to missing authorization checks in all versions up to, and including, 4.0.4.3. This makes it possible for unauthenticated attackers to view private or password-protected events.
CVE-2024-8292	The WP-Recall – Registration, Profile, Commerce & More plugin for WordPress is vulnerable to privilege escalation/account takeover in all versions up to, and including, 16.26.8. This is due to to plugin not properly verifying a user's identity during new order creation. This makes it possible for unauthenticated attackers to supply any email through the user_email field and update the password for that user during new order creation. This requires the commerce addon to be enabled in order to exploit.
CVE-2024-8289	The MultiVendorX – The Ultimate WooCommerce Multivendor Marketplace Solution plugin for WordPress is vulnerable to privilege escalation/de-escalation and account takeover due to an insufficient capability check on the update_item_permissions_check and create_item_permissions_check functions in all versions up to, and including, 4.2.0. This makes it possible for unauthenticated attackers to change the password of any user with the vendor role, create new users with the vendor role, and demote other users like administrators to the vendor role.
CVE-2024-8268	The Frontend Dashboard plugin for WordPress is vulnerable to unauthorized code execution due to insufficient filtering on callable methods/functions via the ajax_request()

12. Select several of the CVE entries and read through the material.

Published: 2024-09-11 **Updated:** 2024-09-11
Title: TDuckCloud TDuckPro Password Recovery

Description

A vulnerability classified as critical was found in TDuckCloud TDuckPro up to 6.3. Affected by this vulnerability is an unknown functionality. The manipulation leads to weak password recovery. The attack can be launched remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CWE 1 Total

Learn more

- CWE-640: CWE-640 Weak Password Recovery

CVSS 4 Total

Learn more

Score	Severity	Version	Vector String
6.9	MEDIUM	4.0	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N
5.3	MEDIUM	3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
5.3	MEDIUM	3.0	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
5.0	—	2.0	AV:N/AC:L/Au:N/C:N/I:P/A:N

Product Status

Learn more

13. Locate a CVE entry that contains the tag Disputed. Click this entry. Under Description click **DISPUTED** to read about what constitutes a disputed CVE. Who would dispute a CVE? Why?

CNA: MITRE Corporation

Published: 2024-08-19 **Updated:** 2024-08-19

Tags: disputed

Description

Pi-hole before 6 allows unauthenticated admin/api.php?setTempUnit= calls to change the temperature units of the web dashboard. NOTE: the supplier reportedly does "not consider the bug a security issue" but the specific motivation for letting arbitrary persons change the value (Celsius, Fahrenheit, or Kelvin), seen by the device owner, is unclear.

Product Status

Learn more

Information not provided

References

- https://github.com/pi-hole/web/pull/3077
- https://www.kiyell.com/The-Harmless-Pihole-Bug/

There are many things that can constitute a dispute, but some are accuracy of information, or duplicate entries. This can be done by vendors, researchers, the CNA, or security teams. This is all essential for the accuracy of information

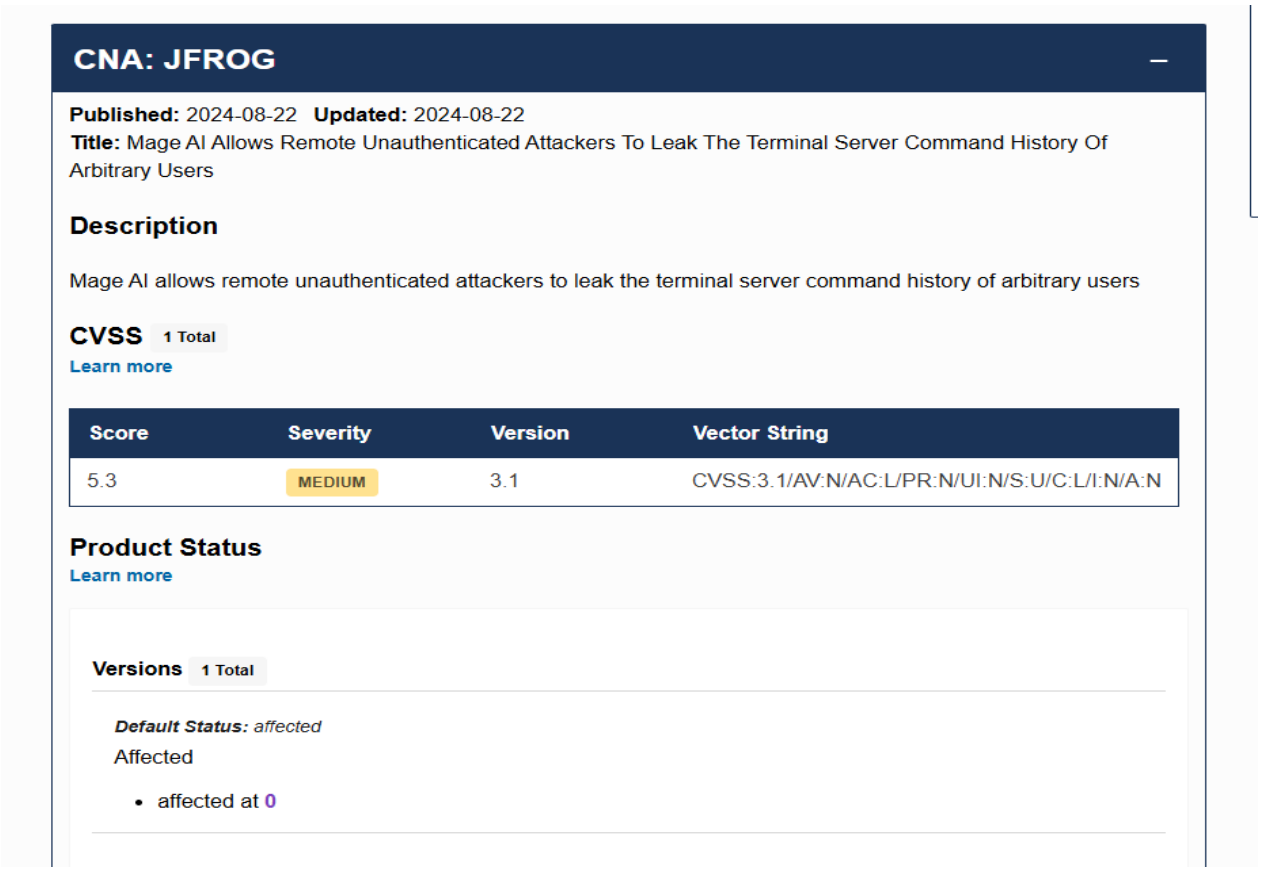
14. Click Search CVE List.

“leak”

There are **3533** CVE Records that match your search.

Name	Description
CVE-2024-8072	Mage AI allows remote unauthenticated attackers to leak the terminal server command history of arbitrary users
CVE-2024-7978	Insufficient policy enforcement in Data Transfer in Google Chrome prior to 128.0.6613.84 allowed a remote attacker who convinced a user to engage in specific UI gestures to lea cross-origin data via a crafted HTML page. (Chromium security severity: Medium)
CVE-2024-7884	When a canister method is called via ic_cdk::call* , a new Future CallFuture is created and can be awaited by the caller to get the execution result. Internally, the state of the Fut is tracked and stored in a struct called CallFutureState. A bug in the polling implementation of the CallFuture allows multiple references to be held for this internal state and not a references were dropped before the Future is resolved. Since we have unaccounted references held, a copy of the internal state ended up being persisted in the canister's heap a thus causing a memory leak. Impact Canisters built in Rust with ic_cdk and ic_cdk_timers are affected. If these canisters call a canister method, use timers or heartbeat, they wil likely leak a small amount of memory on every such operation. In the worst case, this could lead to heap memory exhaustion triggered by an attacker. Motoko based canisters ar affected by the bug. PatchesThe patch has been backported to all minor versions between >= 0.8.0, <= 0.15.0. The patched versions available are 0.8.2, 0.9.3, 0.10.1, 0.11.6, 0.12.2, 0.13.5, 0.14.1, 0.15.1 and their previous versions have been yanked. WorkaroundsThere are no known workarounds at the moment. Developers are recommended to upgrade their canister as soon as possible to the latest available patched version of ic_cdk to avoid running out of Wasm heap memory. Upgrading the canisters (without updating `ic_cdk`) also frees the leaked memory but it's only a temporary solution.
CVE-2024-7786	The Sensei LMS WordPress plugin before 4.24.2 does not properly protect some its REST API routes, allowing unauthenticated attackers to leak email templates.
CVE-2024-7526	ANGLE failed to initialize parameters which led to reading from uninitialized memory. This could be leveraged to leak sensitive data from memory. This vulnerability affects Firefox 129, Firefox ESR < 115.14, Firefox ESR < 128.1, Thunderbird < 128.1, and Thunderbird < 115.14.
CVE-2024-7340	The Weave server API allows remote users to fetch files from a specific directory, but due to a lack of input validation, it is possible to traverse and leak arbitrary files remotely. In various common scenarios, this allows a low-privileged user to assume the role of the server admin.
CVE-2024-7246	It's possible for a gRPC client communicating with a HTTP/2 proxy to poison the HPACK table between the proxy and the backend such that other clients see failed requests. It's a possible to use this vulnerability to leak other clients HTTP header keys, but not values. This occurs because the error status for a misencoded header is not cleared between hea reads, resulting in subsequent (incrementally indexed) added headers in the first request being poisoned until cleared from the HPACK table. Please update to a fixed version of g as soon as possible. This bug has been fixed in 1.58.3, 1.59.5, 1.60.2, 1.61.3, 1.62.3, 1.63.2, 1.64.3, 1.65.4.
CVE-2024-6984	An issue was discovered in Juju that resulted in the leak of the sensitive context ID, which allows a local unprivileged attacker to access other sensitive data or relation accessible the local charm.
CVE-2024-6388	Marco Trevisan discovered that the Ubuntu Advantage Desktop Daemon, before version 1.12, leaks the Pro token to unprivileged users by passing the token as an argument in plaintext.
CVE-2024-6323	Improper authorization in global search in GitLab EE affecting all versions from 16.11 prior to 16.11.5 and 17.0 prior to 17.0.3 and 17.1 prior to 17.1.1 allows an attacker leak

15. Enter a different vulnerability and select several entries to read through its details.



16. Close all windows

References:

Mitre. (1999). *CVE website*. CVE Website. https://www.cve.org/

Case project 2-1: False Positives and False Negatives

Use the Internet to research false positives and false negatives. Which is worse? If a doctor gives information to a patient about the results of a diagnostic test, is a false positive or a false negative worse? What about facial recognition scanning for a criminal? Which is worse for a vulnerability scan, a false positive or a false negative? Write a one-page paper on your findings and analysis

Introduction:

in cybersecurity, understanding the implications of false positives and false negatives is crucial for maintaining the effectiveness of security measures and ensuring the integrity of systems. Both types of errors can have significant impacts, but their severity and implications vary depending on the context.

A false positive in cybersecurity occurs when a security tool or vulnerability scanner incorrectly identifies a non-existent threat or vulnerability. For instance, a vulnerability scanner might flag a benign software component as a security risk. This can lead to several issues such as rescource drain, operational disruptions, or alert fatigue. Resource drain is when time and resources are spent investigating and mitigating non-existent threats, which can divert attention from real security concerns. Operational Disruptions: False positives can lead to unnecessary changes or patches being applied, potentially disrupting normal operations or causing system instability. And an example of alert fatigue would be Frequent false positives that can desensitize security teams to alerts, potentially leading them to overlook genuine threats.

On the other hand, a false negative occurs when a security tool fails to detect an actual threat or vulnerability. This error can have more severe consequences like security breaches, increased risk factors, and delayed responses. For security breaches, a missed vulnerability can be exploited by attackers, leading to data breaches, financial loss, or damage to the organization's reputation. Meanwhile the failure to identify real threats means that attackers have a higher chance of successfully compromising systems without detection would be the increased risk. For delayed responses, the longer a real threat goes undetected, the more damage it can cause, and the harder it can be to mitigate once discovered.

When evaluating which type of error is worse, in my opinion its false negatives because they generally pose a greater risk. This is because the primary goal of security measures is to detect and mitigate genuine threats to protect systems and data. A false negative can leave systems exposed to actual attacks, potentially leading to severe consequences including data breaches, financial loss, and reputational damage.

Although false positives can be disruptive and lead to inefficiencies, they do not pose the same level of risk as false negatives. False positives typically result in operational inefficiencies and increased workload, but they do not inherently expose the system to real threats. The critical nature of identifying and responding to actual vulnerabilities makes false negatives more dangerous and impactful.

Regarding false positives and negatives, false negatives are more detrimental compared to false positives. The primary concern is to ensure that all real threats are identified and addressed to prevent security breaches and protect sensitive information. While false positives can lead to inefficiencies and operational disruptions, the risk of not detecting a genuine threat is significantly higher and more damaging. Therefore, cybersecurity professionals must focus on reducing false negatives to enhance the overall security of their systems.

References:

Santos, M. (2021, September 22). *False positives vs. false negatives*. Medium. https://towardsdatascience.com/false-positives-vs-false-negatives-4184c2ff941a

Case Project 2-3: Vulnerability Scanners

Search the Internet for information on Nessus. Then search for two other vulnerability scanners. Create a table that compares their features. Which would you choose? Why

Introduction

Nessus is a vulnerability scanner by Tenable which helps expose and close weaknesses across a computer and gives a highly detailed report (Tenable, n.d.). Besides Nessus, there are other vulnerability scanner which will be discussed in this case project, which are mainly used to assess a business' cybersecurity in several aspects. The scanners can be used to check networks, systems, applications, security vulnerabilities, and more.

NESSUS	Invicti	Stackhawk
Web application scans, external attack surface scans, cloud infrastructure scans	Scan websites, applications, API, cloud	Run as many scans across all applications and environments, and with unlimited access for users.
Unlimited IT vulnerability assessments	Ai Risk prediction	Designed for development environments for people coding
Vulnerability scoring with CVSS v4, EPSS and VPR	Finds every high-risk vulnerability, great accuracy	Track scan data and gain insight into vulnerabilities over time and across environments.
Configuration, compliance and security audits	Report with assistance in fixing and locating vulnerabilities	Automation and notifications to speed up fixes
Configurable reports	Security automation with configurable automatic fixes and scans	Scan validation and authentication to scan all applications
On-demand training and advanced support	Tracking analytics, notifications, and configuration	API support & regular custom support
Free 7-day trial, but several thousand to	Demo, need a quote to purchase (probably in the	14 day free trial, $42-$59 per code contributor

purchase	thousands)	

References

Invicti. (n.d.). *How Invicti paves your road to security*. Retrieved from invicti: https://www.invicti.com/features/

Microsoft. (n.d.). *What is a virtual machine (VM)?* Retrieved from Microsoft: https://azure.microsoft.com/en-us/resources/cloud-computing- dictionary/what-is-a-virtual-machine

Scale Computing. (2023, September 25). *Understanding Virtual Machine Advantages and Disadvantages*. Retrieved from Scale Computing: https://www.scalecomputing.com/resources/understanding-virtual-machine-advantages-and-disadvantages

Stackhawk. (n.d.). *Application Security at the*. Retrieved from Stackhawk: https://www.stackhawk.com/pricing/

Tenable. (n.d.). *Nessus Vulnerability Scanner: Network Security Solution*. Retrieved from Tenable: https://www.tenable.com/products/nessus

Assignment 2 – Hands On

Sam Peller

September 12, 2024

ISM 4323

Project 3-1: analyze File and Url for File-Based Viruses Using VirusTotal—part 1

Time required: 25 minutes

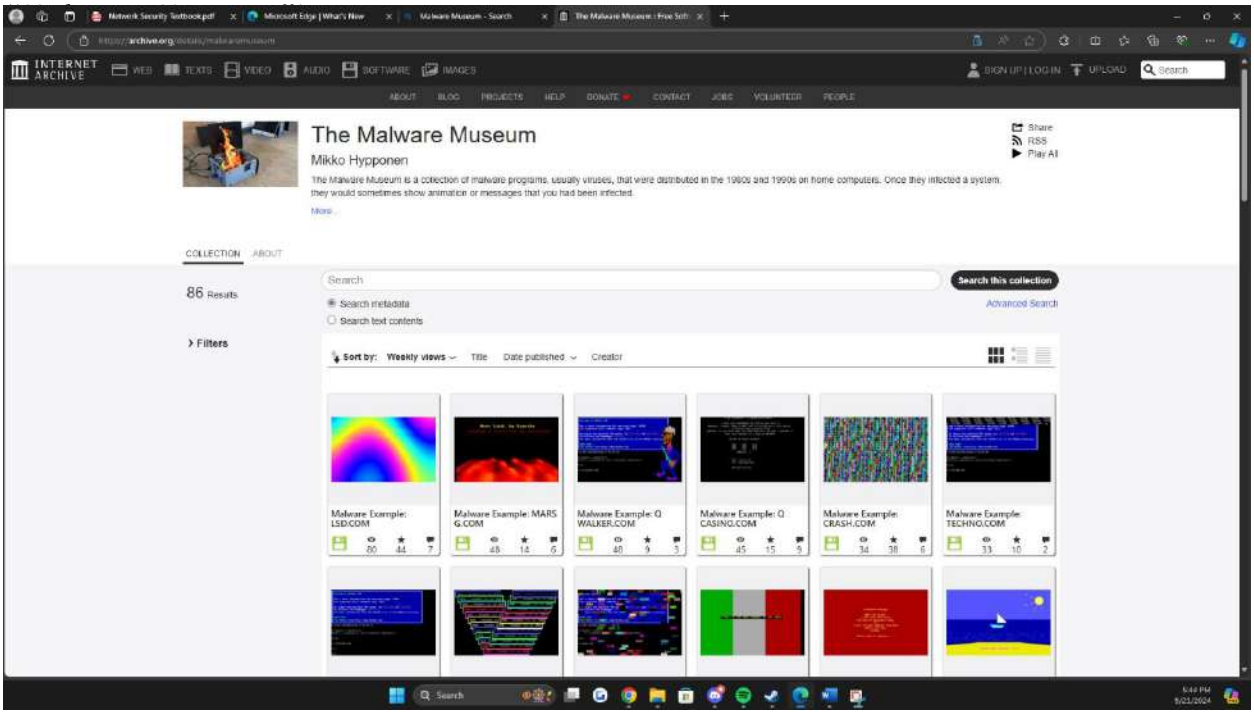
objective: Given a scenario, analyze potential indicators to determine the type of attack.

description: VirusTotal is a free online service that analyzes files and urls to identify potential malware. VirusTotal combines 70 antivirus scanners and url/domain blacklisting services along with other tools to identify malware. A wide range of files can be submitted to VirusTotal for examination, such as user data files and documents, executable programs, pdFs, and images. one of the uses of VirusTotal is to provide a "second opinion" on a file or url that may have been flagged as suspicious by other scanning software. In this project, you use VirusTotal to scan a file and a url.

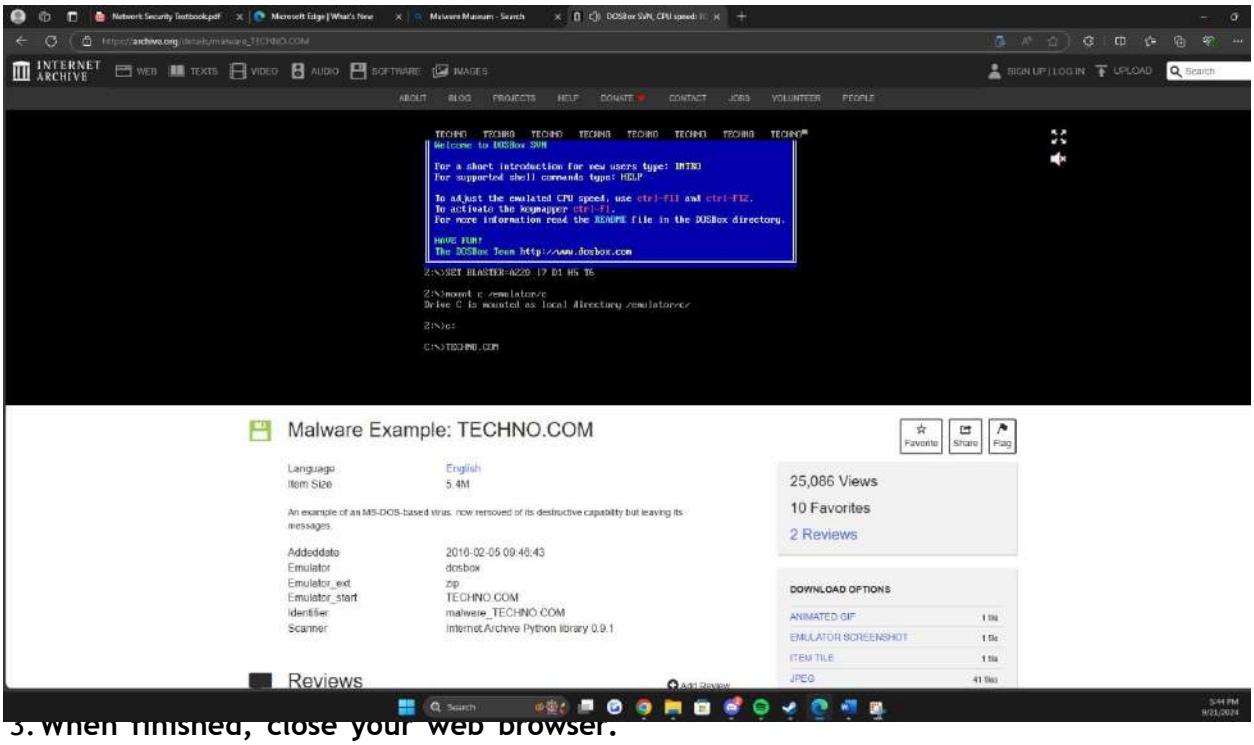
INTRODUCTION

When clicking a link sent by someone you don't trust or downloading a file, it's always good to do a quick double check to make sure nothing bad is going on. VirusTotal was made for things like this, as it states it, "Analyse suspicious files, domains, IPs and URLs to detect malware and other breaches," (VirusTotal, n.d.) Files and URLs are two major sources of cyber-attacks when it comes to executables and cross-site scripting. A free tool to keep you safe online.

1. **First view several viruses from 20 years ago and observe their benign but annoying impact. open your web browser and enter the url archive.org/details/malwaremuseumstab=collection (if you are no longer able to access the site through the web address, use a search engine to search for**

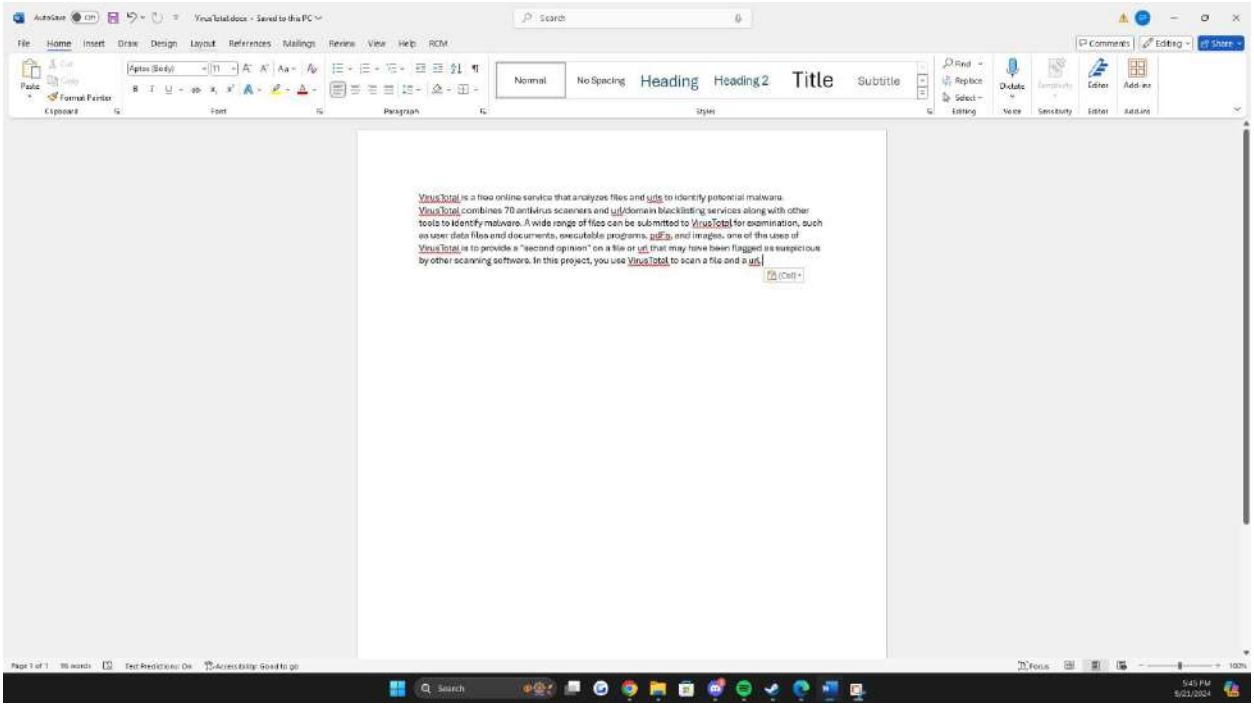


2. **All of the viruses have been rendered ineffective and will not harm a computer. click several of the viruses and notice what they do.**



3. **When finished, close your web browser.**

4. **use Microsoft Word to create a document that contains the preceding paragraph description about VirusTotal. save the document as**

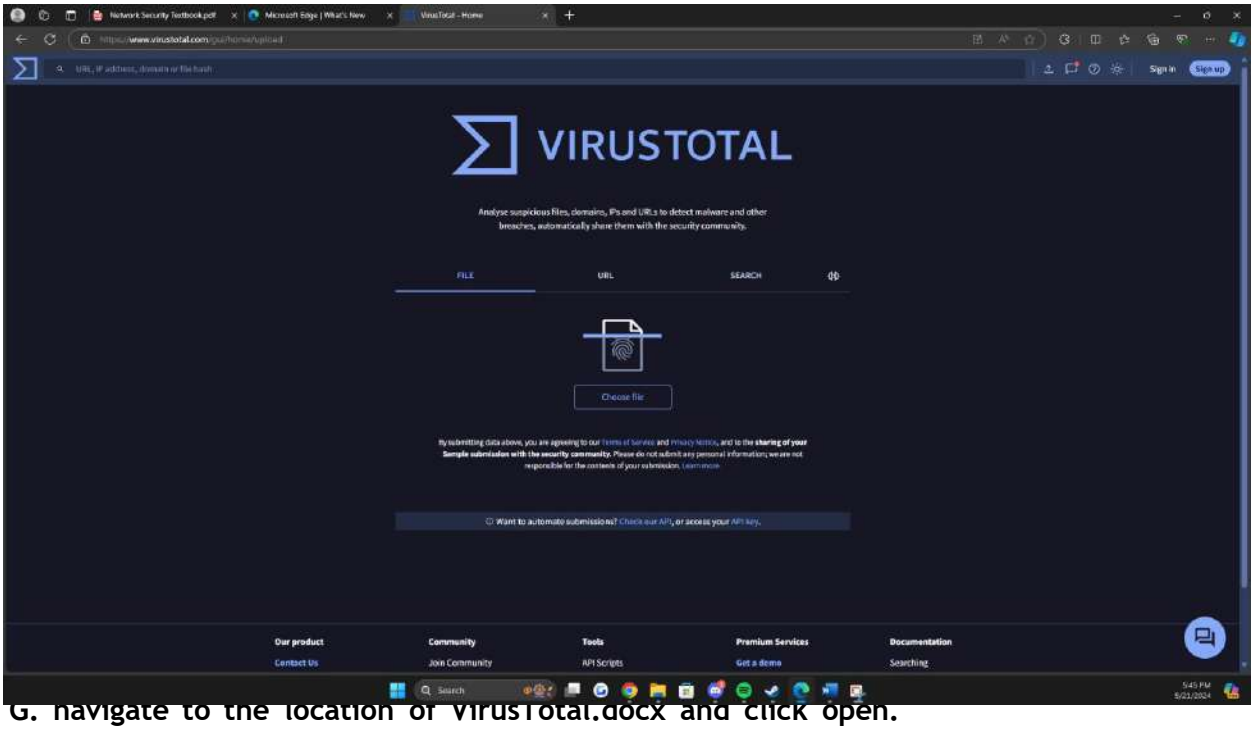


5. **exit Word.**

6. **open your web browser and enter the url www.virustotal.com (if you are no longer able to access the site through the web address, use a search engine to search for "Virus Total").**

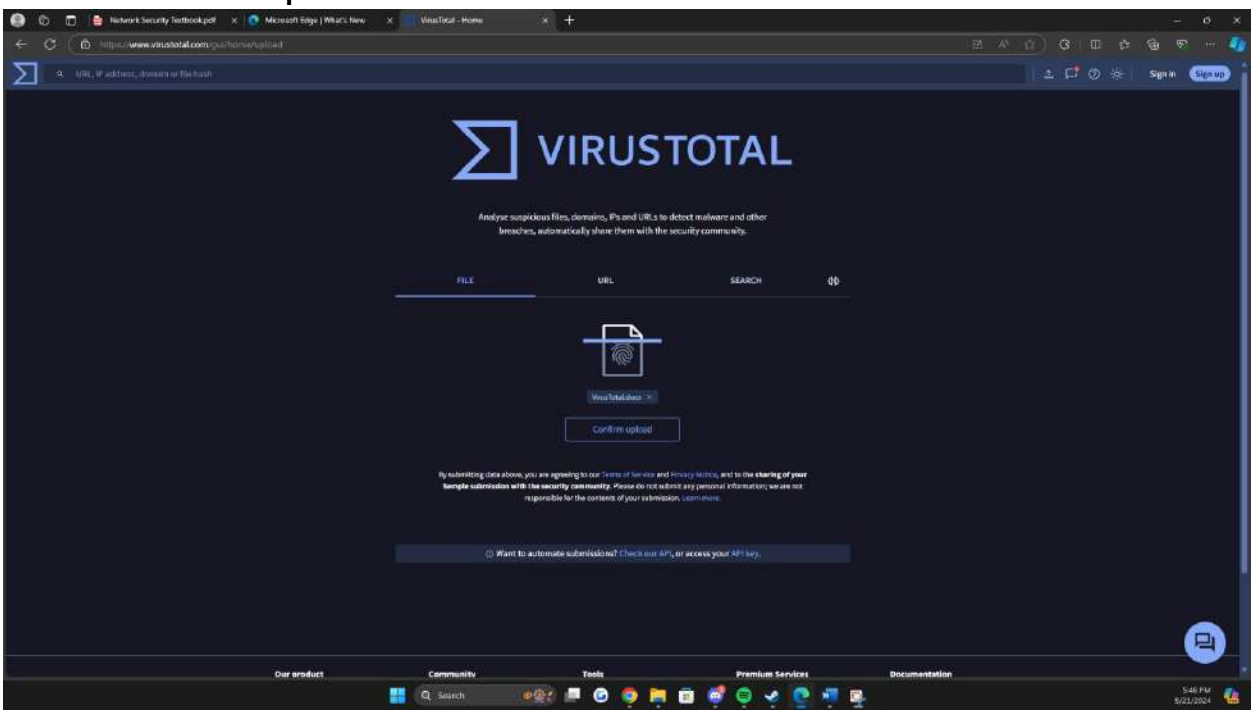
7. **If necessary, click the File tab.**

8. **click Choose File.**



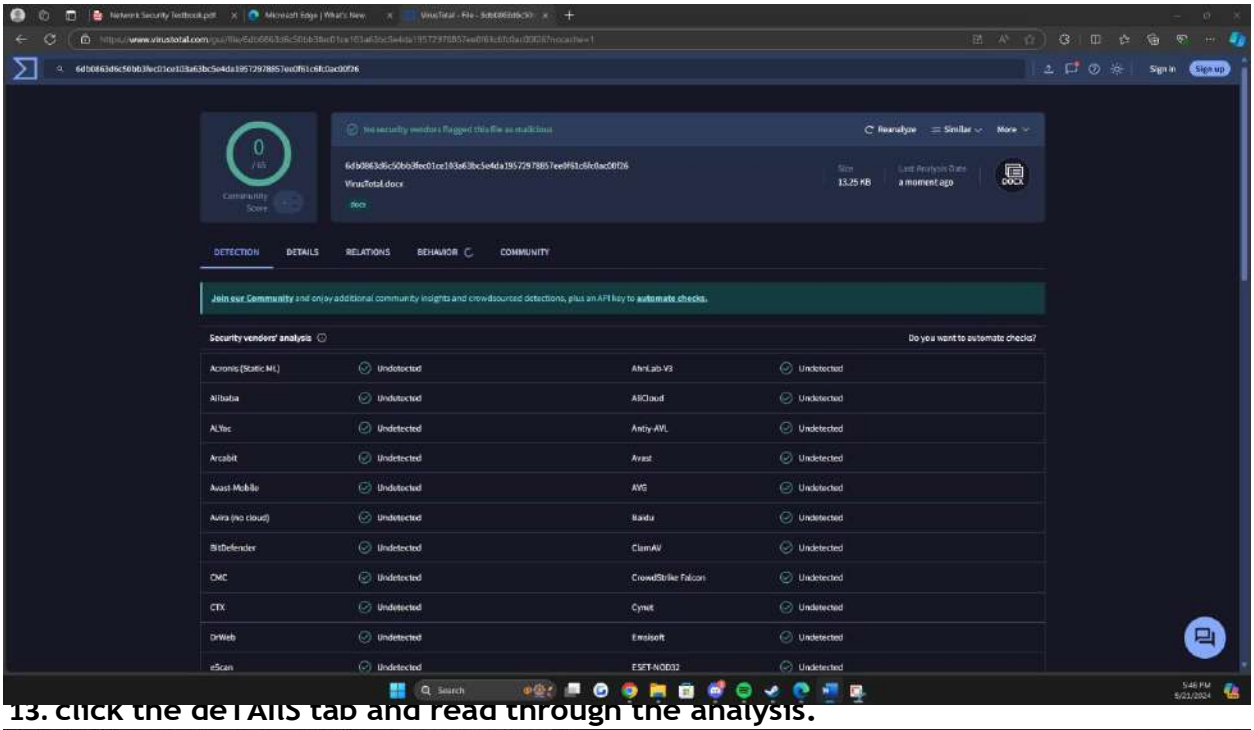
9. **navigate to the location of VirusTotal.docx and click open.**

10. **click Confirm upload.**

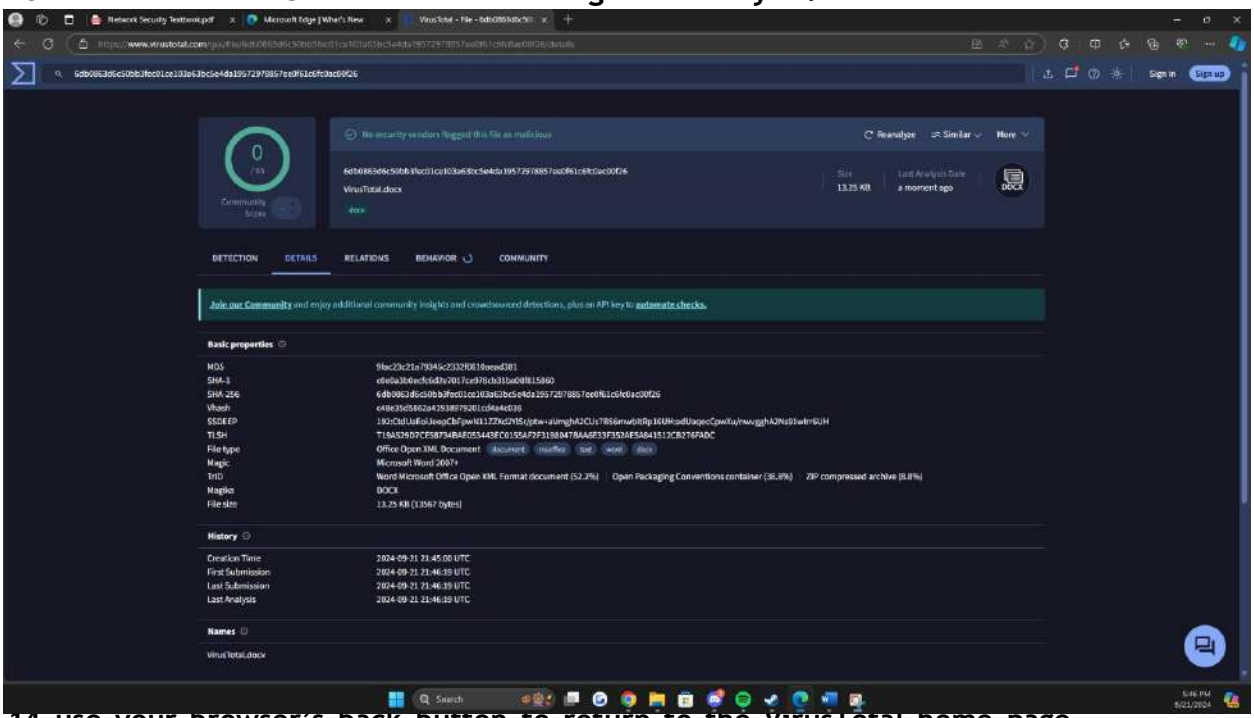


11. Wait until the upload and analysis are completed.

12. scroll through the list of antivirus (AV) vendors that have been polled regarding this file. A green checkmark means no malware was detected.



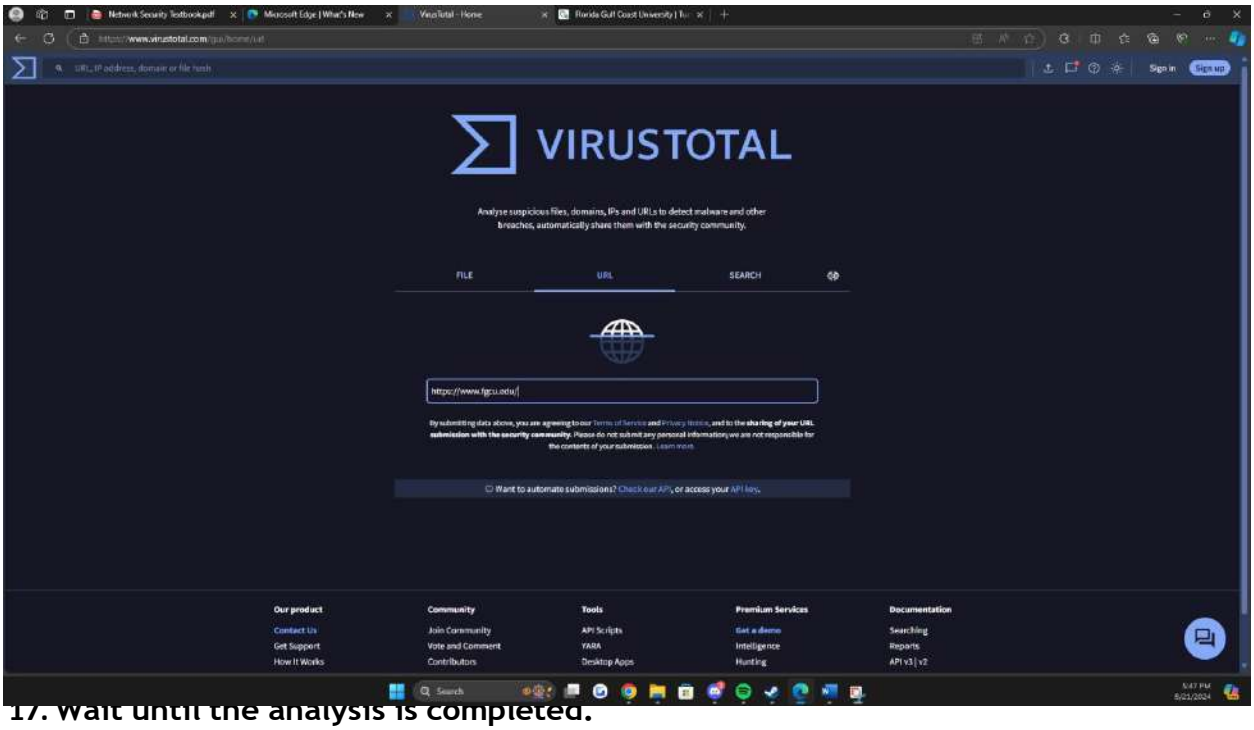
13. click the details tab and read through the analysis.



14. use your browser's back button to return to the VirusTotal home page.

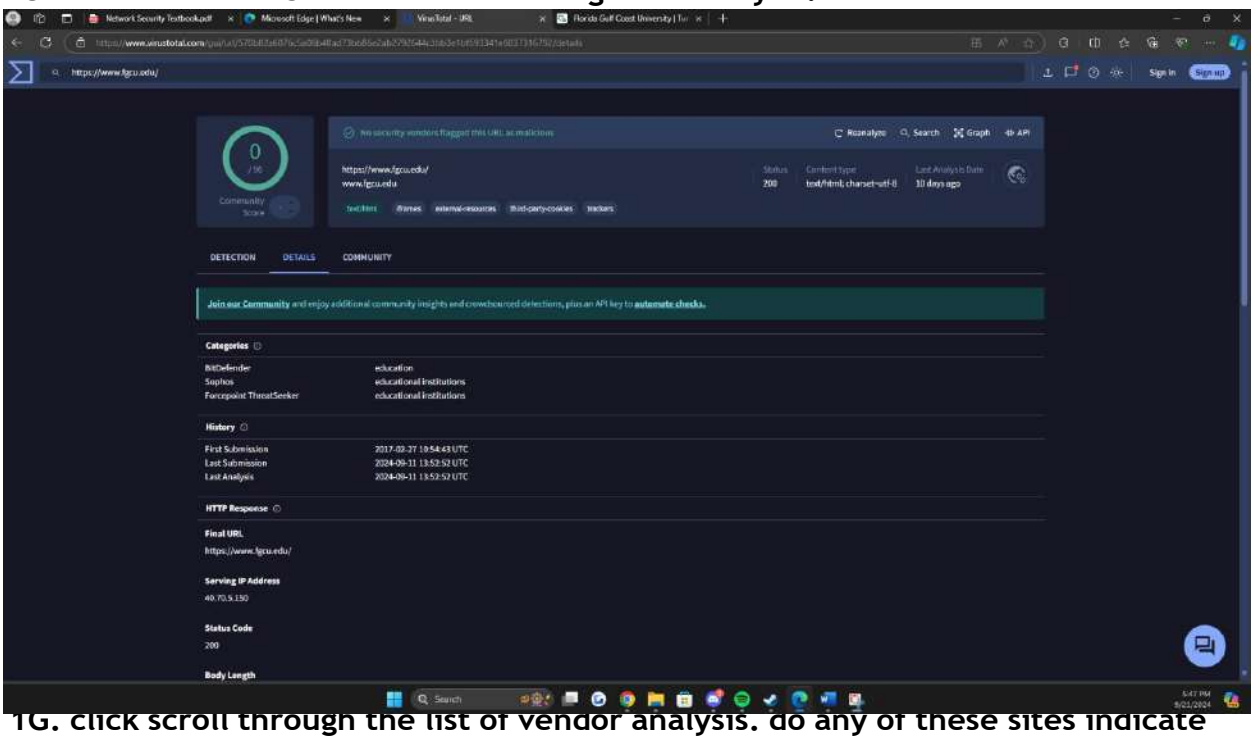
15. now you will analyze a website. click url.

16. **enter the url of your school, place of employment, or another site with which you are familiar.**



17. **Wait until the analysis is completed.**

18. **click the deTAIlS tab and read through the analysis.**



19. **click scroll through the list of vendor analysis. do any of these sites indicate unrated site or Malware site? Yes, at least 25.**

20. **how could VirusTotal be useful to users? how could it be useful to security researchers? could it also be used by attackers to test their own malware before distributing it to ensure that it does not trigger an AV alert? What should be the protections against this?**

Most users when downloading something or visiting a site want to know if it is safe to do so, personally I've used virustotal in these situations to ensure my safety. Safety researchers can use it to analyze new malware or see how accurate threat intelligence is. It could be used my attackers to test their own malware, but I'm sure at least one of these constantly updating antivirus' would be able to detect it. It would also be advantageous for virustotal to rate limit submissions to ensure that this wouldn't happen.

21. **close all windows**

Case project 3-2: LOLBins

Prompt: Fileless viruses take advantage of native services and processes that are part of the OS to avoid detection and carry out their attacks. These native services used in a fileless virus are called living-off-the-land binaries (LOLBins). Use the Internet to research fileless viruses and LOLBins.
When did fileless viruses first appear? How do they compare with file-based viruses? What are the defenses against fileless viruses? Write a one-page paper on your research

Introduction:

Fileless viruses represent a growing threat in the cybersecurity landscape, they leverage native operating system services and processes to execute attacks without relying on traditional files. These malicious entities utilize living-off-the-land binaries (LOLBins), which are legitimate tools within the OS, making them difficult to detect and mitigate[1]. This paper will explore the history of fileless viruses, their differences from file-based viruses, and potential defenses against these sophisticated attacks.

Fileless malware has its roots in the early 2010s, but it gained significant attention around 2017 with high-profile attacks such as the PowerShell-based attacks used in the Equifax breach[2]. Unlike traditional malware that requires a malicious file to be downloaded or executed, fileless viruses execute directly in memory, leveraging built-in OS tools and scripts, particularly PowerShell and Windows Management Instrumentation. This evolution has led to an increase in the use of fileless techniques among cybercriminals, as they can bypass traditional detection methods that focus on file-based signatures.

File-based viruses essentially operate by infecting files on a system, which often relies on user interaction to spread. They can be detected through signature-based antivirus solutions, which scan for known malicious files. In contrast, fileless viruses are more elusive; they often reside only in memory and do not leave traditional footprints on disk. This means they can execute their payloads without triggering alerts from conventional security measures[3]. The use of LOLBins adds another layer of complexity, as these are trusted system tools that can be manipulated for malicious purposes, further obscuring the attacker's presence.

Defending against fileless attacks requires a multi-faceted approach. The first being Behavioral Analysis which would utilize Security solutions that analyze the behavior of processes to identify anomalies indicative of fileless malware, such as unusual PowerShell[4] commands or

[1] (K7, 2022)
[2] (Adebayo, 2023)
[3] (Staff, 2024)
[4] (Neagu, 2023)

WMI queries. Another beneficial solution would be EDR solutions to provide real-time monitoring and response capabilities, focusing on the behavior of running processes rather than just file- based indicators[5]. Also, Application Whitelisting allows only approved applications and scripts to run, organizations can significantly reduce the attack surface available to fileless malware.
Meanwhile you could use PowerShell Constrained Language Mode which restricts the functionality of PowerShell, limiting what scripts can do and thereby reducing the potential for abuse. Finally, user education and awareness can train users to recognize phishing attempts, and suspicious activity can help prevent the initial compromise that often leads to fileless attacks.

Fileless viruses pose a significant challenge to cybersecurity due to their ability to evade traditional detection mechanisms by utilizing native OS services and tools. As they become more prevalent, it is crucial for organizations to adopt advanced detection methods and robust security practices. By focusing on behavior-based analysis, endpoint protection, and user education, organizations can strengthen their defenses against this evolving threat. The landscape of malware continues to shift, and staying informed about these trends is essential for effective cybersecurity strategies.

[5] (Floreza, 2018)

References:

Adebayo, K. S. (2023, December 8). *Equifax's lessons are still relevant, 5 years later*. Equifax's Lessons Are Still Relevant, 5 Years Later. https://www.darkreading.com/cyberattacks-data- breaches/5-years-after-the-equifax-breach-industry-experts-share-new-insights

Fileless malware and LOLBins: Everything you should know. k7 Security. (2022, September 20). https://blog.k7computing.com/fileless-malware-and-lolbins-everything-you-should- know/#:~:text=Significant%20cyber-attacks%20exploiting%20LOLBins-%20A%20Timeline.

Floreza, S. (2018). *Security 101: Defending against fileless malware*. Trend Micro (US). https://www.trendmicro.com/vinfo/us/security/news/security-technology/security-101- defending-against-fileless-malware#:~:text=Fileless%20malware%20are%20a%20growing%20threat

Neagu, C. (2023, August 15). *What is PowerShell and how do you use it?*. Digital Citizen. https://www.digitalcitizen.life/simple-questions-what-powershell-what-can-you-do-it/#:~:text=PowerShell%20is%20a%20powerful%20scripting%20language

Staff, E. (2024, August 19). *File-infecting virus*. DevX. https://www.devx.com/terms/file-infecting- virus/#:~:text=A%20file-infecting%20virus%20is%20a%20type%20of%20malicious,causing%20damage%2C%20data%20corruption%2C%20or%20other%20unwanted%20effects.

project 5-1: creating and using Qr codes

Time required: 15 minutes

Objective: Given a scenario, implement secure mobile solutions.

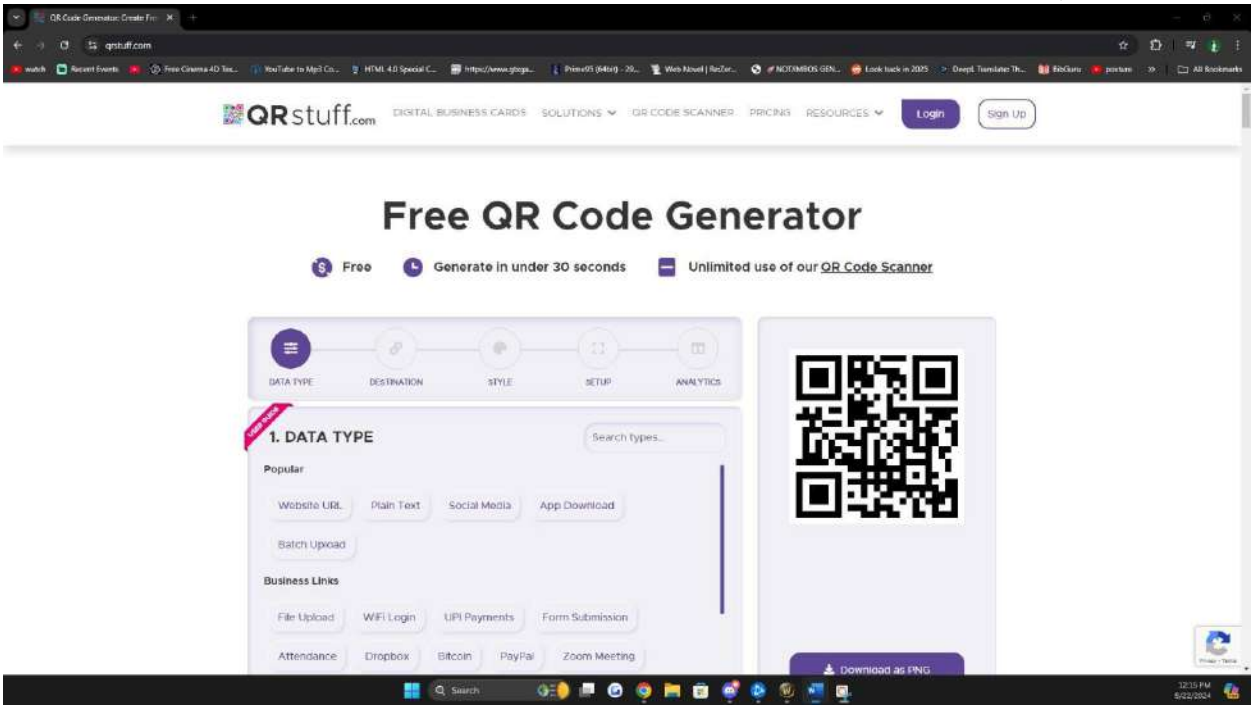
description: Quick Response (QR) codes can be read by an imaging device such as a mobile device's camera or online. However, they pose a security risk. In this project, you create and use QR codes.

INTRODUCTION

Quick Response codes are an easy way to deliver a URL or link to someone else with just a scan of their phones camera or a QR code reading app. However, there are many vulnerabilities with this such as "Quishing" which SecurityHQ (2023) describes as, tricking organizations into scanning a QR code to an impersonating fake website. (Thakkar, Kurkure, C Barlow, 2023) **Even through convenience, threat actors can slip their way through the cracks to take advantage of the technology.**

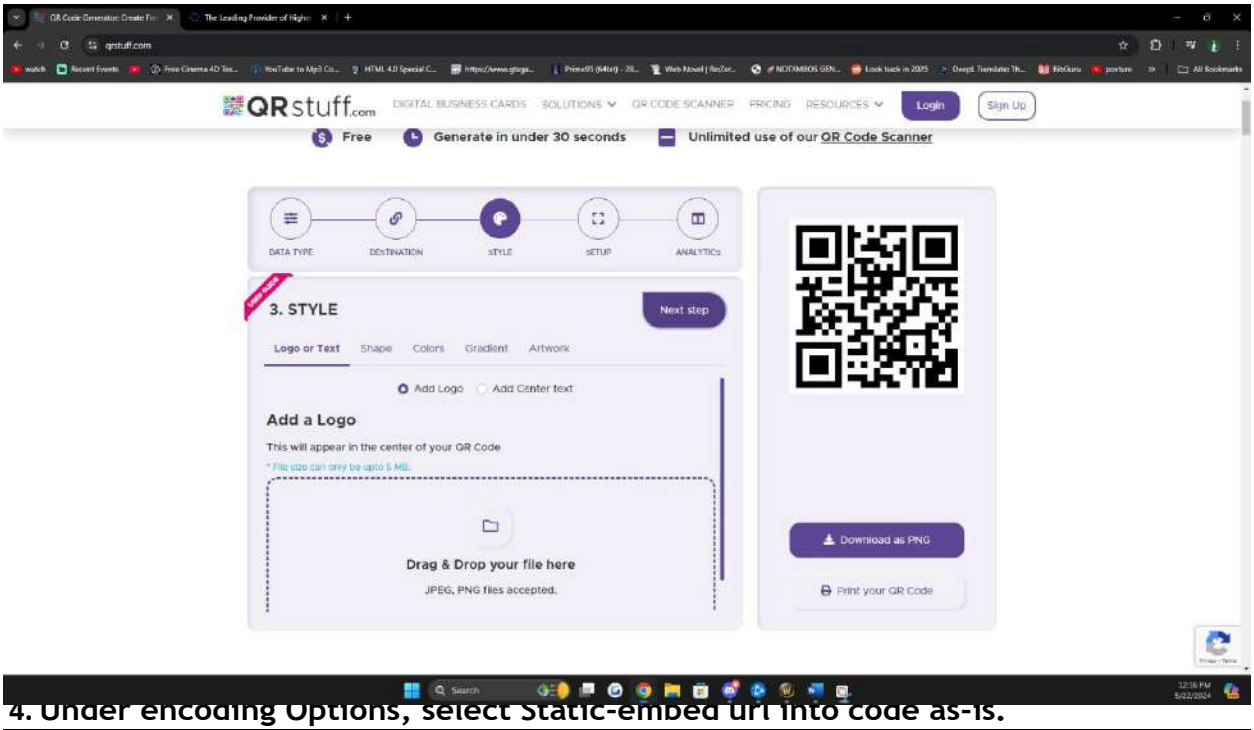
1. **Use your web browser to go to www.qrstuff.com. (If you are no longer able to access the**

program through this URL, use a search engine to search for "Qrstuff.")

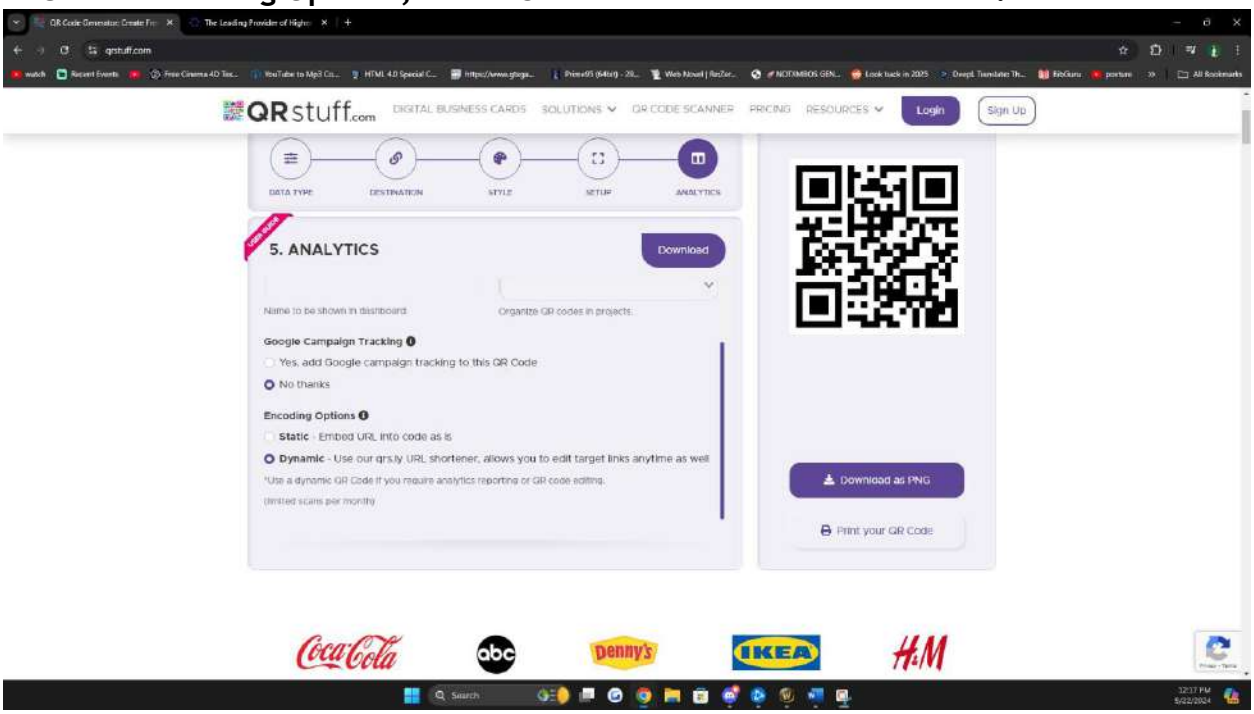


2. First create a QR code. Under Data Type, be sure that Website URL is selected.

3. Under Content, enter the URL www.cengage.com. Watch how the Qr code Preview changes as you type.



4. Under encoding Options, select Static-embed url into code as-is.



5. Under Qr code Preview, click Download Qr COde to download an image of the QR code.



6. Navigate to the location of the download and open the image. Is there anything you can tell by looking at this code? How could threat actors use this to their advantage? Where could malicious QR codes be used? Is there any protection for the user when using QR codes?

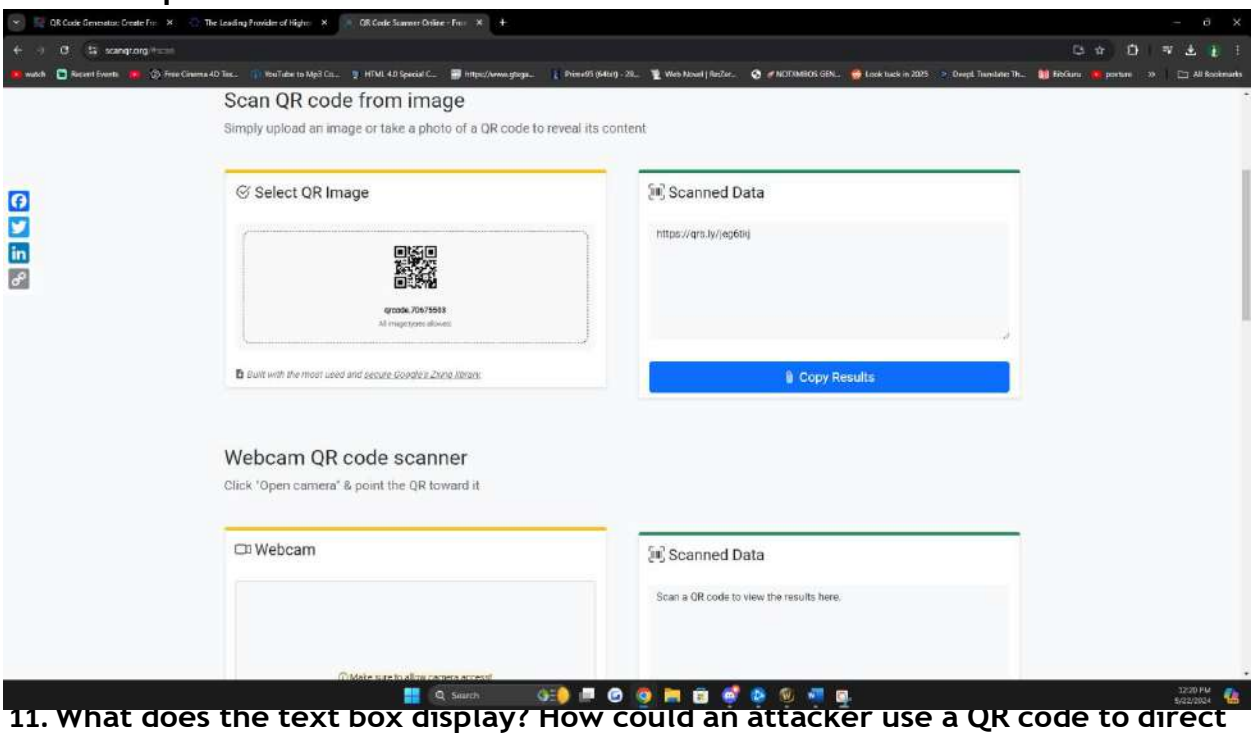
Malicious QR codes can lead to phishing websites designed to steal personal information or login credentials. All QR codes look very similar. If possible, check the URL encoded in the QR code to ensure it's legitimate.

7. Now use an online reader to interpret the QR code. Use your web browser to go to blog.qr4.nl/Online-QrCode_decoder.aspx. (The location of content on the Internet may change without warning. If you are no longer able to access the program through this URL, use a search engine and search for "Free Online QR Code Reader.")

8. Click Choose File.

G. Navigate to the location of the QR code that you downloaded on your computer and click Open.

10. Click upload.

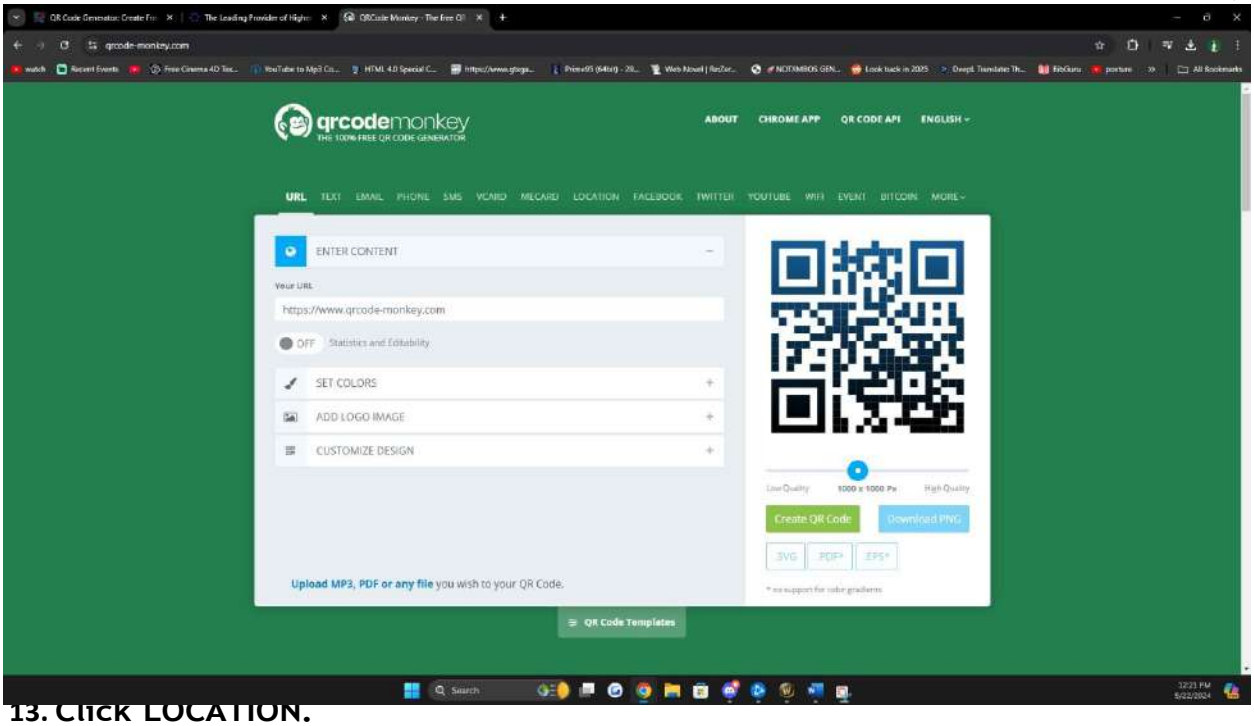


11. What does the text box display? How could an attacker use a QR code to direct a victim to a malicious website?

It returns the URL encoded into the QR Code. Most of the time you don't really look at the link and you just click the qr code on your phone's camera.

12. Use your web browser to go to qrcode-monkey.com. (If you are no longer able to access

the program through this URL, use a search engine to search for “qrcodemonkey.”)



13. Click LOCATION.

14. On the map, drag the pointer to an address with which you are familiar. Note how the latitude and longitude change.

15. Click Create Qr Code.

16. Click download pnG to download this QR code to your computer.

17. Navigate to the location of the download and open the image. How does it look different from the previous QR code? Is there anything you can tell by looking at this code?

<u>You can tell nothing at all and it looks basically the same as the other QR code.</u>

18. Use your web browser to return to blog.qr4.nl/Online-Qr-Code_decoder.aspx.

1G. Click Choose File.

20. Navigate to the location of the map QR code that you downloaded on your computer and click Open.

21. Click upload.

22. In the text box, a URL will be displayed. Paste this URL into a web browser.

23. **What does the browser display? How could an attacker use this for a malicious attack?**

Well it made a QR code of a location on google maps that I clicked. I don't think there's
anything to use off of this.

24. **Return to www.qrstuff.com.**

25. **Click each option under dATA TyPe to view the different items that can be created by a QR code. Select three and indicate how they could be used by an attacker.**

Download malicious apps

Direct you to social media

Text file

26. **Close all windows.**

Case Project 4-3: Application Patch Management

Select four third-party applications (not OSs) that you frequently use. How does each of them address patch management? Visit their websites to determine how they alert users to new vulnerabilities. Are the patch management systems adequate? Should patch management be required of all third-party applications? What are the advantages? What are the disadvantages? Write a one-page paper on your findings

INTRODUCTION

Most supported by the organization applications provide application patch management. From IBM, patch management is the process of applying vendor-issued updates to close any vulnerabilities and optimize the application. (International Business Machines, n.d.) As exploiters take advantage of applications, it is the responsibility of the vendor to address these problems and the process of maintaining their applications is what makes application patch management important for consumers.

The first application I frequently use is Google Chrome as a web browser. They suggest users to have auto-update enabled, version pinning which downloads updates when the user is ready, and fully manual updates. They are very adequate for Google Chrome as the critical ones are forcefully pushed, while the not so important ones aren't and are manual. They don't alert people of vulnerabilities.

The second application I frequently use is the Microsoft Office 365 suite. They automatically apply updates without the user even knowing, which is configurable. They also have the Office Deployment tool for organizations to configure their devices time to update so it doesn't disrupt their workflow. Microsoft is adequately handling their patch management for their Office 365 applications. They don't reveal any security vulnerabilities however have it set up to automatically report them from the application silently.

The third application I frequently use is Steam for gaming purposes. Steam handles their patch management by checking for an update before the user is allowed to get on the platform and if prompts the user to restart the client if there is an update available. Steam does not report security vulnerabilities to their users, like the other applications the news sites do that. Steam is adequately handling their application patch management.

The last application I frequently use is Spotify for music. Spotify handles their patch management by letting users update whenever they want on mobile devices, I think the desktop versions are auto-updates though. Spotify is open about their vulnerabilities and talks about their vulnerability reporting system on their website. Spotify is somewhat adequately handling their patch management, you really never have to update it on your phone so it can have many vulnerabilities lurking.

Application patch management should not be required by all third-party applications. It should only be required for third-party applications that need it and are online services where vulnerabilities are more prominent. Any application that had the ability to connect to the internet at some point, so all of the Adobe applications for example. It is ultimately up to the creator at the end of the day.

Some advantages of it from SentinelOne (2023) include, "Patch management helps establish a strong foundation for enhanced security, risk mitigation, regulatory compliance, cost savings, and improved operational continuity. By prioritizing and implementing effective patch management practices, organizations can strengthen their cybersecurity defenses and protect their data, reputation, and bottom line." (SentinelOne, 2023) . Patch management keeps applications secure and functional for many years if the management is continued.

Some disadvantages of it from Scappman (2022) include, the time-consumption involved, lack of IT inventory management, no desire to deploy the patches, patch failures, and vulnerability management. (Scappman, 2022) The process of diagnosing, testing, and applying the patches leads to a time management problem. There are also patch failures where applying the fixes, breaks something else, or could disable the program temporarily. Thinking about longevity, having to apply patches for an application no one uses 20 years down the line is really demotivating and lacks a benefit to the company. The cycle continues with every fix and there's always another problem to fix, it's just a matter of worth to the company and forcing it on them is entirely up to them.

References

International Business Machines. (n.d.). *What is patch management?* Retrieved from IBM: https://www.ibm.com/topics/patch-management

Scappman. (2022, August 5). *Top 5 Challenges of patch management*. Retrieved from Scappman: https://www.scappman.com/post/top-5-challenges-of-patch-management

SentinelOne. (2023, September 29). *What is Patch Management? Working and Benefits*. Retrieved from SentinelOne: https://www.sentinelone.com/cybersecurity-101/cybersecurity/what-is- patch-management/

Thakkar, D., Kurkure, N., C Barlow, E. (2023, October). *QR Code Vulnerabilities: Dissecting New Techniques Seen in the Wild*. Retrieved from SecurityHQ: https://www.securityhq.com/blog/qr-code-vulnerabilities-dissecting-new-techniques- seen-in-the-wild

VirusTotal. (n.d.). *VirusTotal - Home*. Retrieved from VirusTotal: https://www.virustotal.com/

Assignment 3 – Hands On

Sam Peller

October 10, 2024

ISM 4323

Project 6-4: Using Microsoft's Encrypting File System (EFS)

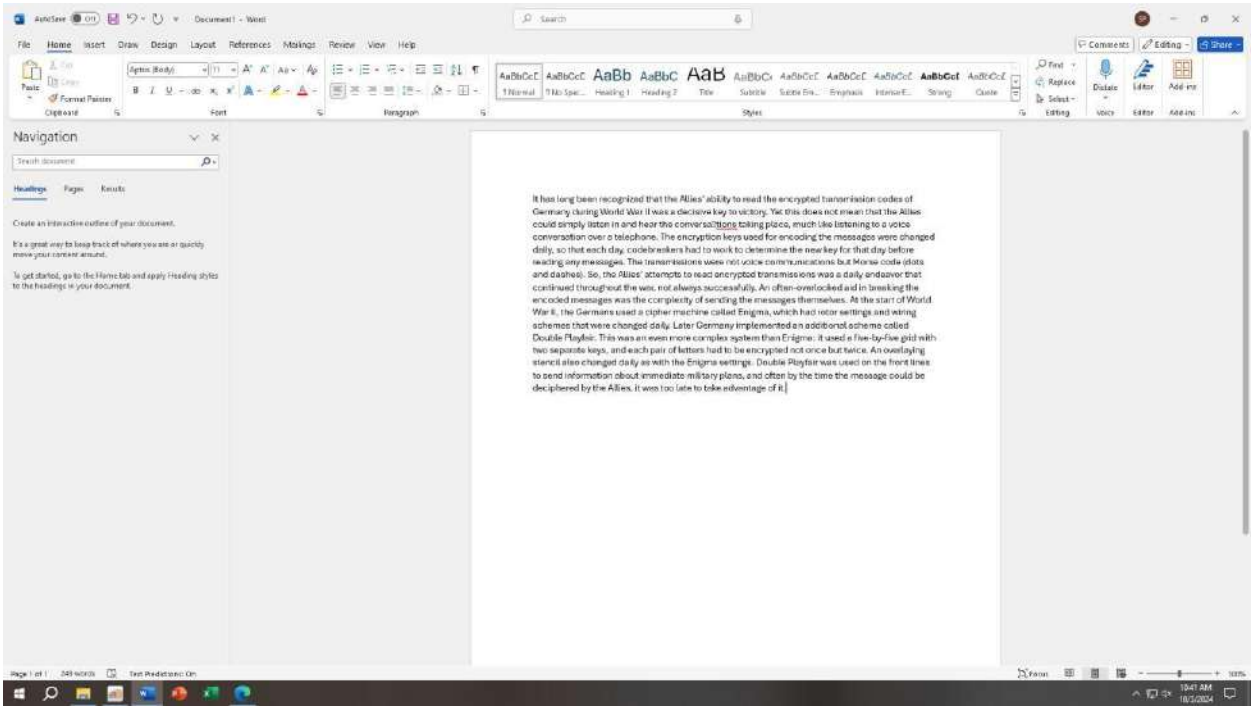
Time Required: 20 minutes

Objective: Given a scenario, implement host or application security solutions. Description: Microsoft's Encrypting File System (EFS) is a cryptography system for Windows releases that use the Windows NT file system (NTFS). Because EFS is tightly integrated with the file system, file encryption and decryption are transparent to the user. In this project, you will turn on and use EFS.

INTRODUCTION

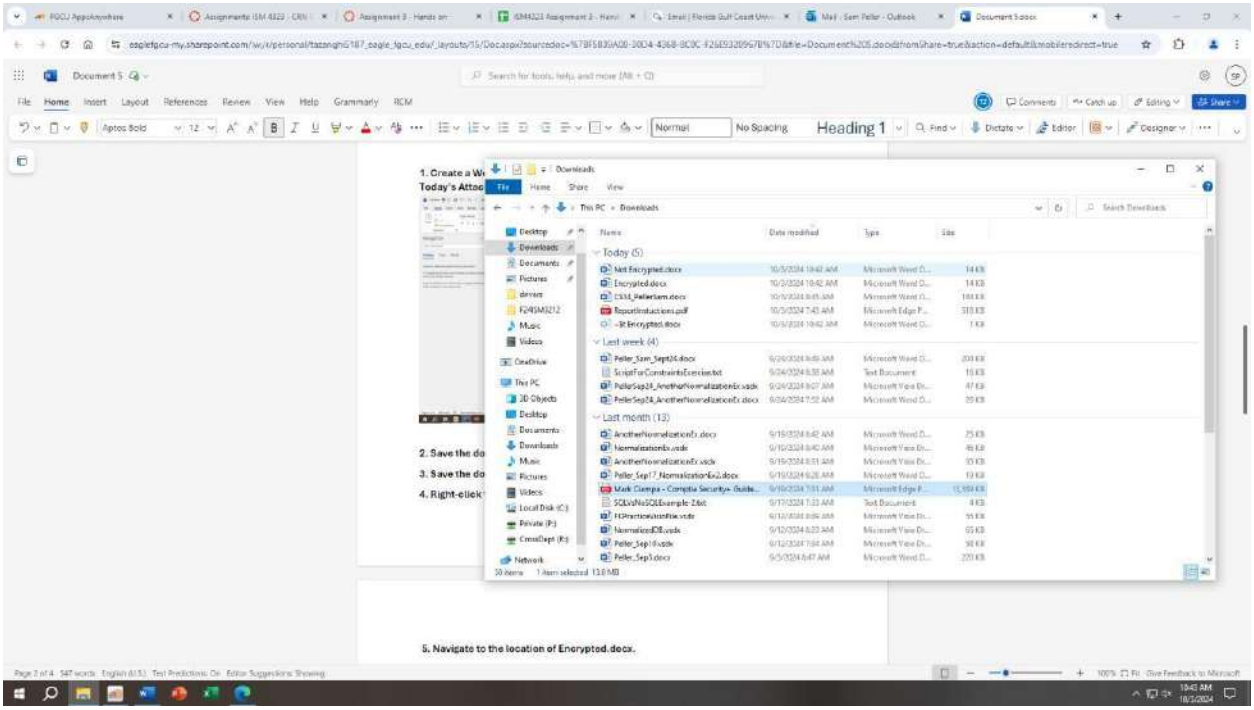
The Encrypted File System (EFS) is a security feature in Windows that enhances file protection by encrypting individual files on NTFS volumes using a public-key cryptography system. While Windows access control typically protects files from unauthorized access, according to Microsoft (2023) EFS adds an extra layer of security, particularly useful if a device containing sensitive information is lost or stolen (Microsoft, 2023). By going to the properties of a file and going into the advanced option you can simply turn it on.

1. Create a Word document with the contents of the first two paragraphs under Today's Attacks and Defenses on the first page of this module.



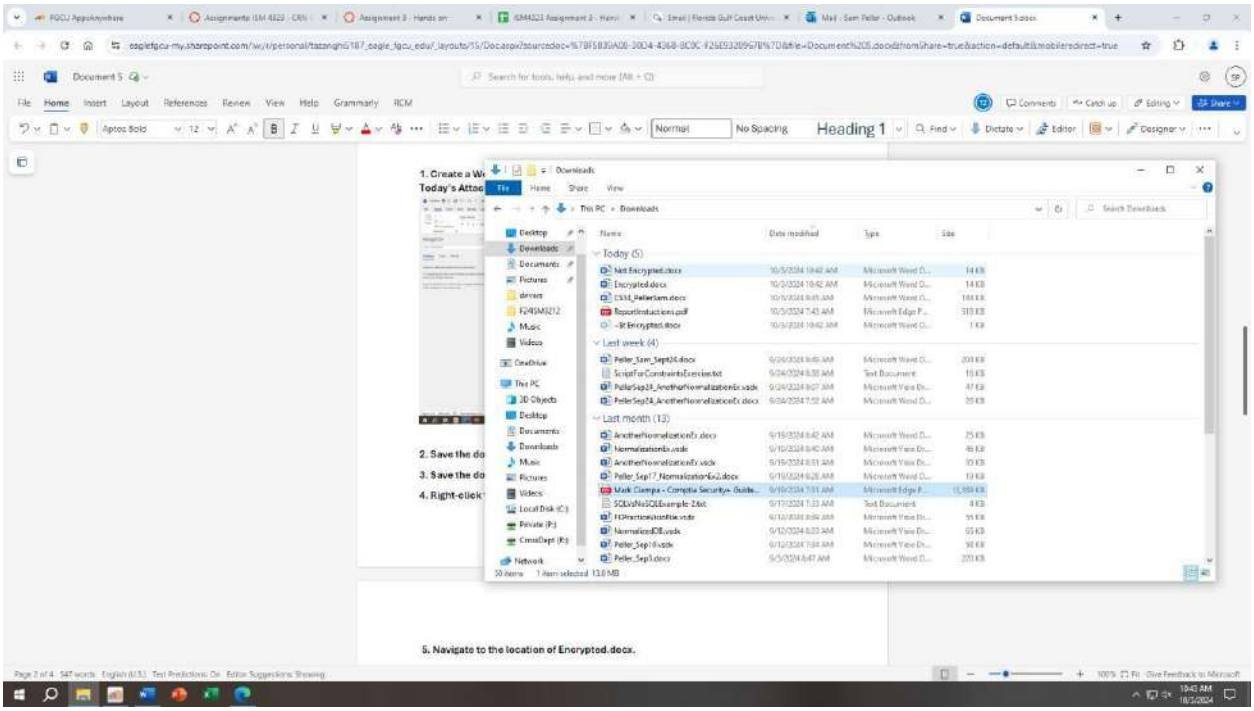
2. Save the document as Encrypted.docx.

3. Save the document again as Not Encrypted.docx.



4. Right-click the Start button, and then click File Explorer.

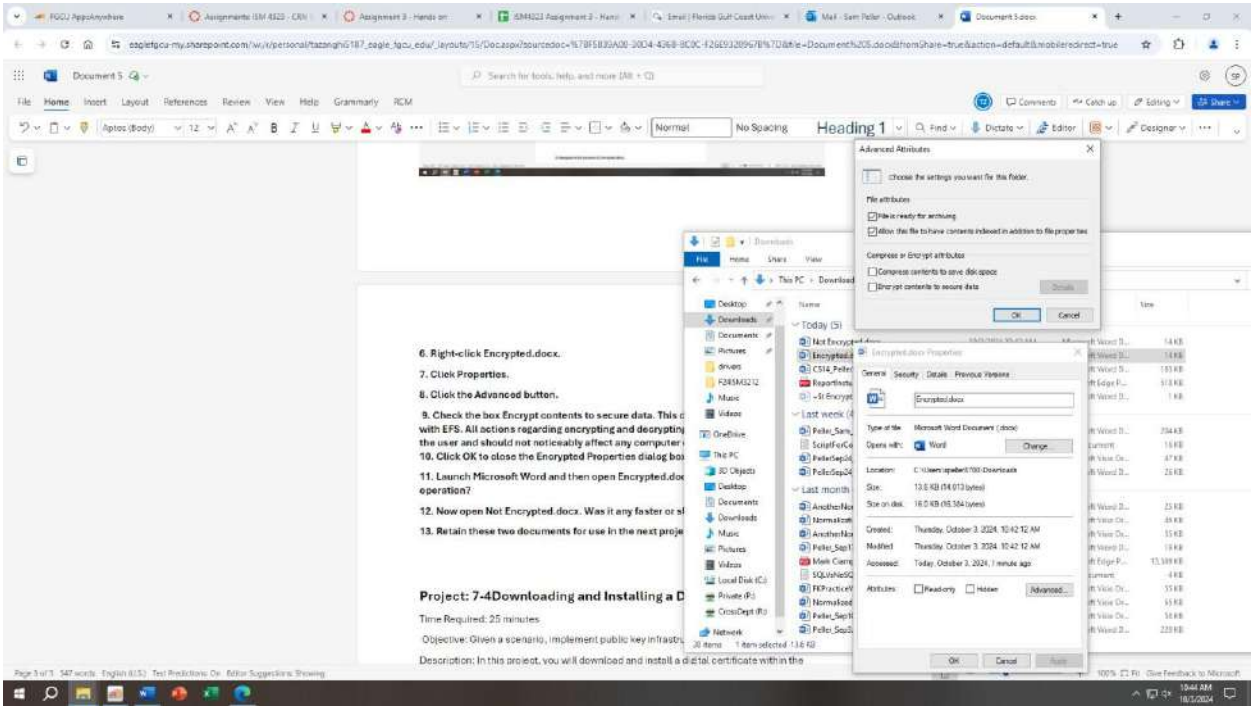
5. Navigate to the location of Encrypted.docx.



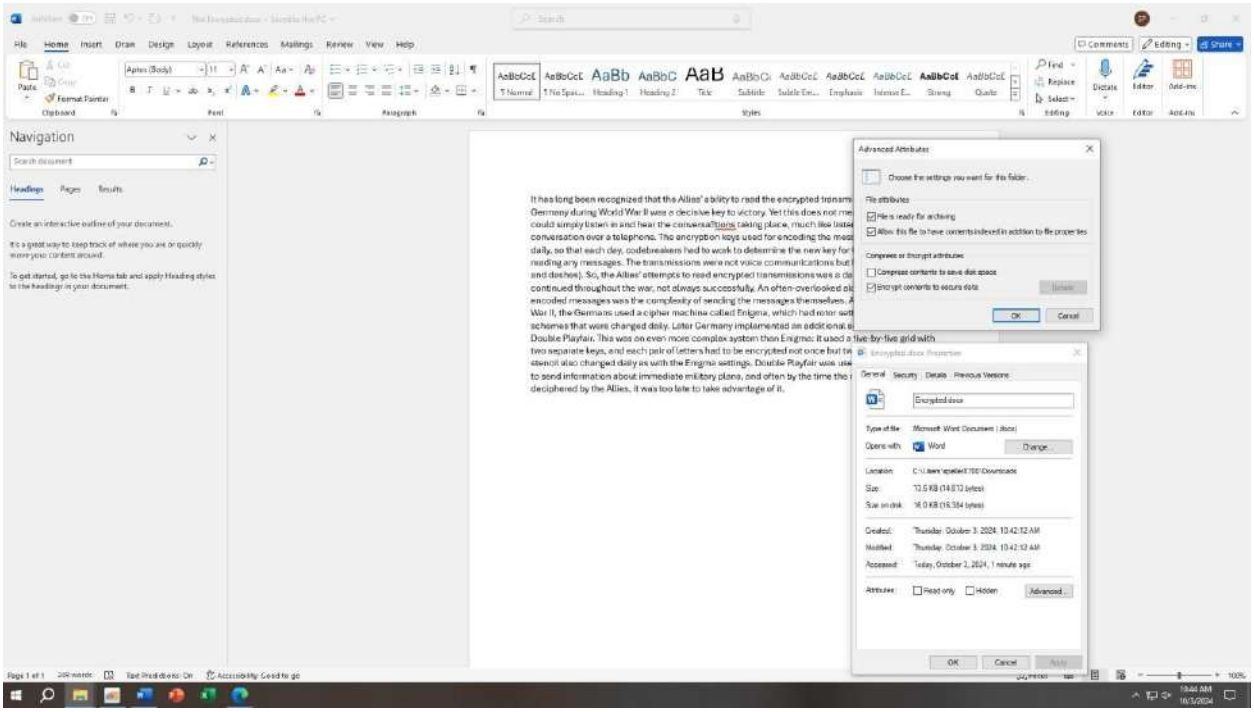
6. Right-click Encrypted.docx.

7. Click Properties.

8. Click the Advanced button.



G. Check the box Encrypt contents to secure data. This document is now protected with EFS. All actions regarding encrypting and decrypting the file are transparent to the user and should not noticeably affect any computer operations. Click OK.



10. Click OK to close the Encrypted Properties dialog box.

11. **Launch Microsoft Word and then open Encrypted.docx. Was there any delay in the operation?** There wasn't any noticeable difference between opening the two files.

12. **Now open Not Encrypted.docx. Was it any faster or slower?**

There wasn't any noticeable difference between opening the two files.

13. **Retain these two documents for use in the next project. Close Word**

Case Project 6-6: One-Time Pad (OTP) Research

Use the Internet to research OTPs: who was behind the initial idea, when they were first used, in what applications they were found, how they are used today, and other relevant information. Then visit an online OTP creation site such as www.braingle.com/brainteasers/codes/onetimepad.php and practice creating your own ciphertext with OTP. If possible, exchange your OTPs with other students to see how you might try to break them. Would it be practical to use OTPs? Why or why not? Write a one-page paper on your findings

INTRODUCTION

The one-time pad (OTP) is a classic encryption method celebrated for its theoretical unbreakability, relying on the use of a pre-shared key that is longer than the message itself as a double-edged sword. Some of its applications from ReasonLabs (2023), describe it as used in some antivirus programs to securely store and transmit sensitive data, such as encryption keys and decryption algorithms (ReasonLabs, 2023). If all electronics went offline for a period in time, the one-time pad would be a great method to send encrypted messages in times of need.

A one-time pad is an encryption technique that is supposed to be uncrackable but requires the use of a pre-shared key larger than the message being sent. According to Crypto Museum (2023), the initial idea was by banker Frank Miller which was later reinvented. It was first used by agents of the former Soviet Union during the 1960s (Crypto Museum, 2023). It's a one-time pad because it's a booklet of either letters or numbers stapled together and after usage is destroyed. They can be hidden inside small objects and are supposed to be concealable. According to Reason Labs (2023), the keys are generally not practical for everyday use but are still sometimes used for improved confidentiality in military or government communications, when used correctly it's considered unbreakable. (ReasonLabs, 2023)

To put it into practice, Braingle offers a simulator where to encipher a message, each letter of the plaintext is added to a corresponding letter from the one-time pad using their positions in the alphabet (A=1, B=2, etc.). After adding, 1 is subtracted from the result. If the sum exceeds 26, it wraps around the alphabet. To decipher, each letter of the ciphertext is subtracted from the corresponding one-time pad letter. If the result is negative, it wraps around to the end of the alphabet (Braingle, n.d.). From the website, you are provided a one-time pad code, you first encipher the plaintext, then you get an enciphered message. You then decipher it, and get a new enciphered message, and encipher it to get the message.

As One-Time pads are considered unbreakable when done correctly, they aren't practical to use. The length of the pad must be as long as the message being encrypted and it is inconvenient for such long and unique keys each time. The sender and receiver need identical copies of the OTP and vulnerabilities in transmission as well as re-use is not suggested. On the bright side, OTPs needs to be truly random and doing it on a large scale would not be optimal. Manually decrypting a message with this system is inefficient and error prone. It is not suggested to use OTP's in general use and would recommend modern day encryption methods.

One-time pads also present significant logistical issues beyond key management. They require a secure and trusted channel for exchanging the pads themselves before any communication can begin, which can be difficult to maintain. Furthermore, if an adversary gains access to even part of the one-time pad, the security of the system collapses entirely. Unlike modern encryption methods that allow for secure key exchange over public channels (like RSA or

Diffie-Hellman), OTPs do not offer such flexibility. These factors make them less practical in modern digital communication environments, where scalability and ease of use are essential.

References

Braingle. (n.d.). *One-time Pad Cipher*. Retrieved from Braingle: https://www.braingle.com/brainteasers/codes/onetimepad.php#form

Crypto Museum. (2023). *One-Time Pad (OTP)*. Retrieved from Crypto Museum: https://www.cryptomuseum.com/crypto/otp/index.htm

Microsoft. (2023, January 12). *File Encryption*. Retrieved from Microsoft: https://learn.microsoft.com/en-us/windows/win32/fileio/file-encryption

ReasonLabs. (2023). *What is One-time pad?* Retrieved from Reason Labs: https://cyberpedia.reasonlabs.com/EN/pre-shared%20key.html

Project 7-4: Downloading and Installing a Digital Certificate

Time Required: 25 minutes

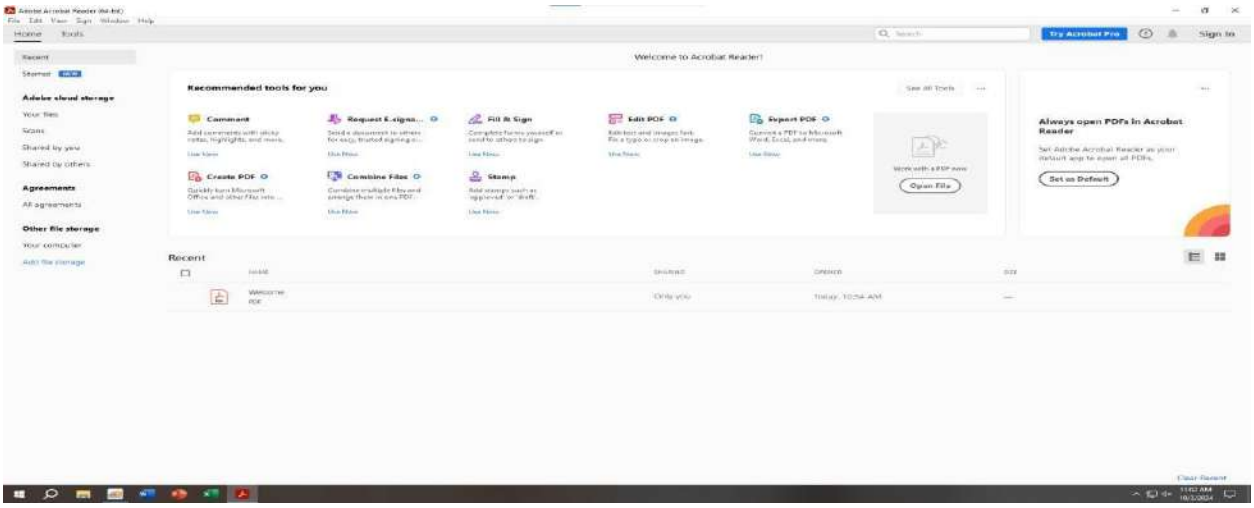
Objective: Given a scenario, implement public key infrastructure.

Description: In this project, you will download and install a digital certificate within the Adobe Acrobat Reader DC.

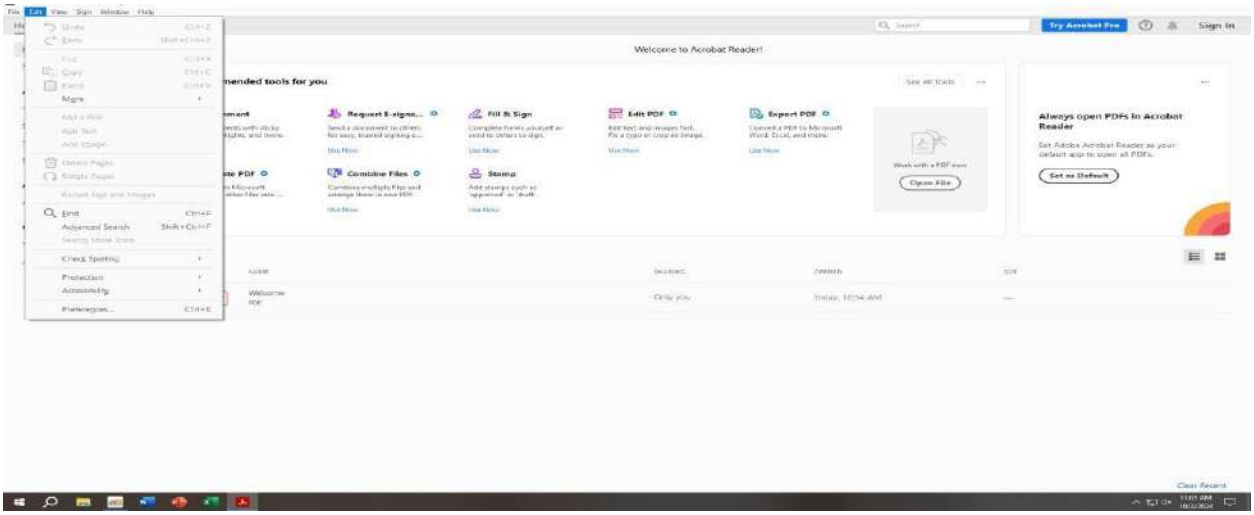
Introduction: Downloading and installing a digital certificate in Adobe Reader is a crucial step for enhancing the security and authenticity of your digital documents. A digital certificate serves as a virtual ID card, this allows users to sign, encrypt, and validate the integrity of files securely. This process not only helps protect sensitive information but also ensures that your electronic signatures are recognized and trusted by recipients.

1. Check to determine if Adobe Acrobat Reader DC or Adobe Acrobat Professional is installed on your computer. If so, you may skip these download and installation steps and go directly to Step 5.

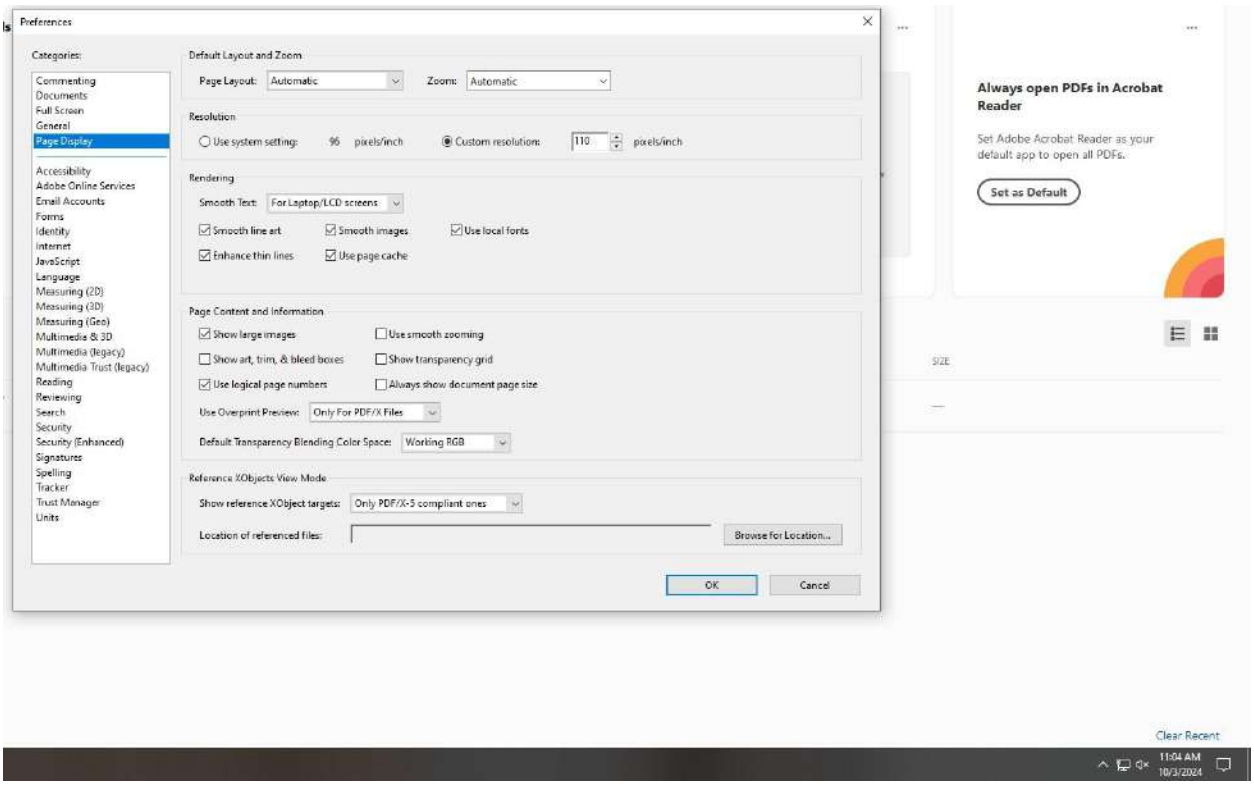
5. Launch Reader.



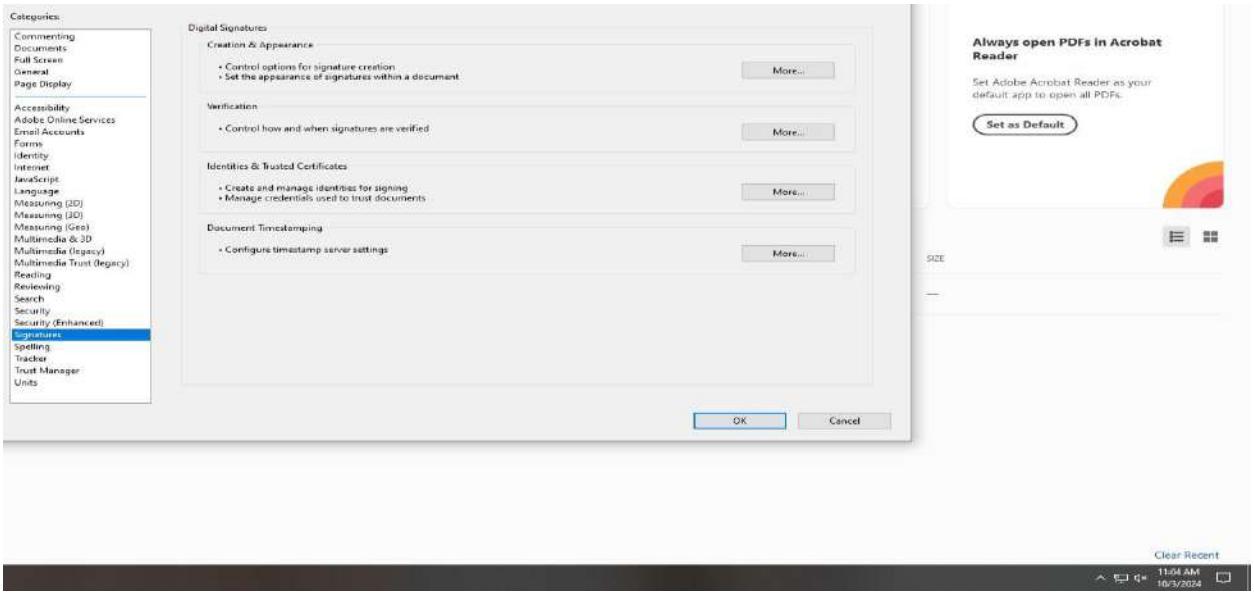
6. Click Edit.



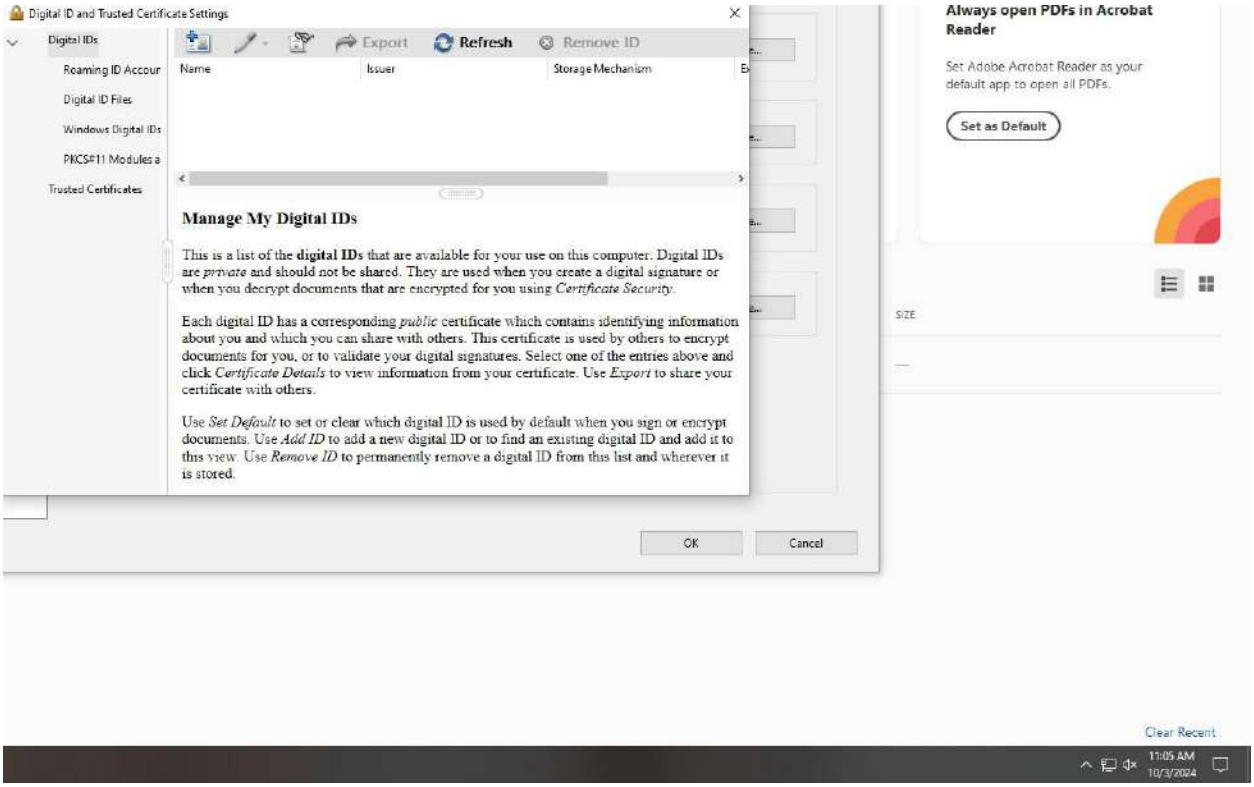
7. Click Preferences.



8. Click Signatures.

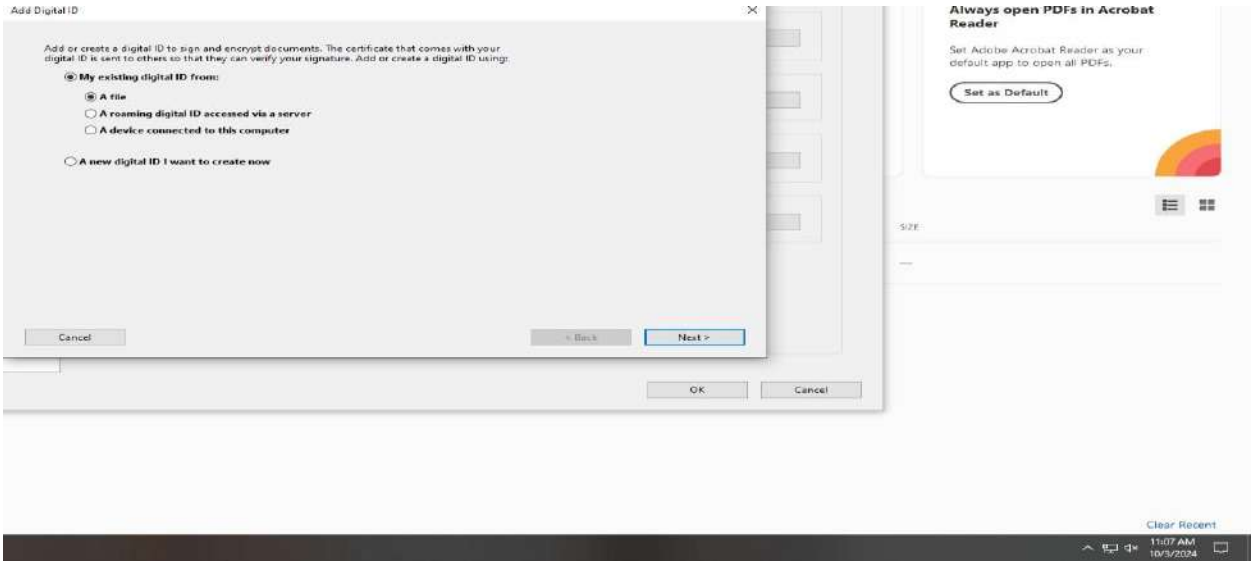


9. Under Identities C Trusted Certificates, click More.

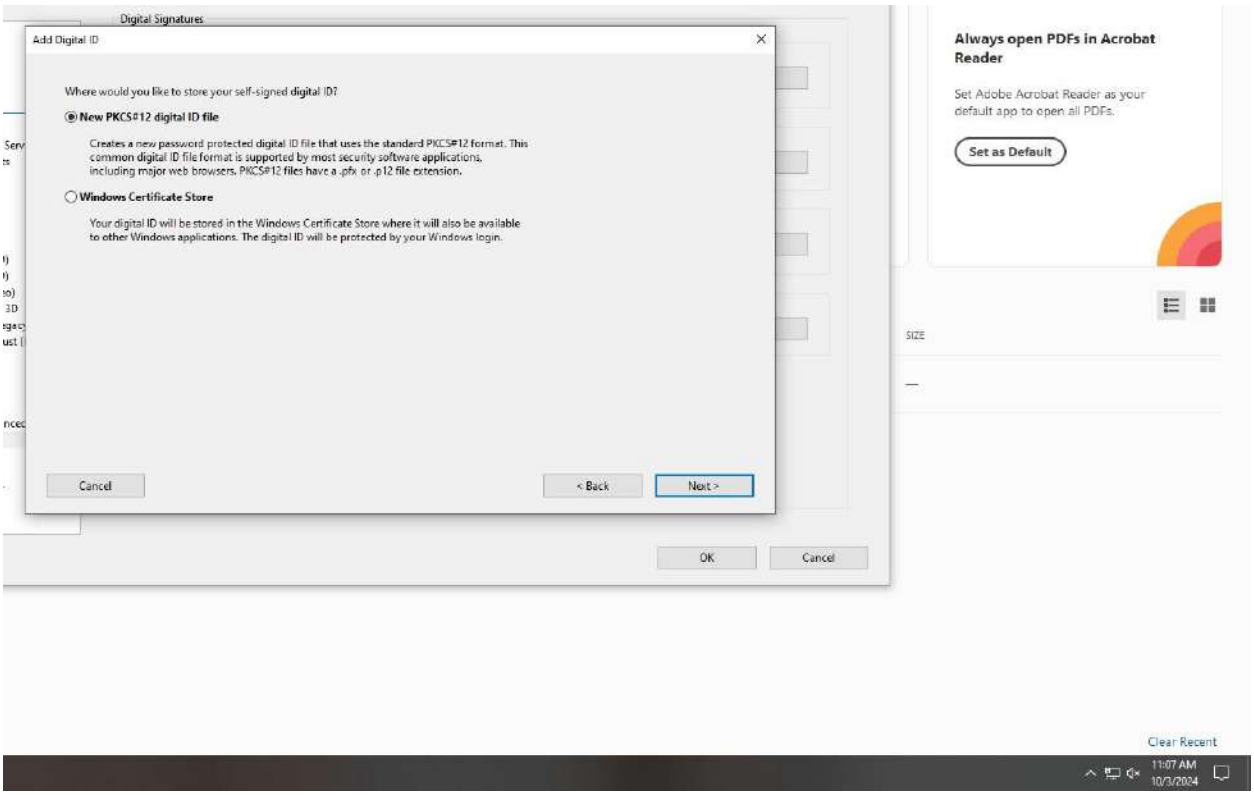


10. In the left pane, click Digital IDs to display the menu choices, if necessary.

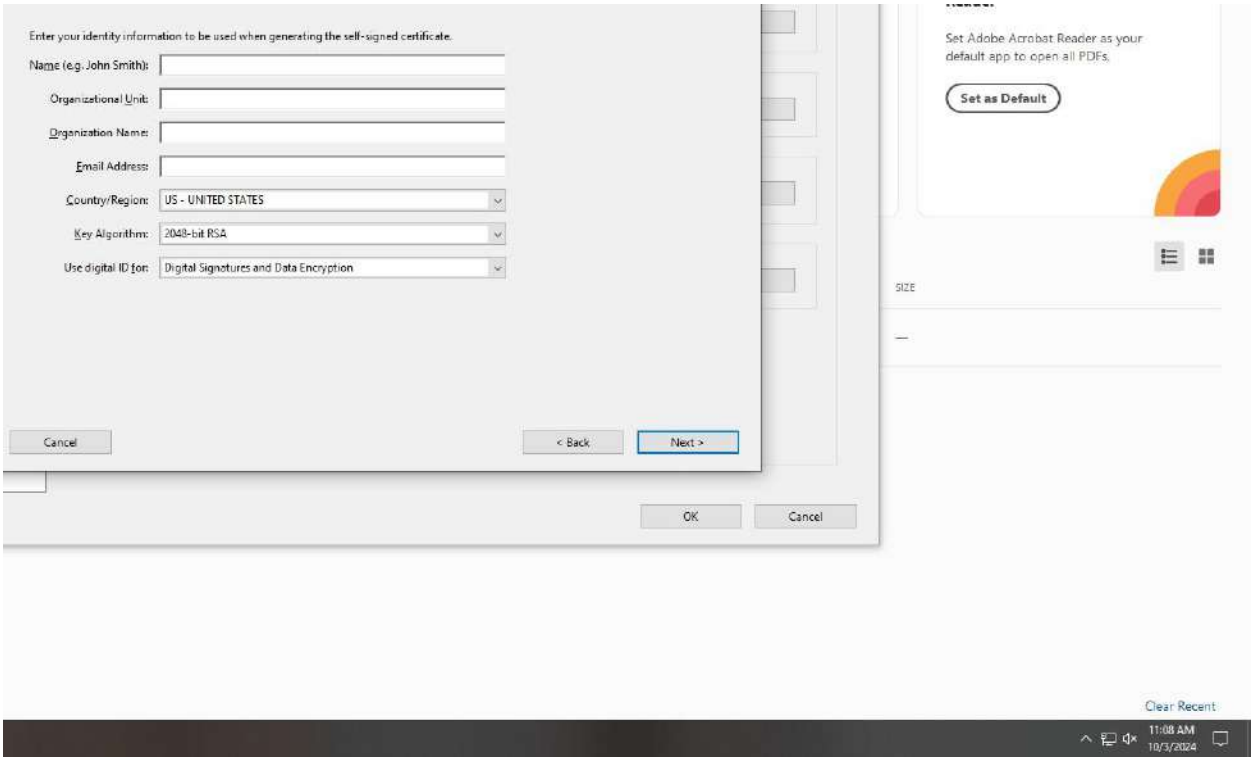
11. At the menu at the top of the main pane, click the Add ID icon (it is the first icon and has a plus sign).



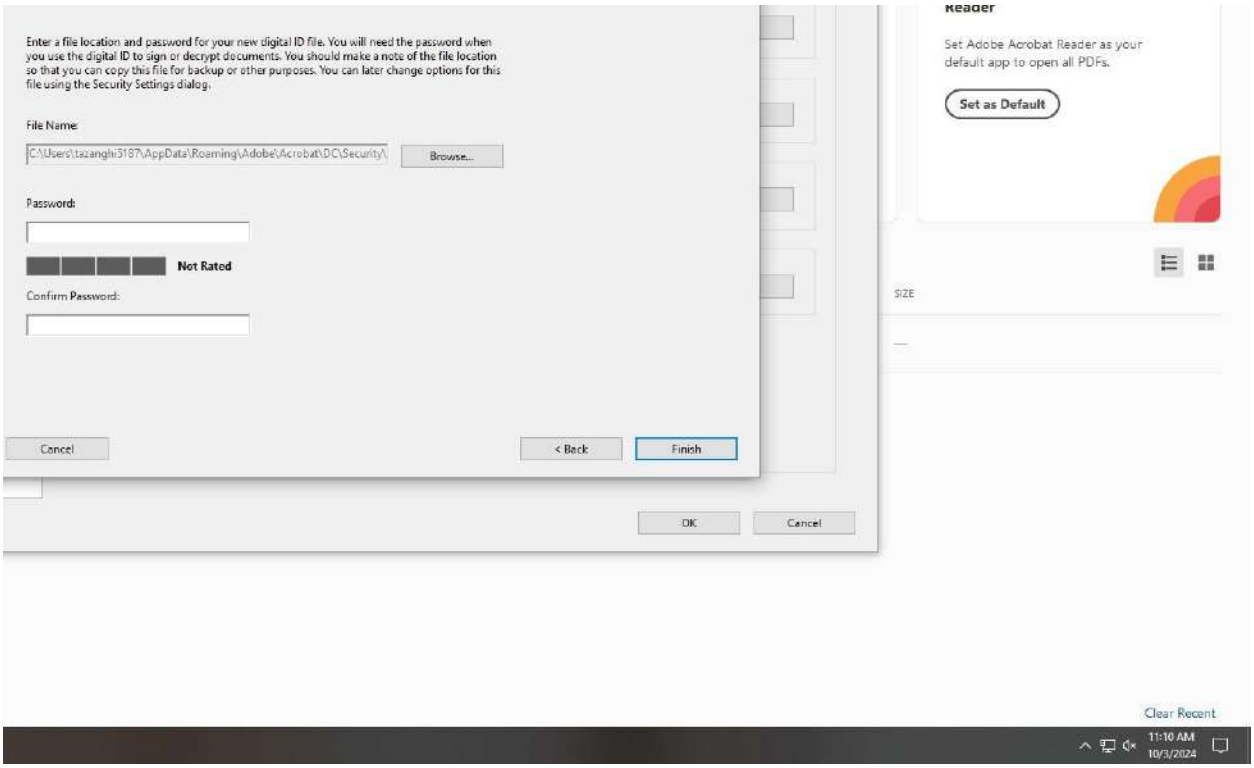
12. Click A new digital ID I want to create now. Click Next.



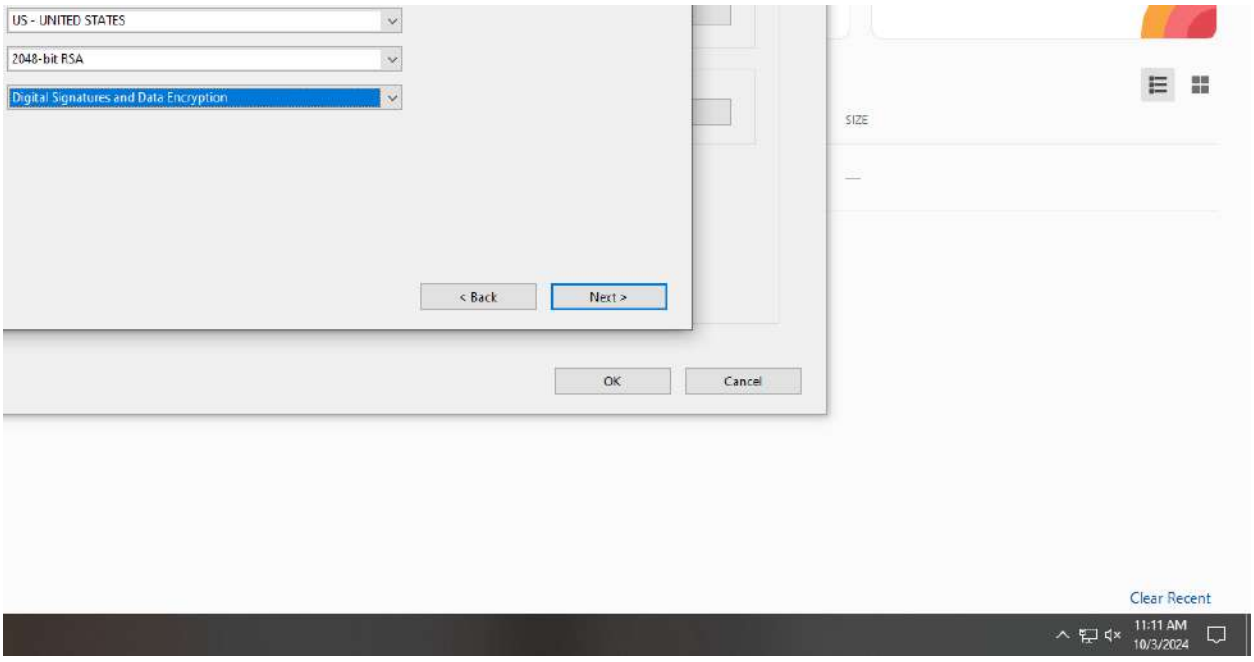
13. If necessary, click New PKCS#12 digital ID file. What is a PKCS#12? What type of file extension will it have? Click Next.



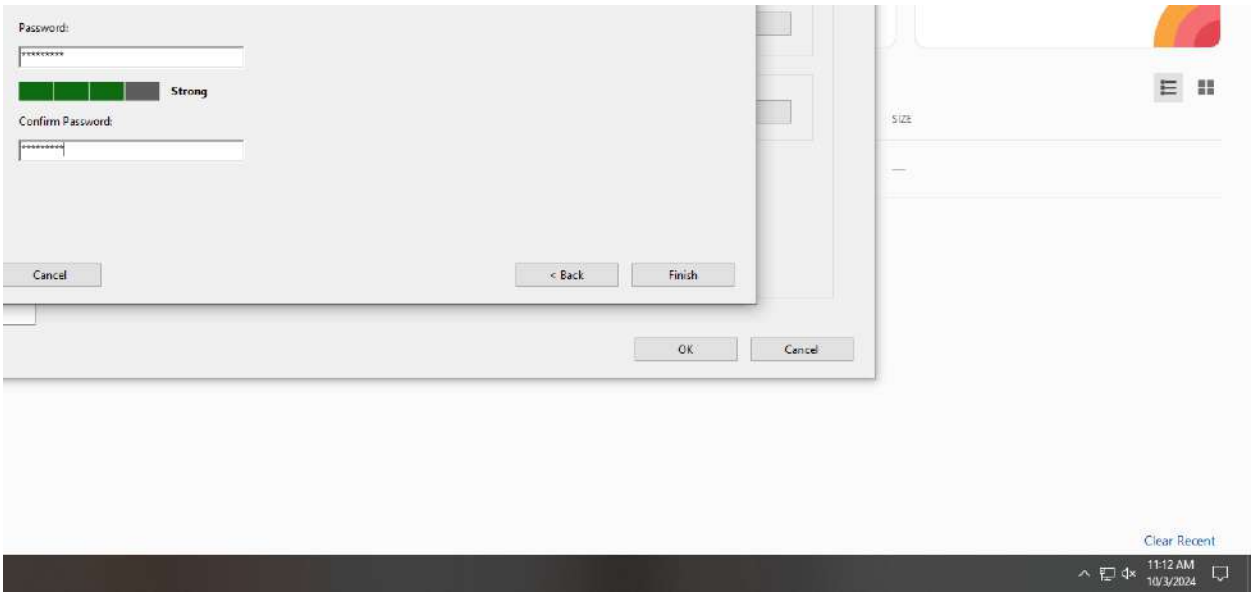
14. Enter the requested information. Under Key Algorithm, click the down arrow to display two options. The default is 2048-bit RSA, which provides more security, while 1024-bit RSA provides less security but is more universally compatible. Accept the 2048-bit RSA.



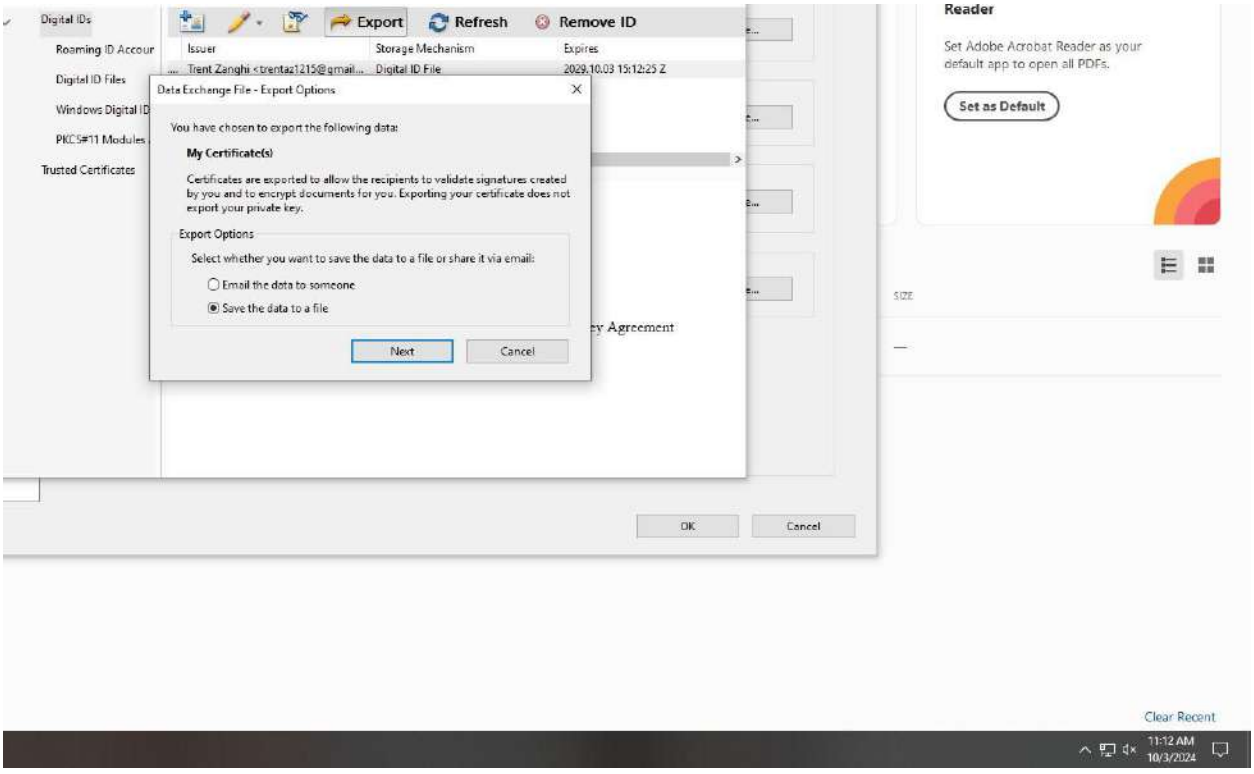
15. Under Use digital ID for, click the down arrow to display three options. Select the default Digital Signatures and Data Encryption. Click Next.



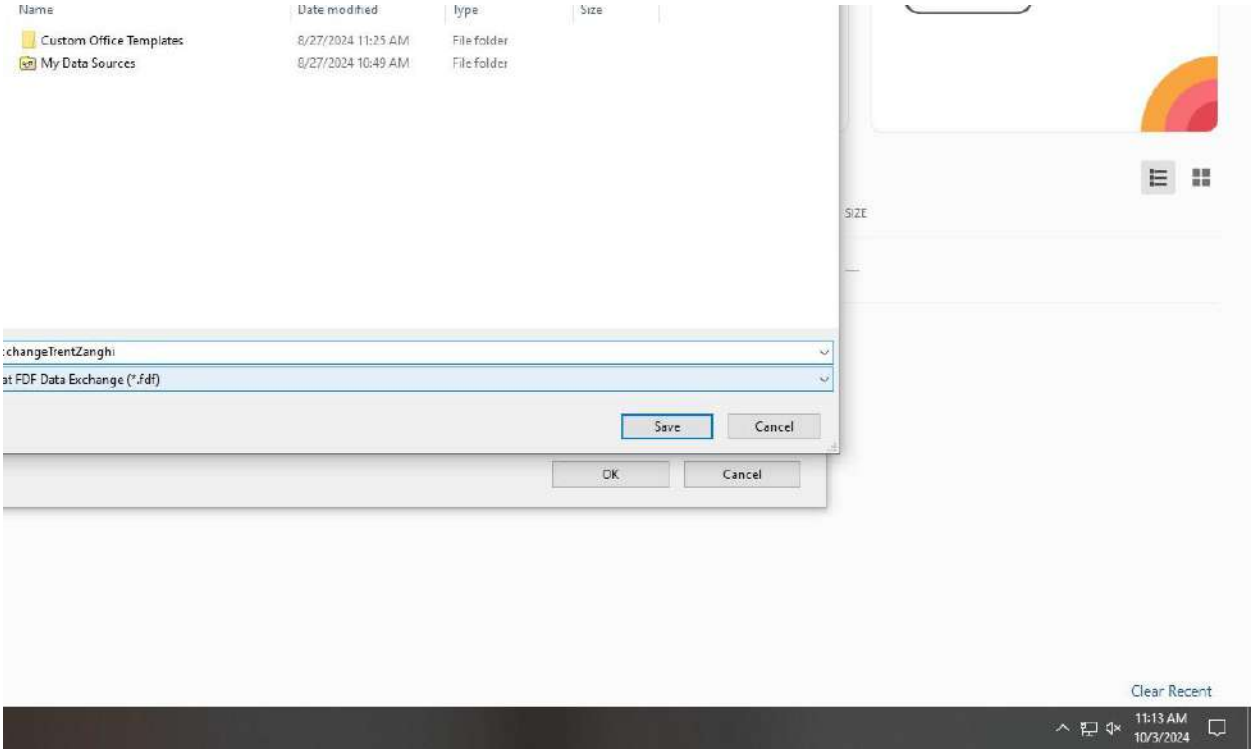
16. Create and enter a strong password, and then confirm that password. Click Finish.



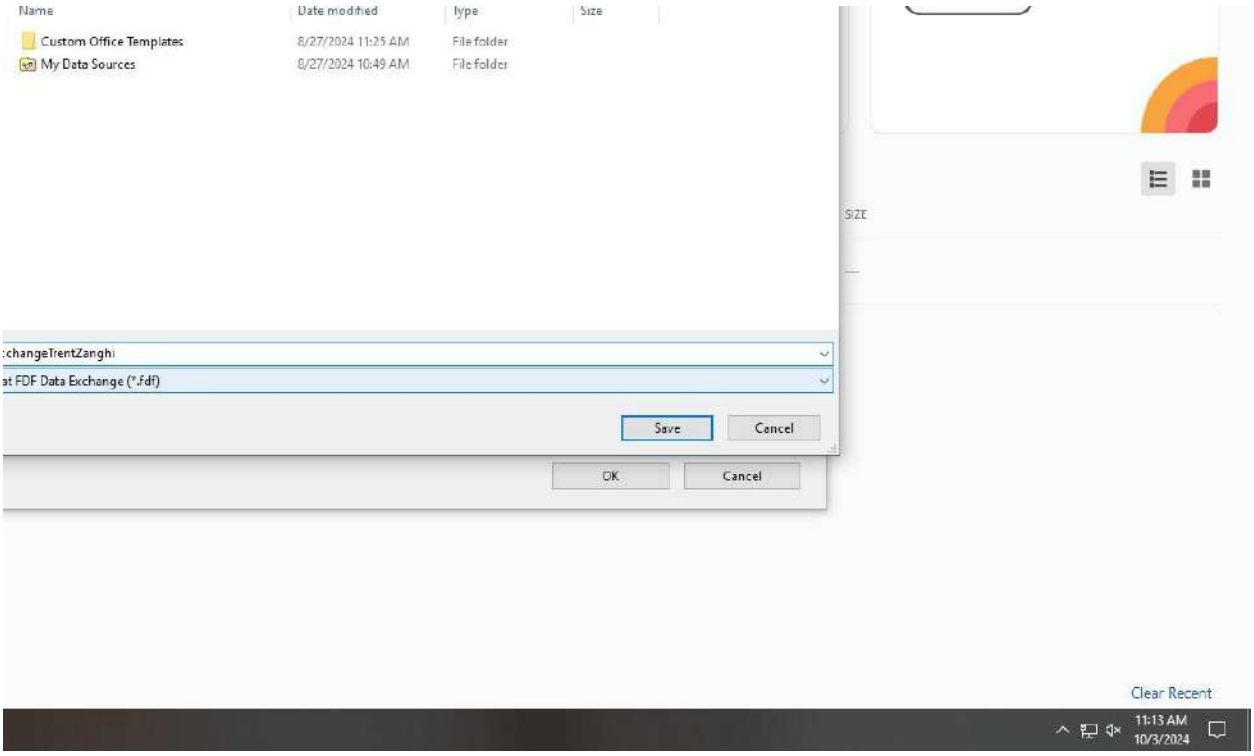
17. Your file is now created. Click Export.



18. If necessary, click Save the data to a file and then click Next.



19. Save the file to your computer.



20. Close the windows associated with configuring your certificate. You can use this certificate by sending it to anyone who needs to validate your identity.

21. Close all windows.

Case Project 7-6: Digital Certificate Costs

Use the Internet to research the costs of the different types of digital certificates: domain validation, EV, wildcard, SAN, machine/computer, code signing, and email. Look up at least three providers of each, and create a table listing the type of certificate, the costs, and the length of time the certificate is valid.

Introduction:

When selecting a digital certificate, it's essential to understand the various types and their costs. Digital certificates vary in their scope, security level, and use cases, from basic Domain Validation (DV) to more complex Extended Validation (EV), Wildcard, SAN (Subject Alternative Name), machine/computer, code signing, and email certificates. Prices fluctuate depending on the provider, the type of certificate, and the level of validation required.

Certificate Type	Provider	Cost (Approx.)	Validity Period
Domain Validation	Comodo	$100/year	1 to 6 years
	DigiCert	$312-1296/year	1 year
	GeoTrust	$168/year	1 year
Extended Validation (EV)	Comodo	$99 - $1,200/year	1 to 2 years
	DigiCert	$468 - $1,860/year	1 to 2 years
	GlobalSign	$599/year	1 year
Wildcard	Comodo	$53 - $103/year	1 year
	DigiCert	$855 year	1 year
	GlobalSign	$849y ear	1 year
Subject Alternative Name (SAN)	Comodo	$227/year	1 year
	DigiCert	$1260/year	1 year
	GlobalSign	$849 /year	1 year
Machine/Computer	Comodo	$50 - $300/year	1 to 3 years
	DigiCert	$199 - $500/year	1 to 2 years

	GlobalSign	$300 - $600/year	1 to 2 years
Code Signing	Comodo	$219.45/year	1 year
	DigiCert	$588/year	1 year
	GlobalSign	$369/year	1 year
Email (S/MIME)	Comodo	$12/year	1 year
	DigiCert	$150/year	1 year
	GlobalSign	$39/year	1 year

References:

Cheap wildcard SSL certificate. Comodo. (2024). https://comodosslstore.com/promoads/wildcardssl.aspx?utm_source=bingCutm_medium=cpcCutm_campaign=Comodo+WildcardCutm_term=comodo+wildcardCmsclkid=8a6bceede6df1cfd1c9da9e0bd8fcef6

Digicert True Business ID. GeoTrust. (2024). https://www.geotrust.com/tls-ssl/tls-ssl-certificates

Digital Trust for the real world. DigiCert. (2024). https://www.digicert.com/#:~:text=%24100%20%2F%20month%20%2F%20standard,domain%2012%20month%20auto-renewing%20subscription%20%241%2C296.00

Wildcard SSL - SSL & Digital certificates by globalsign. GlobalSign. (2024). https://shop.globalsign.com/en/ssl/wildcard-ssl#:~:text=From%20%24849,USD%20%2Fyear

Assignment 4 – Hands On

Sam Peller

November 6, 2024

ISM 4323

project G-1: using glasswire Firewall

Time required: 25 minutes

Objective: Given a scenario, implement secure network designs.

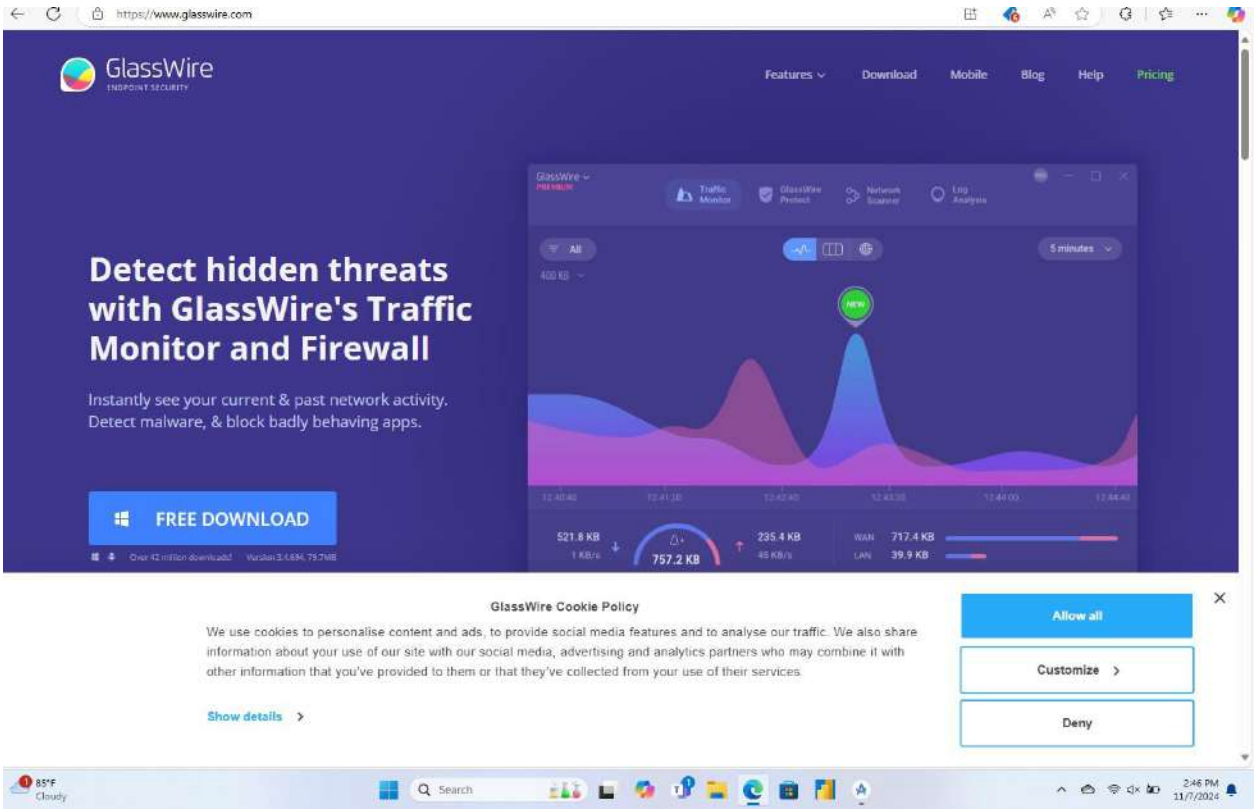
Description: GlassWire is a firewall and Security and Information Event Management (SIEM) product. In this activity, you will download and install GlassWire.

Introduction:

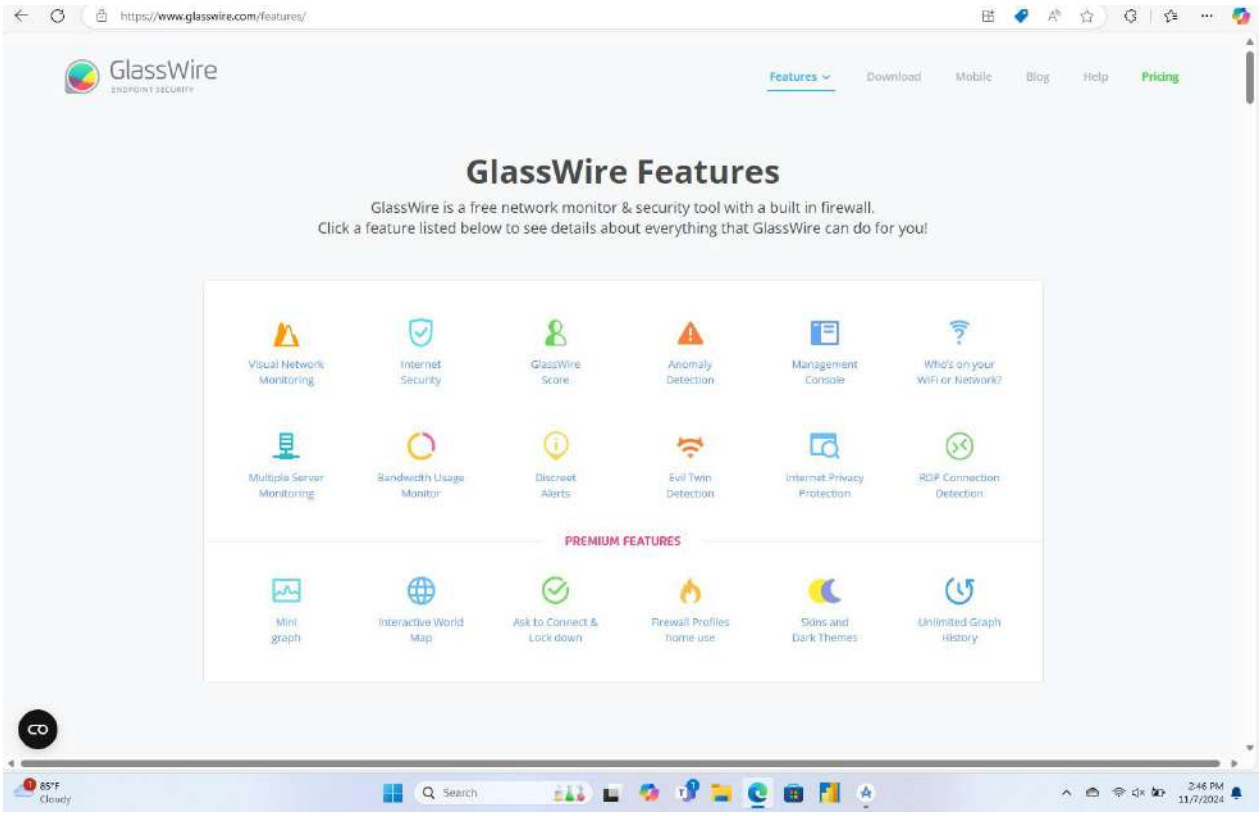
In today's digital landscape, securing network infrastructure is vital to protect against a wide array of cyber threats. With the rapid increase in sophisticated attacks, IT professionals are continuously exploring advanced tools and techniques to design and implement secure networks. One powerful approach involves using firewalls alongside Security and Information Event Management (SIEM) systems, which together provide real- time monitoring, analysis, and response capabilities to enhance network security. This activity focuses on GlassWire, which is a unique product that combines firewall capabilities with SIEM functionalities. GlassWire not only monitors network traffic but also provides alerts on potential security events, allowing users to manage and respond to threats proactively. its an invaluable asset in implementing secure network designs. This exercise highlights how firewalls and SIEM products can work together to maintain network integrity and protect sensitive data across diverse environments.

1. Use your web browser to go to www.glasswire.com. (If you are no longer able to access

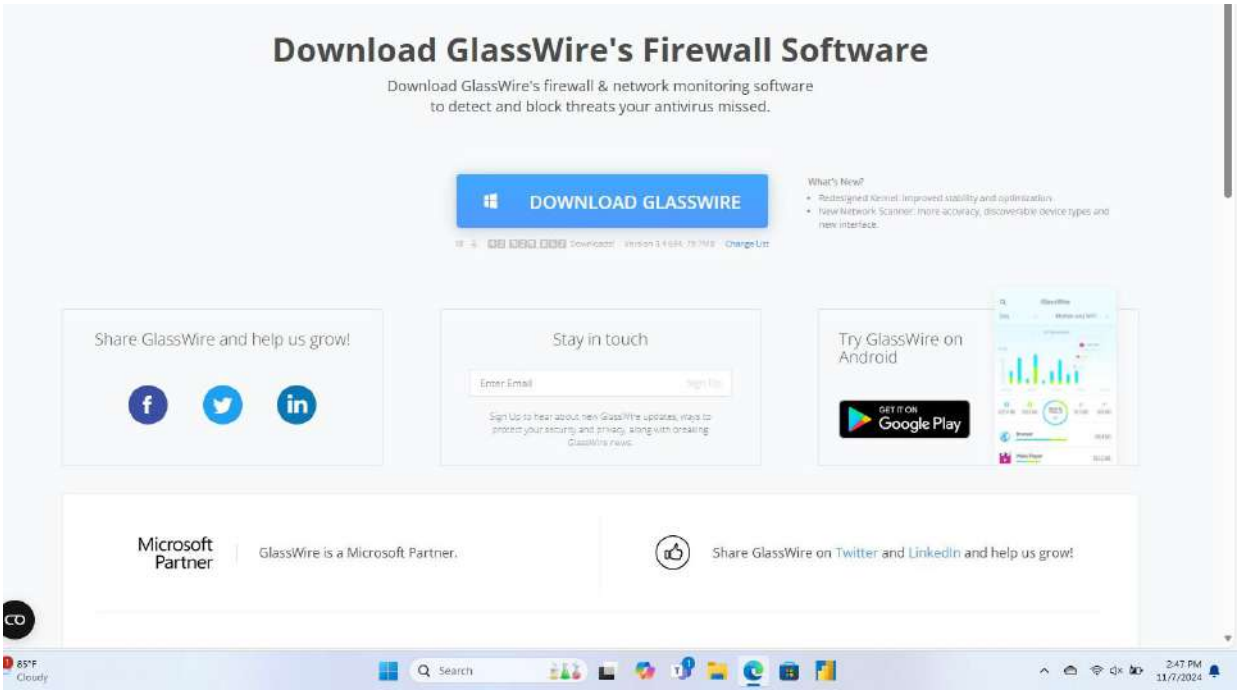
the site through the URL, use a search engine to search for "GlassWire.")



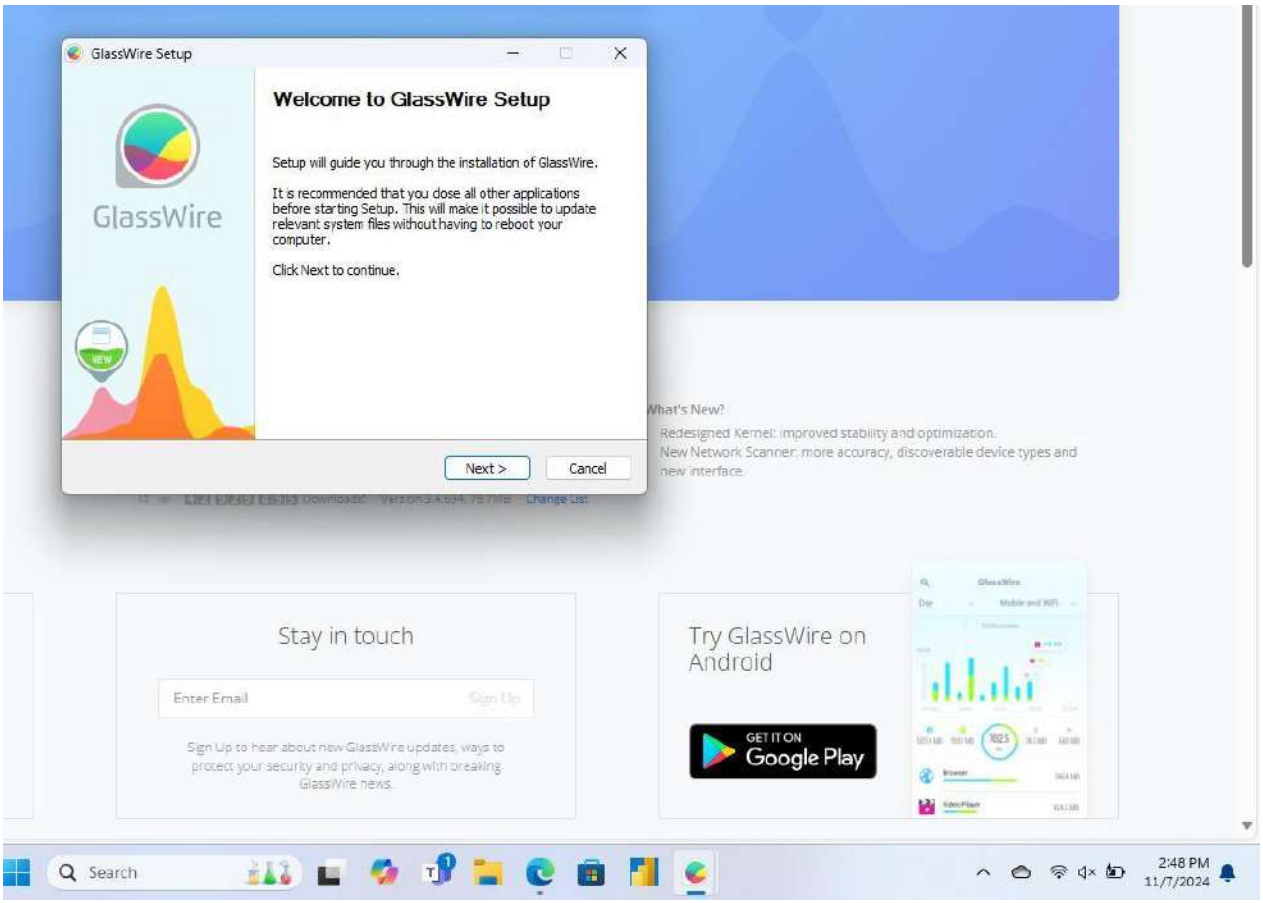
2. Click Features and scroll through the page to read about the different features and configuration options in this product.



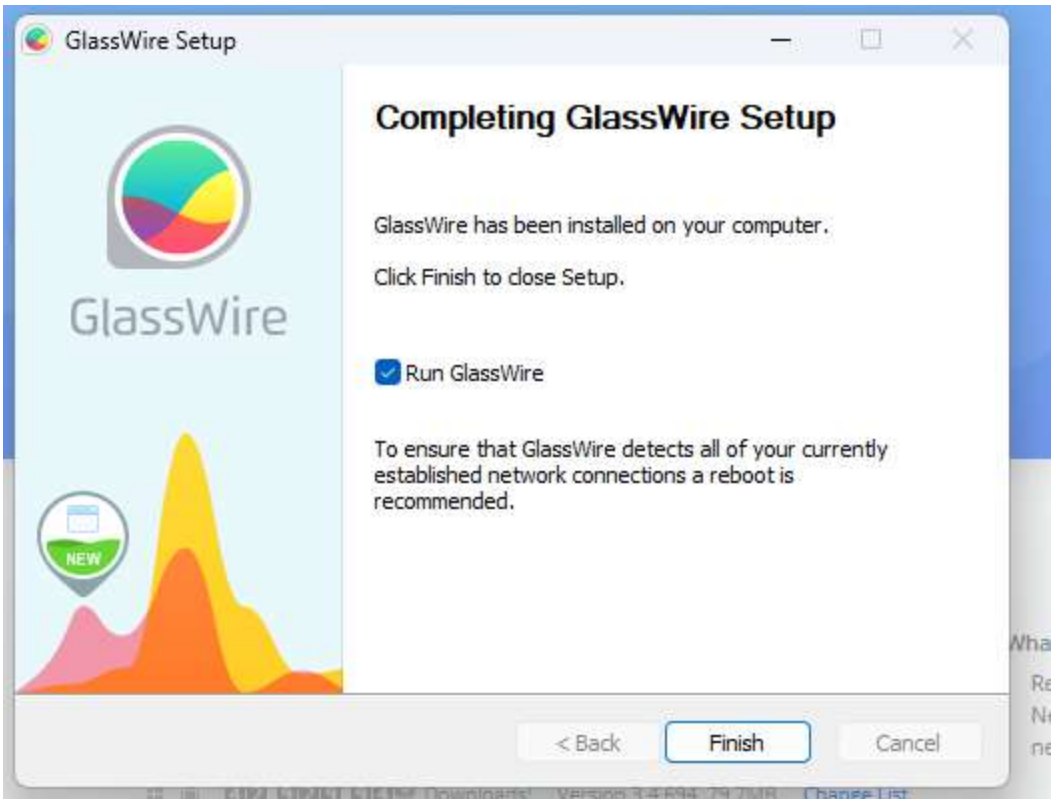
3. Click Free download and then click download Glass wire to download the file.



4. Navigate to the location of the downloaded file GlasswireSetup.exe and launch this program to install GlassWire by accepting the default settings.

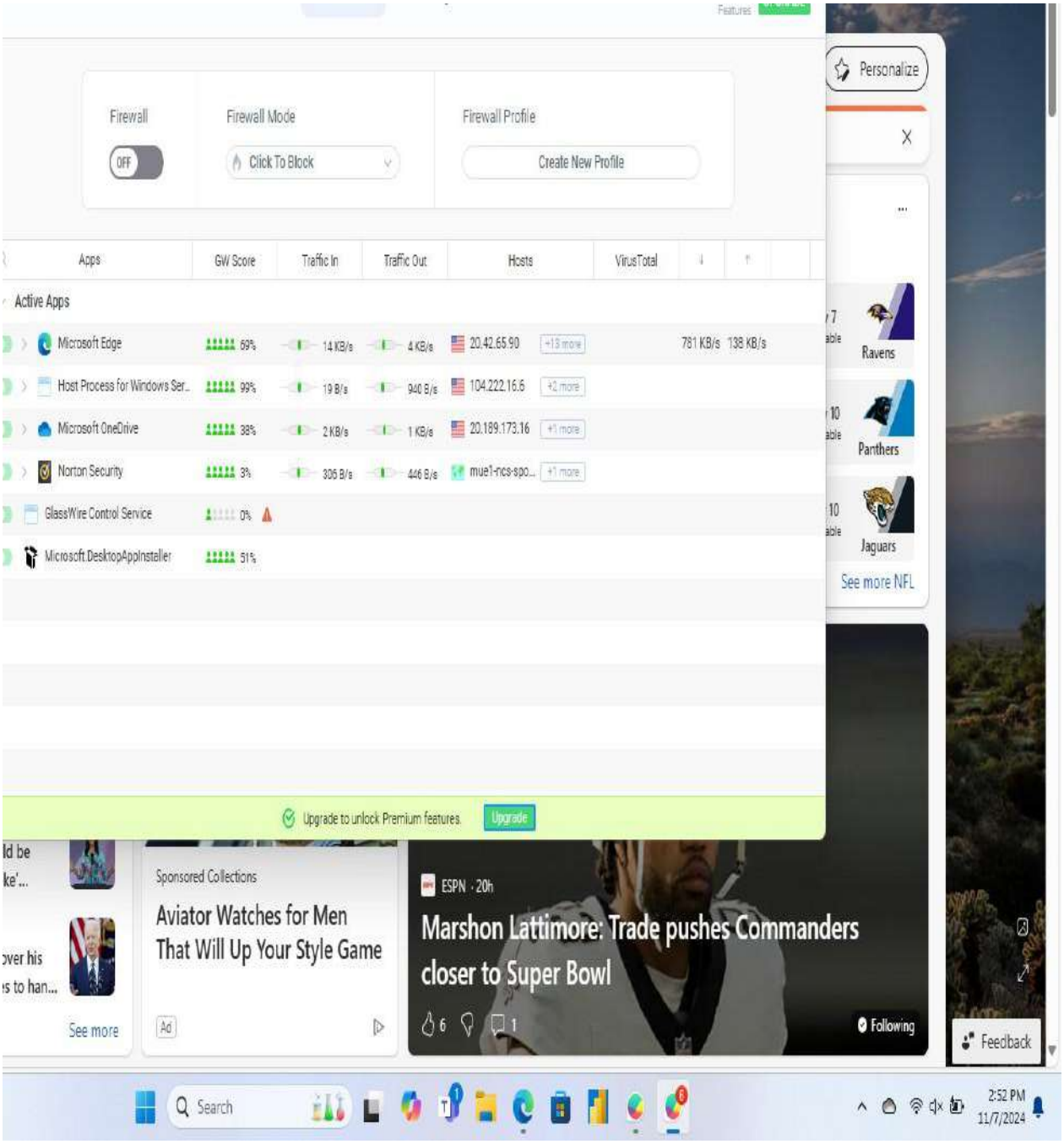


5. Click Finish to run GlassWire.



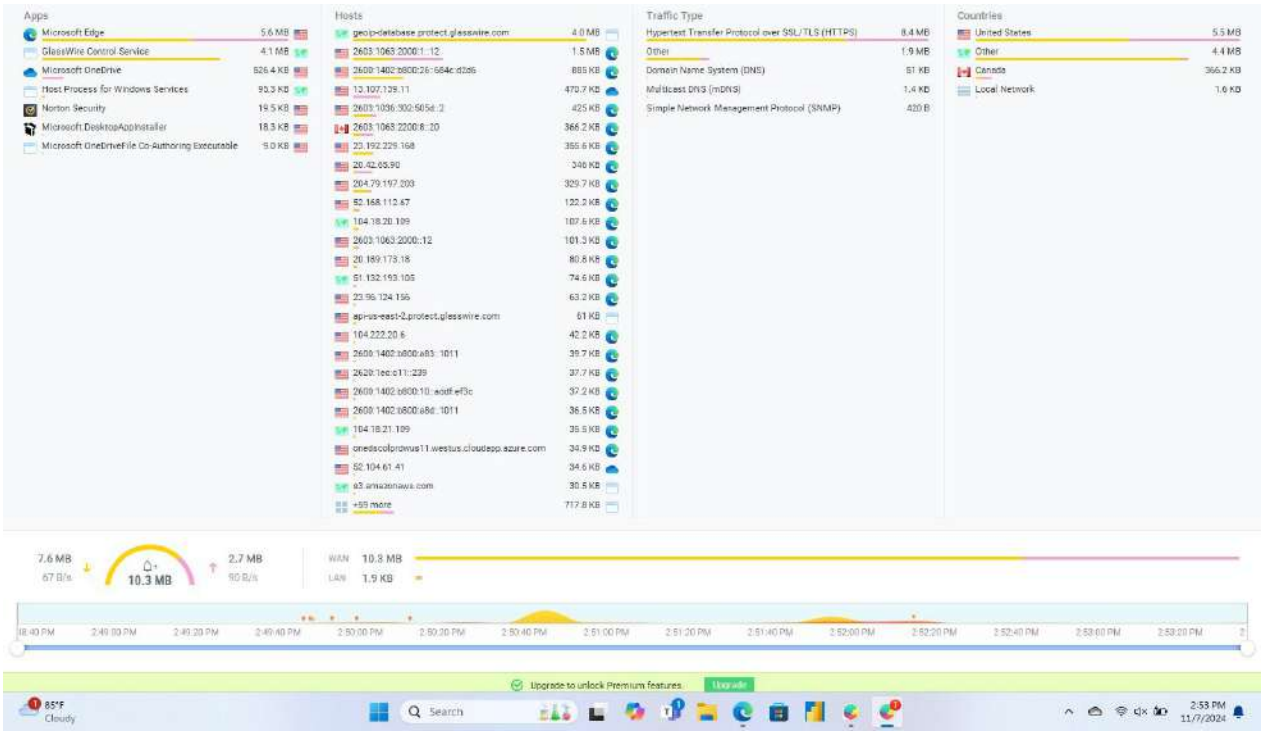
6. Note that the information scrolls horizontally to the left regarding events that are occurring. Open a web browser and surf the Internet for several minutes.

7. Return to GlassWire.



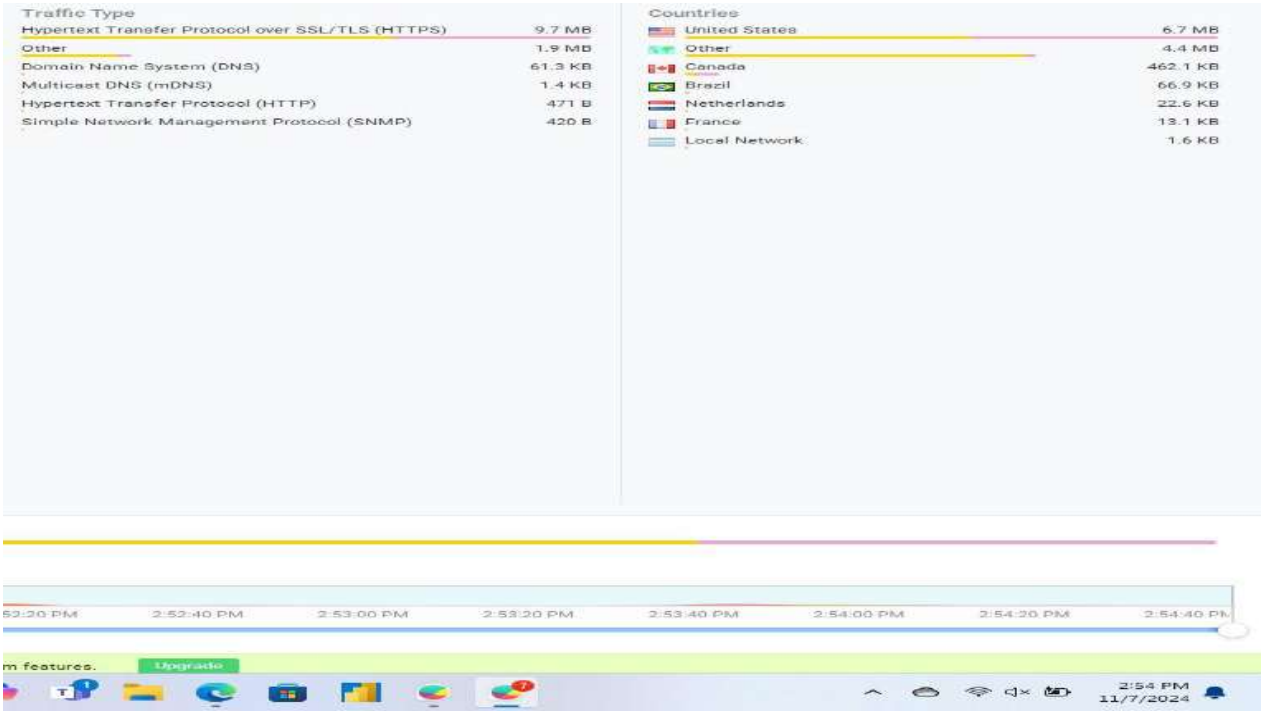
8. Slide the scroller at the bottom of the screen to consolidate the views.

9. Click Apps. What information is given in the left pane? How can this be useful?

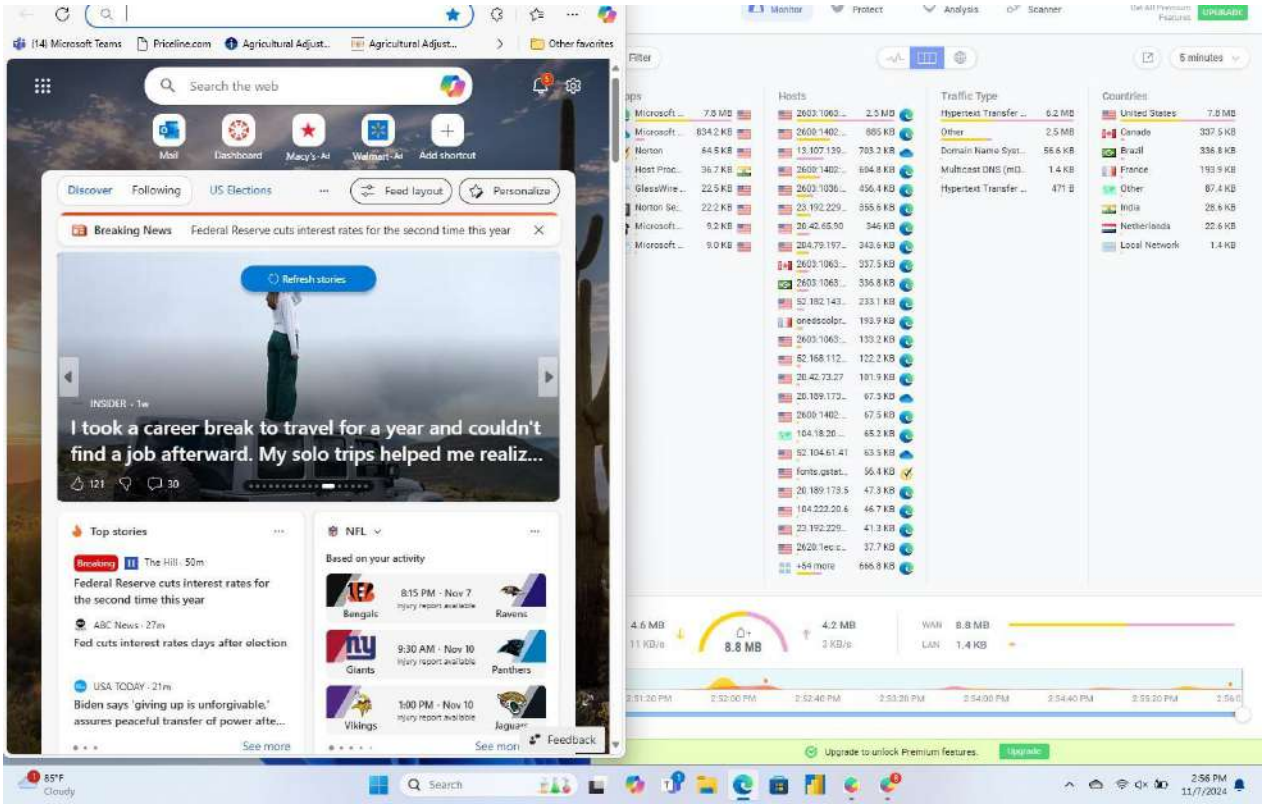


It can highlight the consumption of each app

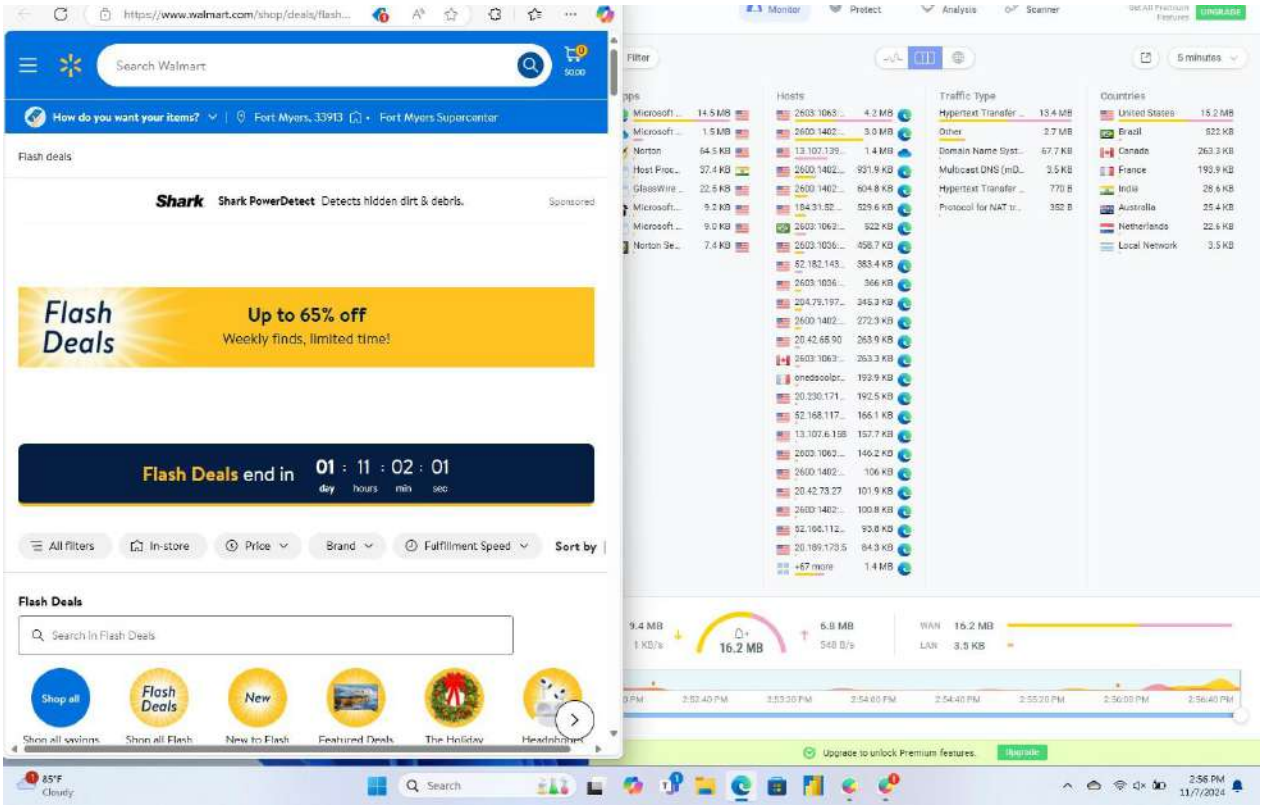
10. Click Traffic to view an analysis of the different traffic types.



11. Open a web browser, and then arrange the GlassWire window and the browser window side by side on your computer screen.



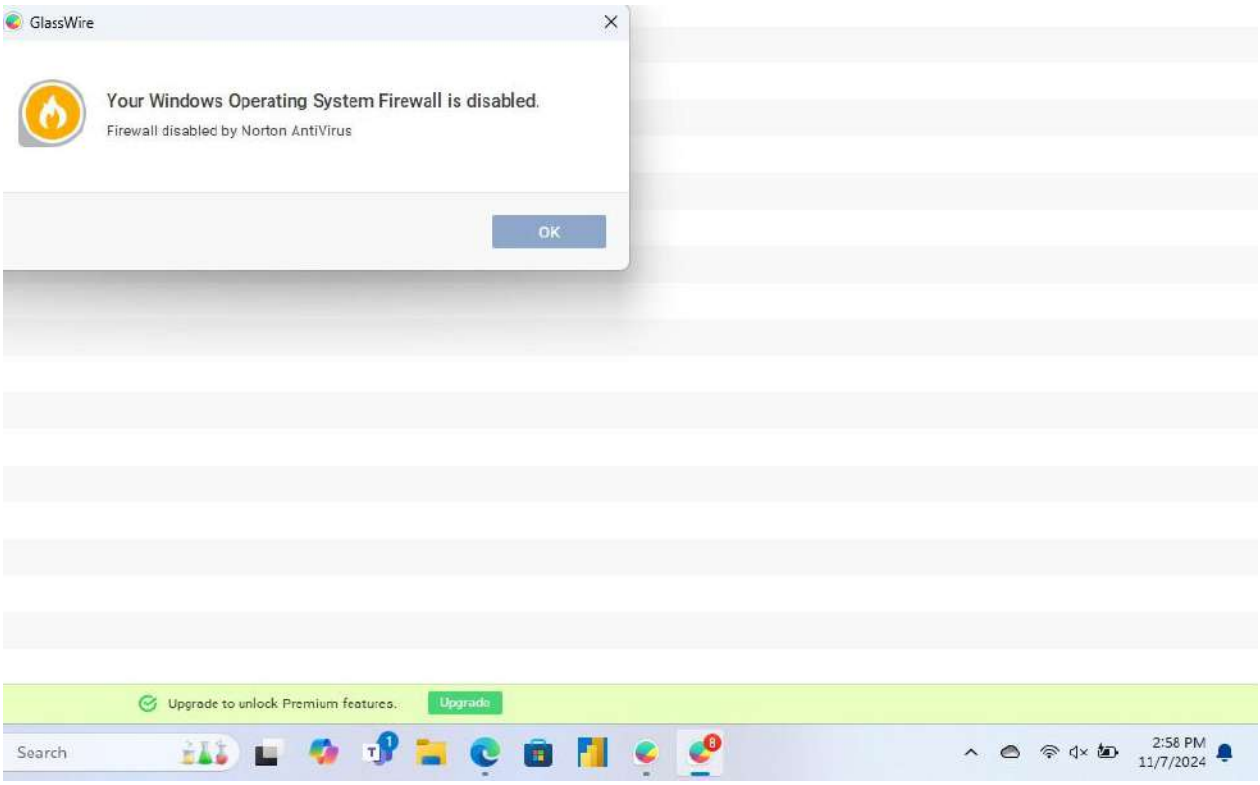
12. Use your web browser to surf the web, and watch the GlassWire screen as well. What can you learn from this?



It will update in real time to show new hosts and their countries

13. Close the browser window and maximize GlassWire.

14. Click the Firewall button. What apps or services have recently gone through your firewall?



N/A

15. Click the usage button to see a summary of the local Apps utilized, the Hosts accessed, and the Traffic Type.

16. Click Alerts. Scroll through any alerts that have been issued. What can you tell about them?

The outputs vary

17. How valuable is this information from GlassWire?

For me it is only slightly valuable because I don't know what to do with some of the information. For a professional it could be very valuable depending on the goal.

18. Close all windows.

case project G-5: UTM comparison

Description: Create a table of four UTM devices available today. Include the vendor's name, pricing, a list of features, the type of protections it provides, etc. Based on your research, assign a value of 1–5 (from lowest to highest ranking) that you would give that UTM. Include a short explanation of why you gave it that ranking

Introduction:

Unified Threat Management (UTM) devices are integral to modern network security, providing a comprehensive solution that combines multiple security functions within a single platform. UTMs typically offer features such as firewalls, intrusion prevention systems, antivirus protection, and web filtering, helping organizations streamline their security infrastructure and simplify network management. With cyber threats evolving, selecting a reliable UTM device that meets organizational needs and budget constraints is crucial for maintaining robust network defenses.

Vendor	Model	Pricing	Features	Protections Provided	Rating	Explanation
Cisco	Firepower NGFW	Starting at $595	IPS, Advanced Malware Protection (AMP), URL Filtering, VPN, Application Control	Network, Web, Application, Intrusion Prevention	5	Cisco's Firepower NGFW offers advanced security features suitable for various business sizes. Integration with Defense Orchestrator simplifies management, though its high cost may limit smaller enterprises.
Fortinet	FortiGate NGFW	Starts at $499	SD-WAN, Zero Trust Network Access, AI Threat Detection,	Network, Malware, Web, Threat Intelligence	4	FortiGate's AI-driven threat detection and comprehensive UTM suite make it a powerful option for

			Intrusion Prevention, Sandboxing			enterprises with high traffic volumes, though it has a learning curve.
Sophos	UTM	Approx. $350/year	Advanced Threat Protection (ATP), Intrusion Prevention System (IPS), VPN, Email/Web Filtering	Network, Email, Web, Application	4	Sophos UTM's modular, intuitive design is ideal for mid-sized and smaller businesses. However, it lacks some cloud integration capabilities seen in more advanced systems.
WatchGuard	Firebox	Starting at $520	Gateway Antivirus, URL Filtering, VPN, Application Layer Inspection, Behavioral Sandbox Detection	Network, Malware, Web, Application	3	WatchGuard Firebox is cost-effective and well- suited to smaller businesses, though it lacks advanced threat intelligence integrations found in higher-end options.

Project 8-3: mac spoofing

Time required: 25 minutes

objective: Given a scenario, analyze potential indicators associated with network attacks.

description: In a Mac cloning attack, threat actors discover a valid Mac address of a device connected to a switch. They spoof the Mac address on their device and send a packet onto the network. In this activity, you will spoof a Mac address.

INTRODUCTION

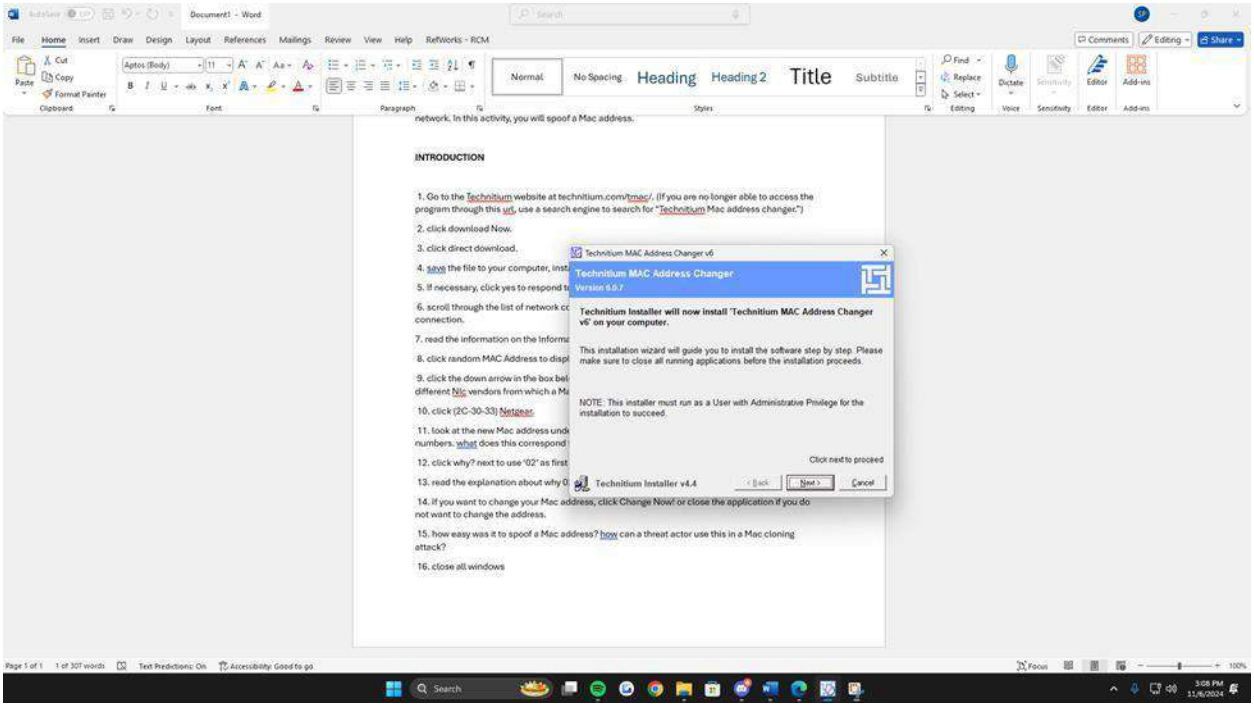
A Media Access Control (MAC) address is a number assigned to network devices to identify individual devices. In a MAC cloning attack, attackers can exploit them for unauthorized access or disruption. By identifying the valid MAC addresses on a network, attackers can spoof this address on their own device and send malicious packets onto the network impersonating that device (Cranor, 2021). They can bypass MAC filtering security measures utilizing this spoof and this lab will demonstrate how easy it is to change your own MAC address.

1. Go to the Technitium website at technitium.com/tmac/. (If you are no longer able to access the

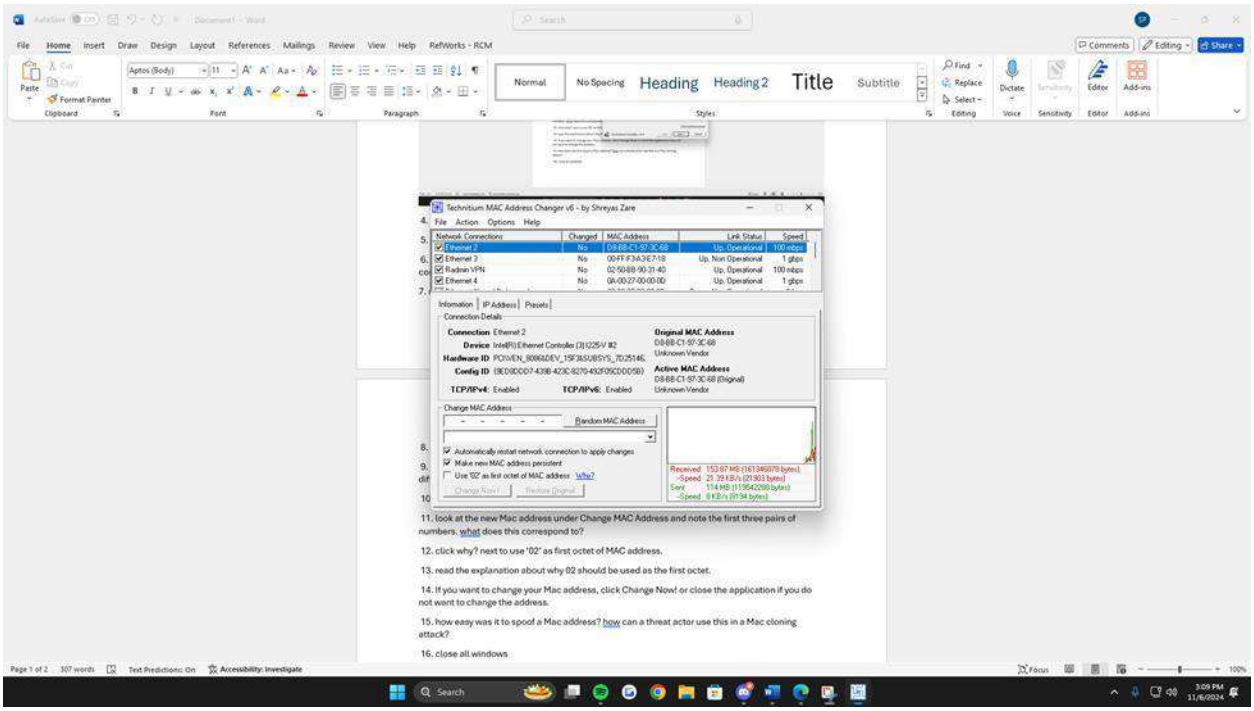
program through this url, use a search engine to search for “Technitium Mac address changer.”)

2. click download Now.

3. click direct download.



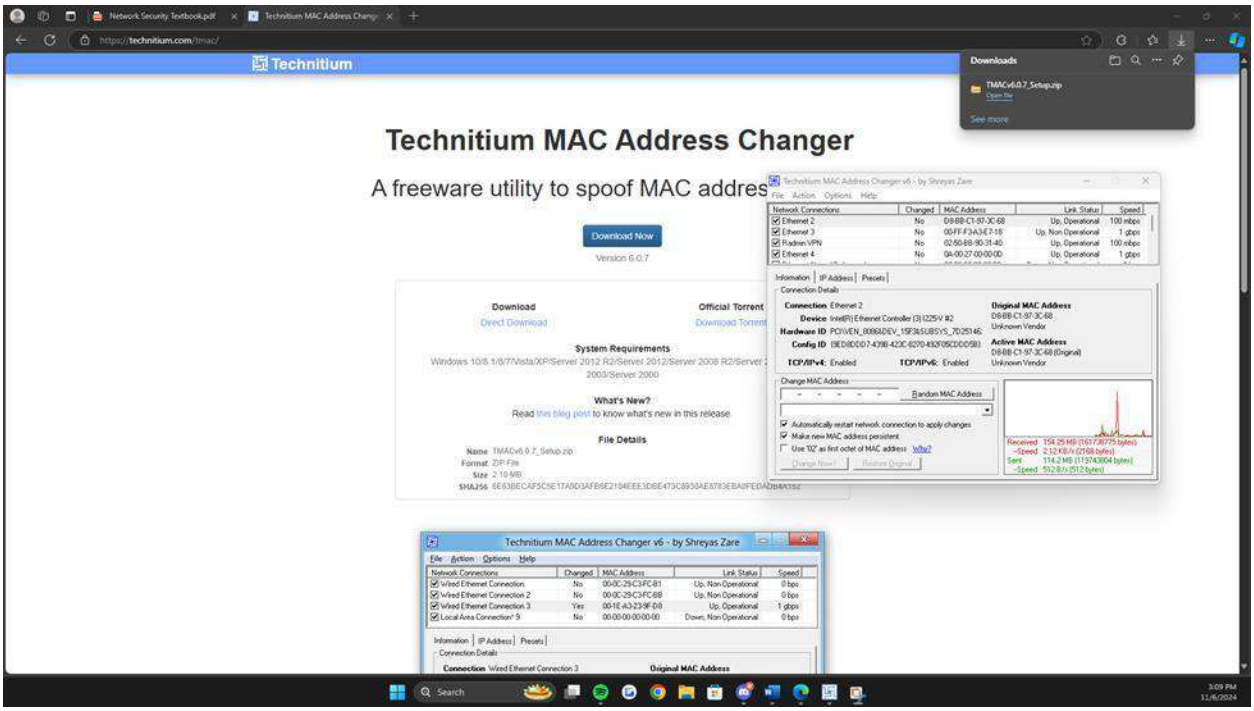
4. save the file to your computer, install the application, and then start it.



5. If necessary, click yes to respond to the dialog box.

6. scroll through the list of network connections on your computer, and then select your Internet connection.

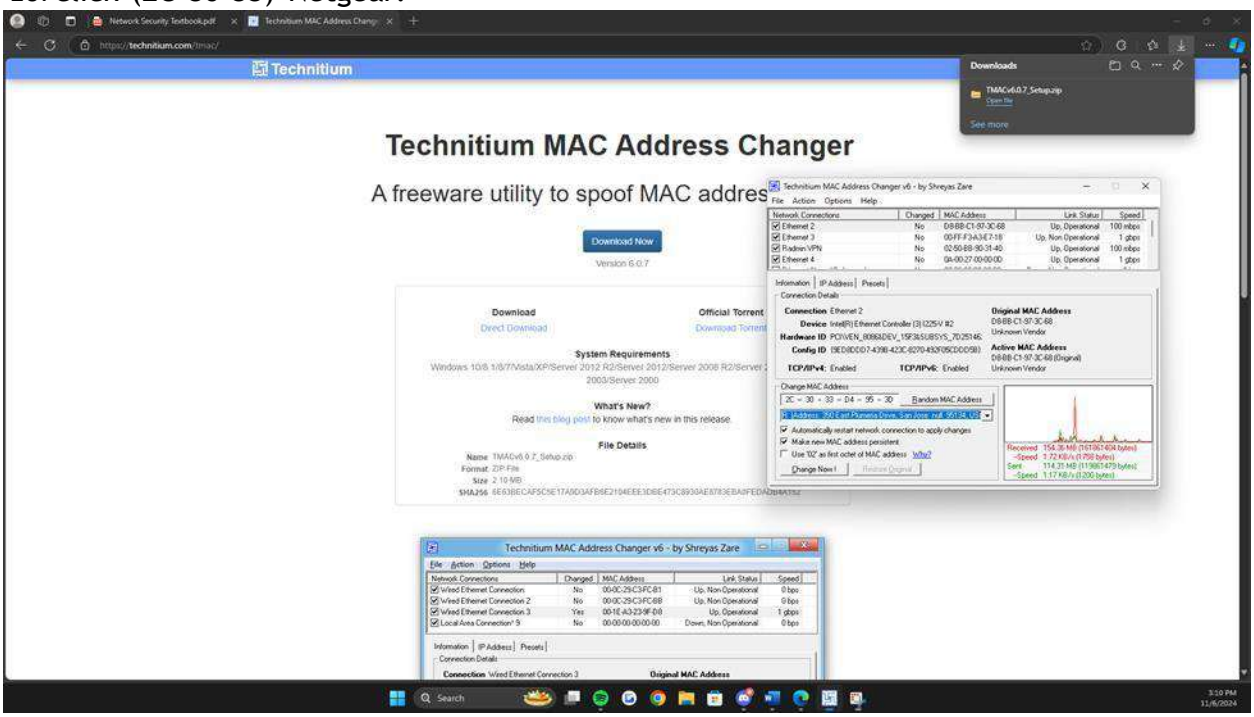
7. read the information on the Information tab.



8. click random MAC Address to display another Mac address that can be assigned to this device.

9. click the down arrow in the box below the new random Mac address. Note the long list of different NIc vendors from which a Mac address can be chosen.

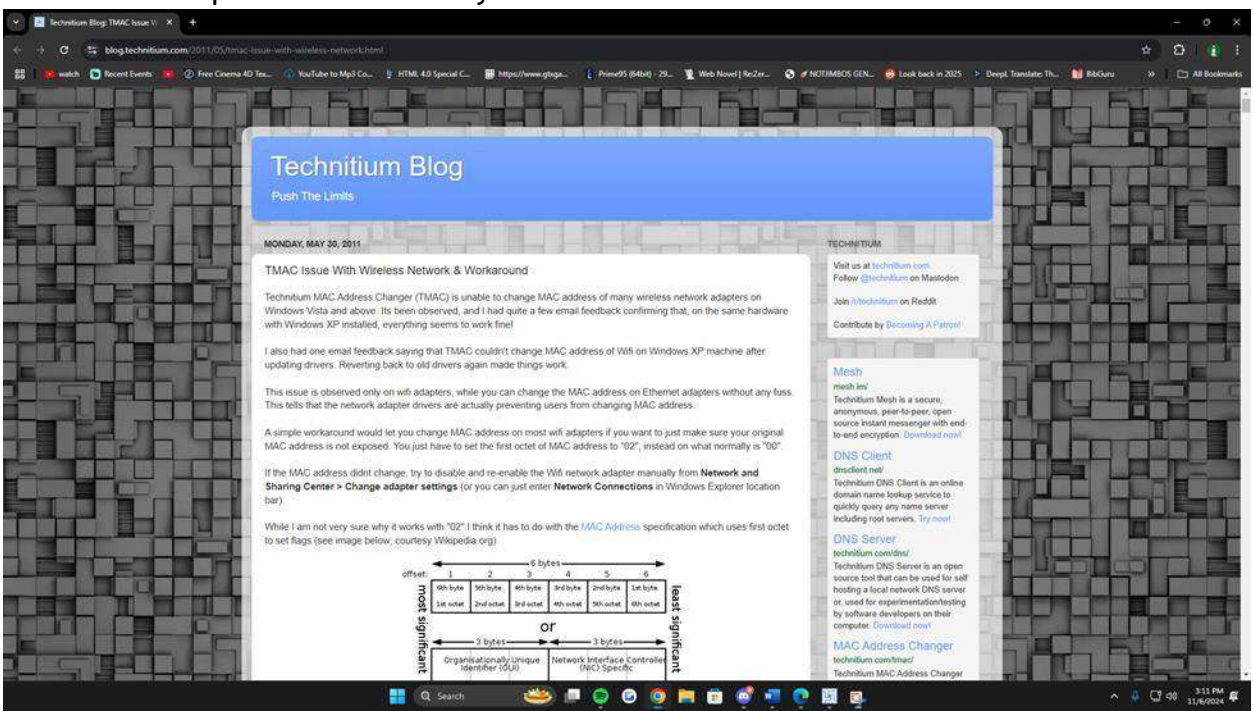
10. click (2C-30-33) Netgear.



11. look at the new Mac address under Change MAC Address and note the first three pairs of numbers. what does this correspond to? **It corresponds to the NIC vendor identifier code**

12. click why? next to use '02' as first octet of MAC address.

13. read the explanation about why 02 should be used as the first octet.



14. If you want to change your Mac address, click Change Now! or close the application if you do not want to change the address.

15. how easy was it to spoof a Mac address? how can a threat actor use this in a Mac cloning attack? **After installing the application, you can change it within seconds each time. Some networks use MAC address filtering as a form of access control, allowing only devices with pre-approved MAC addresses to connect. A threat actor could observe the MAC address of an authorized device and clone it to gain unauthorized access to the network.**

16. close all windows

Case Project 10-1: trustworthy email Protocols and Standards

In addition to S/MIME, there are several protocols and standards that protect email. These include STARTTLS, DNS Based Authentication of Named Entities (DANE), Sender Policy Framework (SPF), DomainKeys Identified Mail (DKIM), and Domain-based Message Authentication, Reporting, and Conformance (DMARC). Use the Internet to research each of these. Create a summary of each along with the respective strengths and weaknesses. Which would you recommend? Why?

INTRODUCTION

To protect the integrity, authenticity, and confidentiality of emails, several protocols and standards have been developed, each addressing different aspects of email security. These include STARTTLS, DNS-Based Authentication of Named Entities (DANE), Sender Policy Framework (SPF), DomainKeys Identified Mail (DKIM), and Domain-based Message Authentication, Reporting, and Conformance (DMARC). Together, they form a comprehensive framework to safeguard email transmissions against malicious attacks and ensure that email communication remains trustworthy and secure (Perception Point, 2024).

STARTTLS

STARTTLS is commonly used in email communication, where SMTP servers initiate an encrypted channel for email transmission, and in Internet Relay Chat (IRC), where servers upgrade to secure connections. One of its main advantages is that it enhances data security by encrypting connections. It also offers flexibility by allowing an upgrade from an insecure to a secure connection. However, STARTTLS has drawbacks, including vulnerability to downgrade attacks, where an attacker forces the connection to remain insecure. Additionally, since STARTTLS is optional, some services may still transmit data over unencrypted connections. (NordVPN, 2024)

DNS-Based Authentication of Named Entities (DANE)

DANE strengthens email security by using DNSSEC to bind TLS certificates to domain names, reducing reliance on Certificate Authorities (CAs). This gives domain administrators more control over their security, allowing them to generate their own keys. The main advantage is streamlining trust within the DNS system. Some challenges include the need for expertise in managing CAs, potential security gaps if DNS and security roles are separated, and ongoing risks related to DNSSEC resolver compromises and certificate status checks (Housley C Turner, 2013).

Sender Policy Framework (SPF)

SPF enables domain owners to specify which IP addresses are authorized to send emails on their behalf, thus combating email spoofing. SPF works by checking the sender's IP address against a published list of allowed servers in DNS. Implementing SPF offers several advantages, such as preventing phishing attacks by flagging emails sent from unauthorized sources and boosting domain reputation by signaling a commitment to email security. However, SPF has some limitations, including the failure of forwarded emails to pass authentication, making it challenging for domain owners to maintain accurate SPF records (DuoCircle, 2023).

DomainKeys Identified Mail (DKIM)

DKIM provides message integrity by allowing the sender's domain to sign an email with a cryptographic key. The recipient can then verify the message was not altered and that it was sent from an authorized source. DKIM ensures the content's integrity and offers robust protection against certain spoofing attacks, but it can be bypassed by domain abuse or forwarding scenarios, where the signature is no longer valid after transit (Kucherawy, 2011).

Domain-based Message Authentication, Reporting, and Conformance (DMARC)

DMARC is an email authentication protocol that protects against email spoofing and impersonation by using SPF and DKIM standards. It lets domain owners specify how email should be handled when it fails authentication and provides reporting mechanisms to identify failed

authentication attempts. It can prevent phishing attacks and improve domain security by

blocking unauthorized use of domain for sending fraud emails. Its effectiveness is based on configuration and doesn't protect against all types of email-based attacks (Mimecast, 2024).

DMARC is recommended for comprehensive email protection. While each protocol addresses specific threats, DMARC provides a unified approach by leveraging both SPF and DKIM for authentication while offering reporting mechanisms to monitor email activity. Its combination of sender authentication and domain management makes it an effective solution for mitigating email- based attacks, particularly phishing and spoofing, despite the complexity of initial implementation.

References

Cranor, L. (2021). *Security and Usability: Designing Secure Systems That People Can Use.* O'Reilly Media, Inc.

DuoCircle. (2023, May 5). *Advantages and Disadvantages of SPF*. Retrieved from DuoCircle: https://support.duocircle.com/support/solutions/articles/5000882462-advantages-and- disadvantages-of-spf

Expert Insights. (2024). *The Top 8 Unified Threat Management Platforms*. Retrieved from https://www.expertinsights.com

Geekflare. (2024). *S Best Unified Threat Management (UTM) Solutions for Small to Big Businesses.* Retrieved from 9 Best Unified Threat Management (UTM) Solutions for Small to Big Businesses - Geekflare

Housley, R., C Turner, S. (2013, March 12). *The Promise of DANE*. Retrieved from National Institute of Standards and Technology: https://csrc.nist.gov/csrc/media/events/workshop-on- improving-trust-in-the-online- marketpl/documents/submissions/housley_promise_dane.pdf

Kucherawy, M. (2011, September). *DomainKeys Identified Mail (DKIM) and Mailing Lists.* Retrieved from Internet Engineering Task Force: https://www.rfc-editor.org/rfc/pdfrfc/rfc6377.txt.pdf

Assignment 5 – Hands On

Sam Peller

November 27, 2024

ISM 4323

Project 11-2: Viewing WLAN Security Information with Vistumbler

Project 11-2: Viewing WlAN security information with Vistumbler 345

Time required: 25 minutes

Objective: Given a scenario, install and configure wireless security settings.

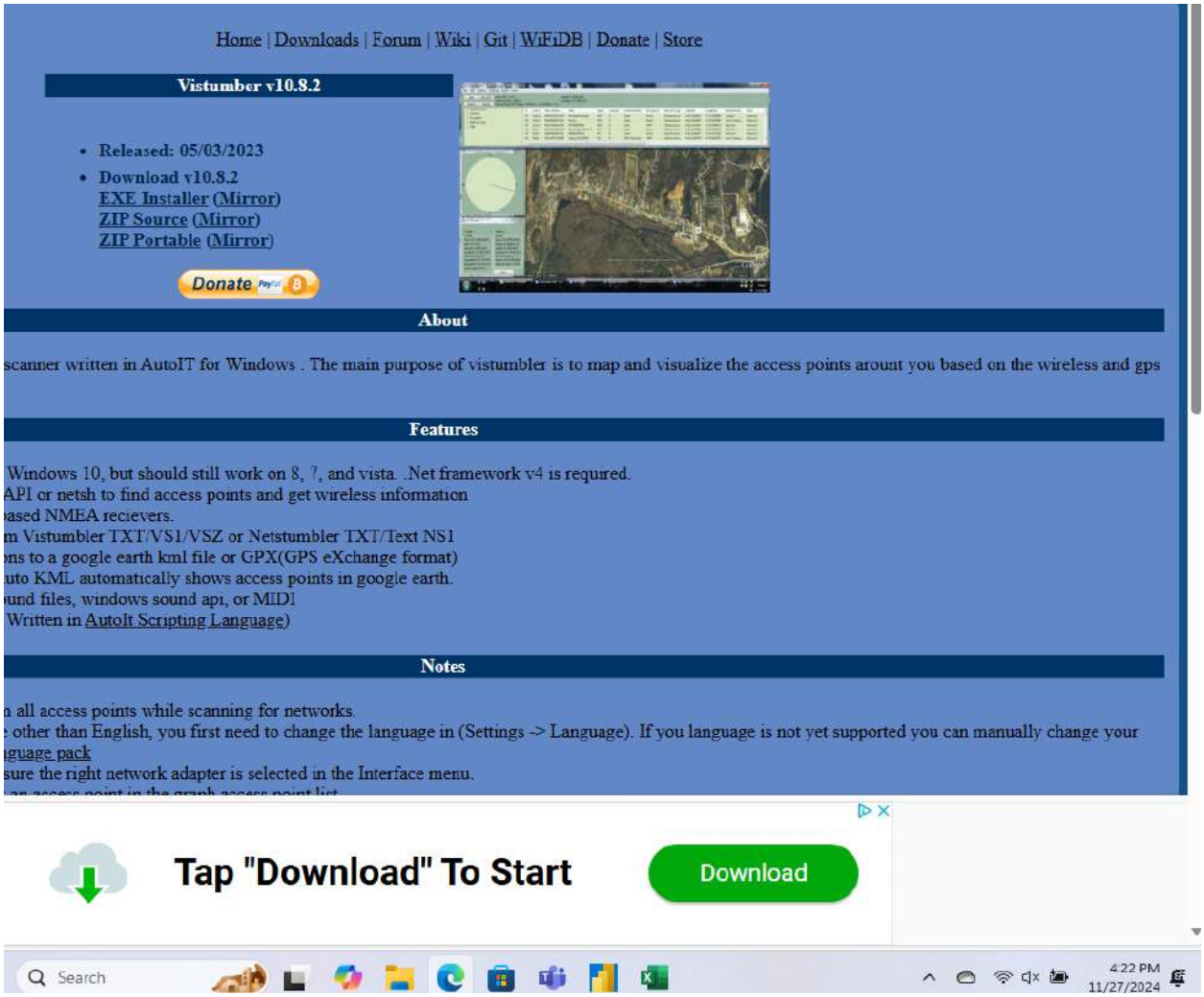
description: Vistumbler can be used to display the security information that is beaconed out from WLANs. Note that Vistumbler does not allow you to "crack" any WLANs but instead only displays information. In this project, you use Vistumbler to view this information. This project works best when you are in an area in which you can pick up multiple WLAN signals.

Introduction:

Vistumbler is a useful tool for visualizing security information broadcasted by wireless local area networks (WLANs). While it does not provide capabilities for cracking or breaching network security, it is an effective way to gather information about available WLANs, such as their signal strength, encryption types, and other key details. Exploration works particularly well in areas with multiple WLAN signals, allowing for a more diverse set of observations and insights into network characteristics and coverage.

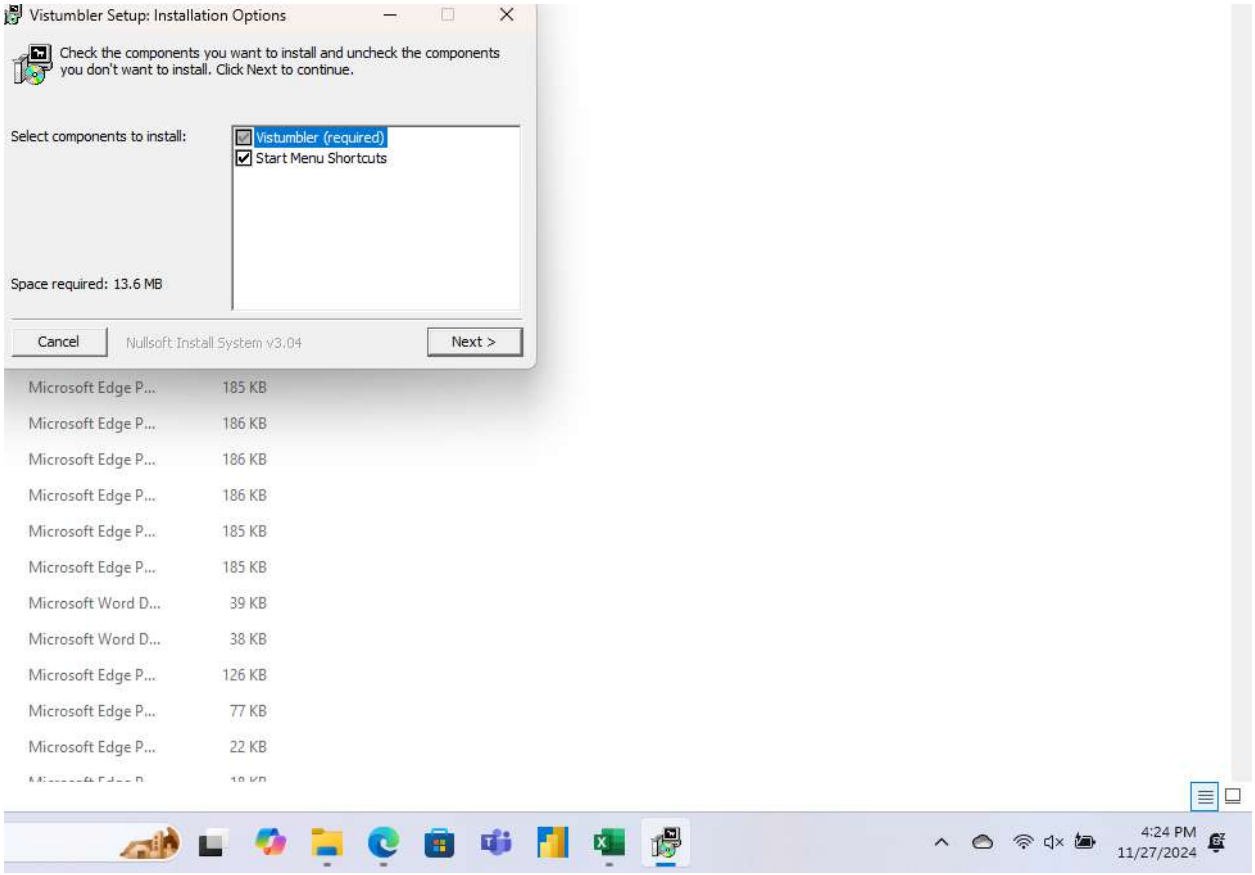
1. Use your web browser to go to www.vistumbler.net. (The location of content on the Internet may change without warning. If you are no longer able to access the program through this URL, use a search engine and

search for “Vistumbler.”)

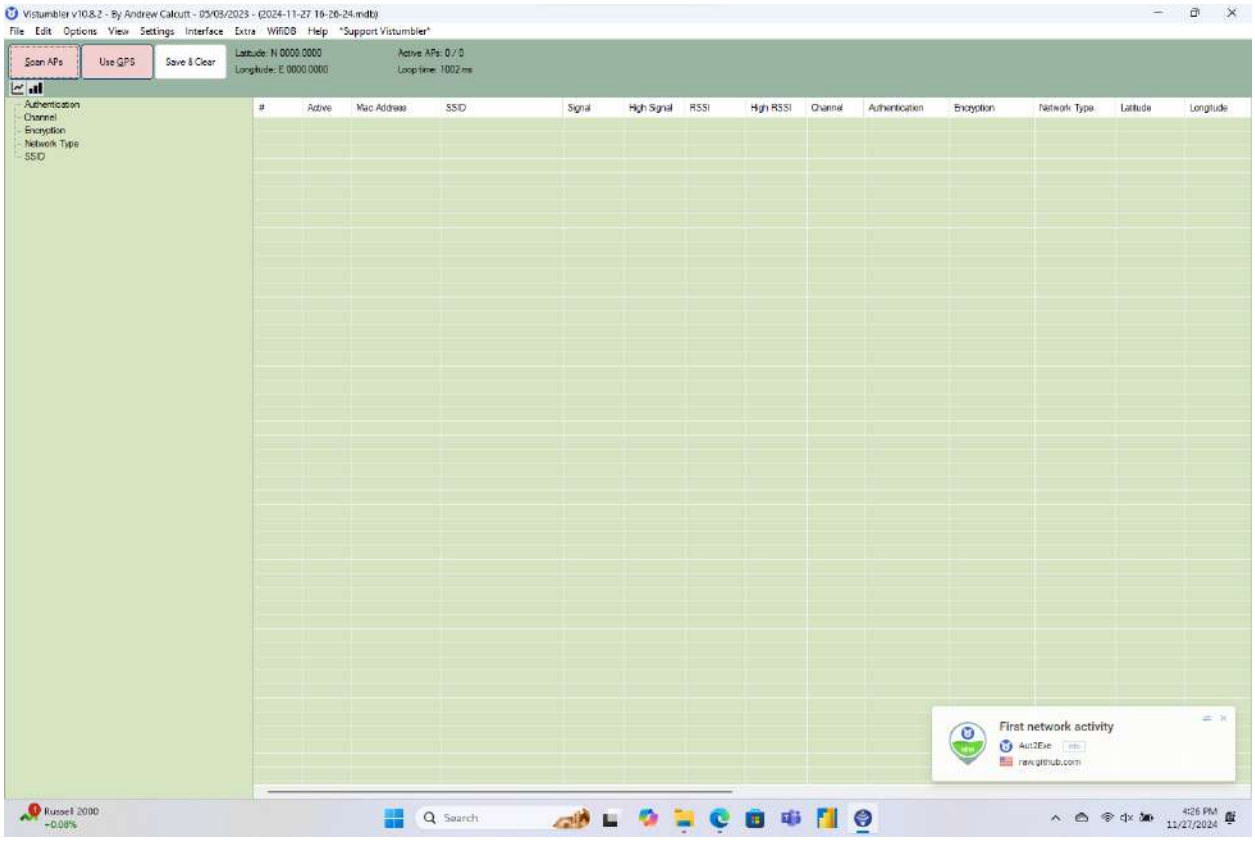


2. Click eXe Installer (Mirror).

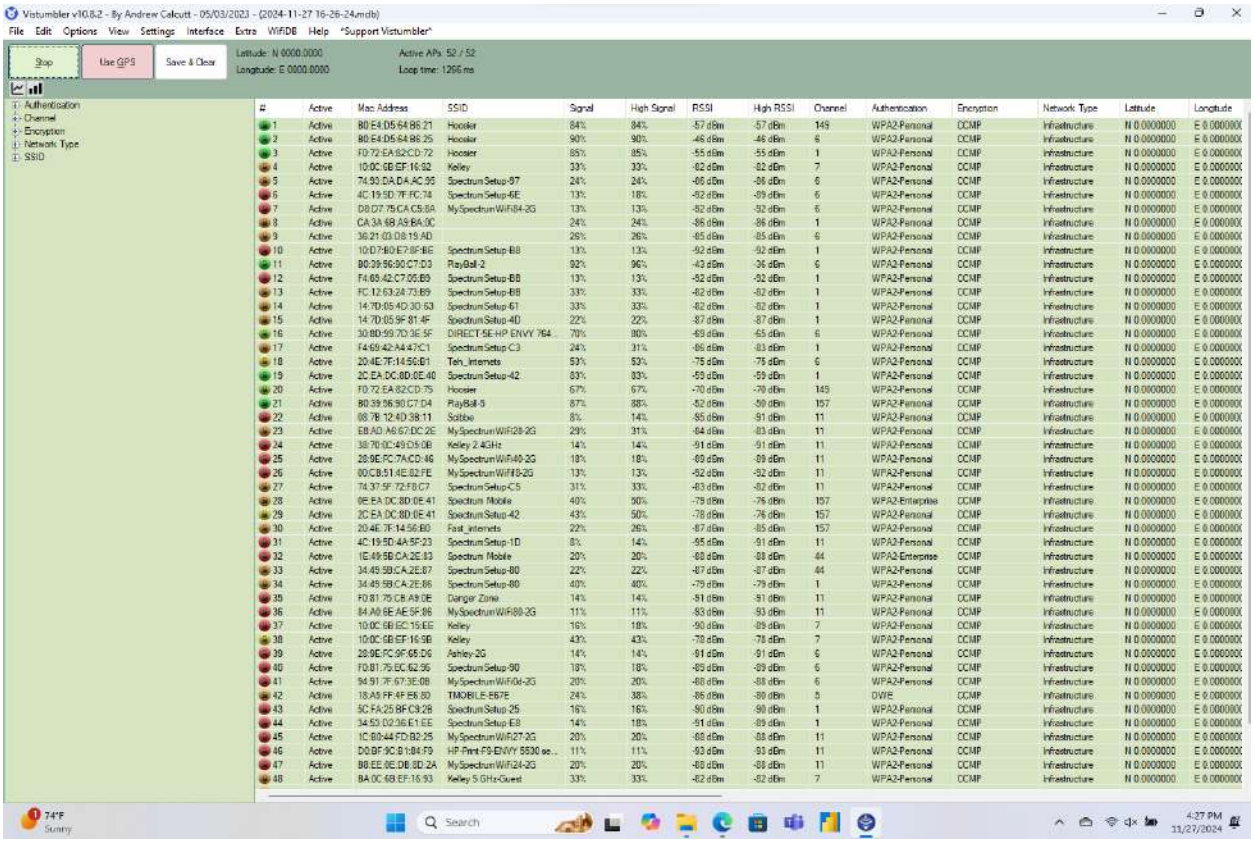
3. Follow the prompts to download and install Vistumbler using the default settings



4. If the program does not start after the installation is complete, launch Vistumbler.
5. If necessary, expand the window to full screen



6. Click Scan APs. If no networks appear, click Interface and then select the appropriate wireless NIC interface.

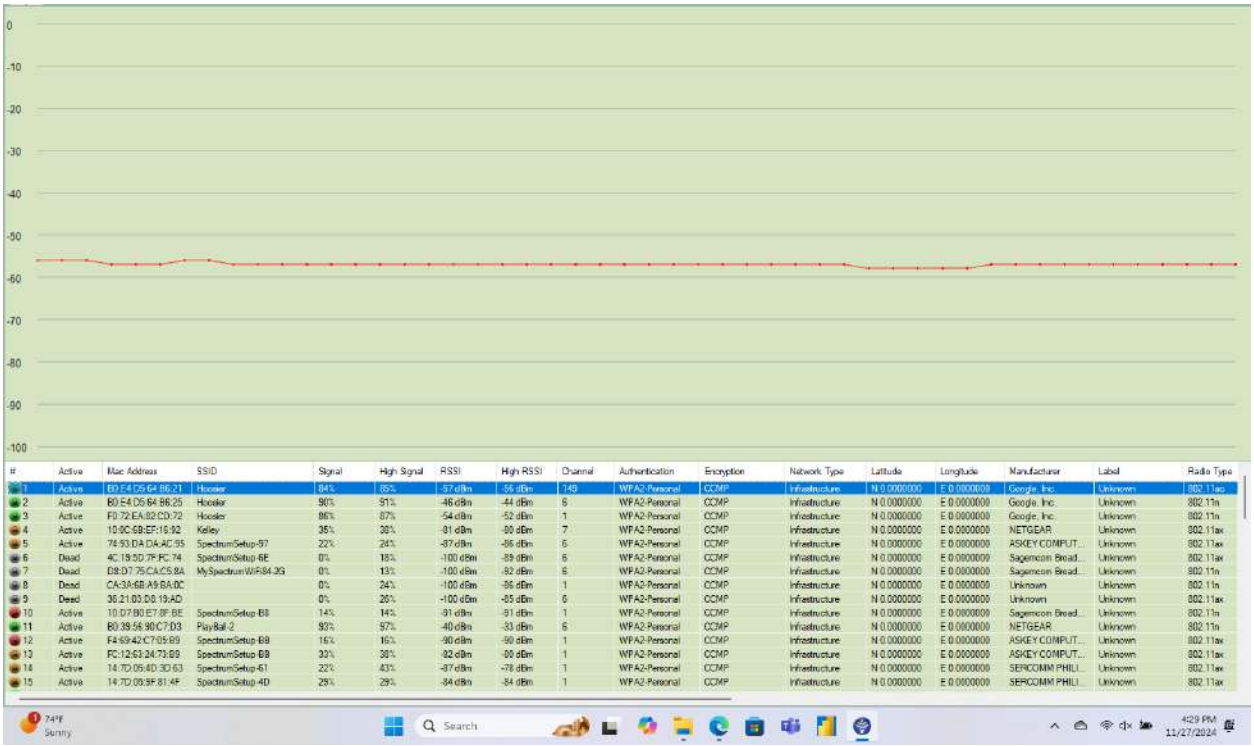


7. Note the columns Signal and High Signal. How could they be used in a site survey?

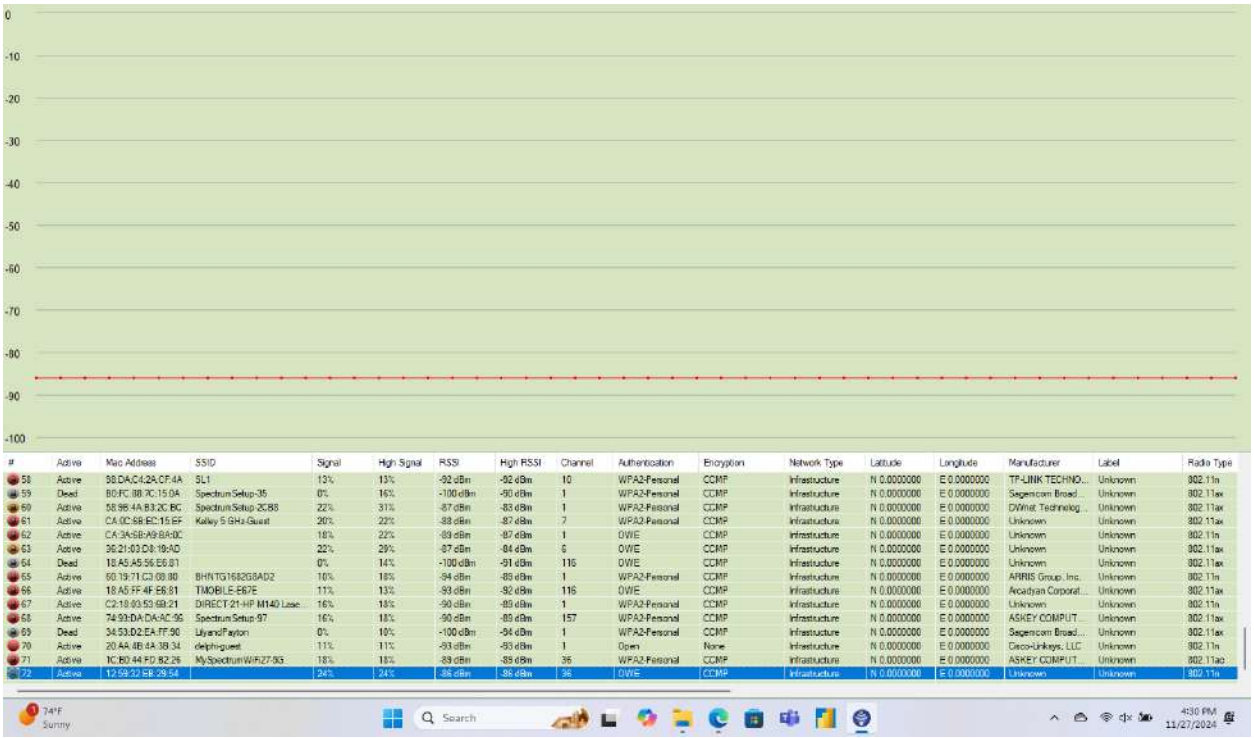
In a site survey, the "Signal" and "High Signal" columns help assess wireless signal strength and quality throughout an area. The "Signal" column shows the strength of the wireless signal, helping identify weak coverage areas that may need more access points or adjustments. The "High Signal" column indicates areas with strong coverage, useful for ensuring key locations have reliable connectivity. Comparing these columns helps identify signal fluctuations or interference, guiding decisions on optimizing access point placement. Together, they ensure consistent and effective wireless coverage across the site.

8. Click Graph 1.

9. Click one of the APs displayed at the bottom of the screen. Allow Vistumbler to accumulate data over several minutes. What information is displayed on this graph?



10. Click Graph 2.
11. Click another one of the APs displayed at the bottom of the screen. Allow Vistumbler to accumulate data over several minutes. What information is displayed on this graph? How is this different from the previous graph?



12. Click No Graph to return to the previous screen.
13. Use the horizontal scroll bar to move to the right. Note the columns Authentication, encryption, Manufacturer, and radio Type. How would this information be useful to an attacker?

They provide critical information that could be exploited by an attacker. The "Authentication" and "Encryption" columns reveal the security protocols in use, such as WPA2 or WEP, allowing an attacker to identify weaker security methods that are more susceptible to attacks, like cracking WEP keys. The

"Manufacturer" column can provide insight into the type of devices being used, which helps an attacker target known vulnerabilities specific to that brand. Finally, the "Radio Type" column provides details on the wireless standard (e.g., 802.11n, 802.11ac), which could help an attacker determine potential attack methods or limitations of the network. Together, this information allows an attacker to identify weak points in the network and tailor their approach for gaining unauthorized access.

14. Use the horizontal scroll bar to move back to the far left.

15. In the left pane, expand the information under Authentication. What types are listed?



16. Expand the information under these types and note the information given for the wireless LAN signals.



17. In the left pane, expand the information under encryption. What types are listed? Which types are most secure? Which types are least secure?

types like WEP, WPA, WPA2, are listed. WPA2, then WPA is less secure, while WEP is the least secure and highly vulnerable. It is best to use WPA3 or WPA2 and avoid WEP and WPA.

18. Expand the information under these types and note the information given for each WLAN.



19. Record the total number of different WLANs that you can detect, along with the number of encryption types. Which type is most common?
WPA2
20. One of the features of Vistumbler is its ability to use audio and text-to-speech information so that the location and strength of WLANs can be detected without the need to constantly monitor the screen. Be sure that the speakers on the laptop computer are turned on.
21. Click Options.
22. Click Speak Signals. Vistumbler will “speak” the percentage of signal strength.
23. Now carry the laptop away from the AP and note the changes. How would this be helpful to an attacker?

It allows an attacker to determine the range and coverage area of the wireless network in real-time. This information helps them identify the network boundaries, weak signal spots, and potential locations where they can remain undetected while still accessing the network. It also assists in finding an optimal position for attempting attacks, such as cracking the network encryption, while maintaining a stable connection to the target AP.
24. Close Vistumbler

Case Project 11-6: Your Personal Wireless Security
Description:

Is the wireless network you own as secure as it should be? Examine your wireless network or that of a friend or neighbor and determine which security model it uses. Next, outline the steps it would take to move it to the next highest level. Estimate how much it would cost and how much time it would take to increase the level. Finally, estimate how long it would take you to replace all the data on your computer and what you might lose if the data were corrupted by an attacker. Would this be motivation to increase your current wireless security model? Write a one-page paper on your work
Introduction:

In today's increasingly connected world, the security of wireless networks is a critical concern for individuals and households. A secure wireless network is essential to protect sensitive information from unauthorized access and cyber threats. This paper examines the current security model of a personal

wireless network and explores the steps required to enhance its security. The analysis considers the costs, time involved, and potential consequences of a data breach, ultimately highlighting the importance of proactive measures in maintaining robust network security.

Examining a personal wireless network, I determined that it currently employs the WPA2-Personal (Wi-Fi Protected Access 2) security model. While WPA2 is relatively secure, recent advancements in cyberattacks, such as brute force and dictionary attacks, suggest that moving to a more advanced security model would be prudent. The next highest level of wireless security is WPA3, which provides enhanced encryption algorithms and more robust protections against attacks.

To upgrade to WPA3, several steps would be required. First, the router's firmware needs to be checked to see if it supports WPA3 through an update. If not, purchasing a new router capable of WPA3 is necessary. A reliable, mid-range router supporting WPA3 would cost around $100 to $200, while installation and configuration would take approximately 1-2 hours, probably 2 judging my skill level... including updating passwords for connected devices. This is a small investment considering the increased protection against potential threats.

In the event of a security breach, replacing corrupted data on a computer would be a time-consuming process. Based on the amount of data currently stored, it could take 10 to 12 hours to fully restore everything from backups. The potential loss includes personal documents, photos, and work files that may not have been backed up recently, leading to irreplaceable losses. This scenario highlights the critical importance of improving wireless security and serves as strong motivation to upgrade the network to WPA3. The cost and effort to upgrade are minor compared to the consequences of a successful attack, making the enhancement well worth the time and investment.

Project 13-2: viewing Windows slack and Hidden data

●

Time required: 20 minutes

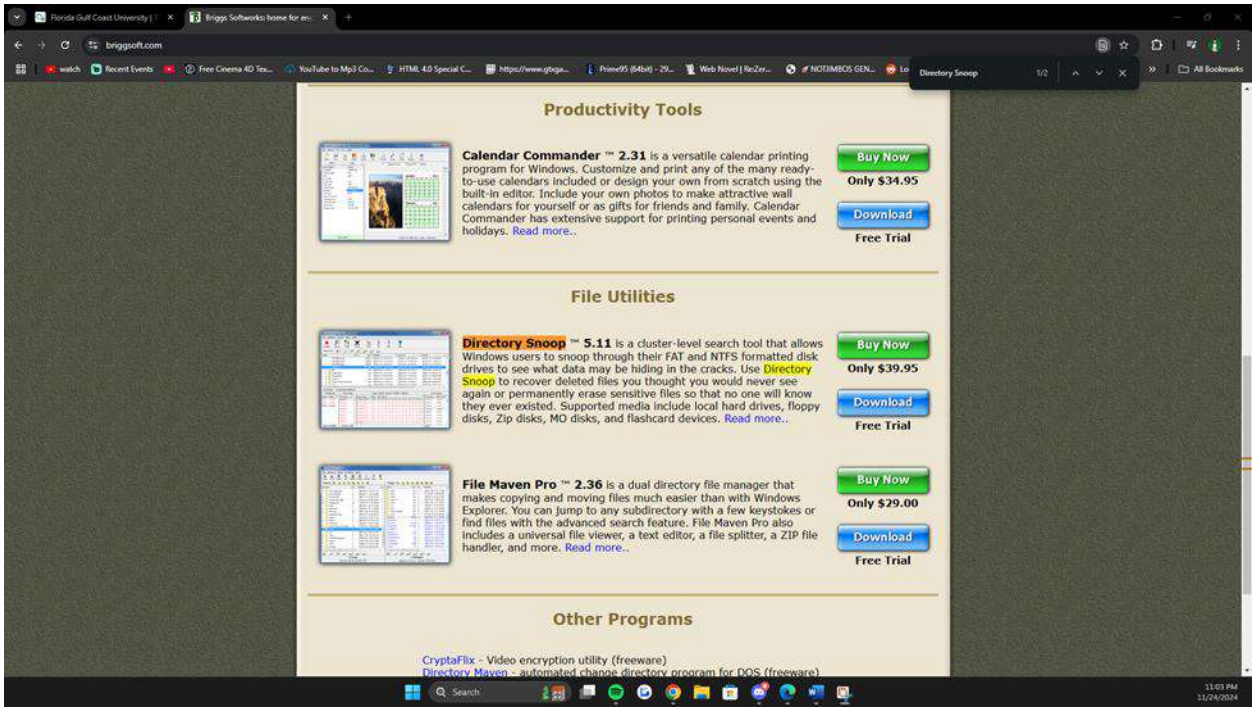
Objective: 4.5 Explain the key aspects of digital forensics. Data recovery

description: RAM slack, drive slack, and other hidden data can be helpful to a computer forensics investigator. In this project, you download and use a program to search for hidden data.

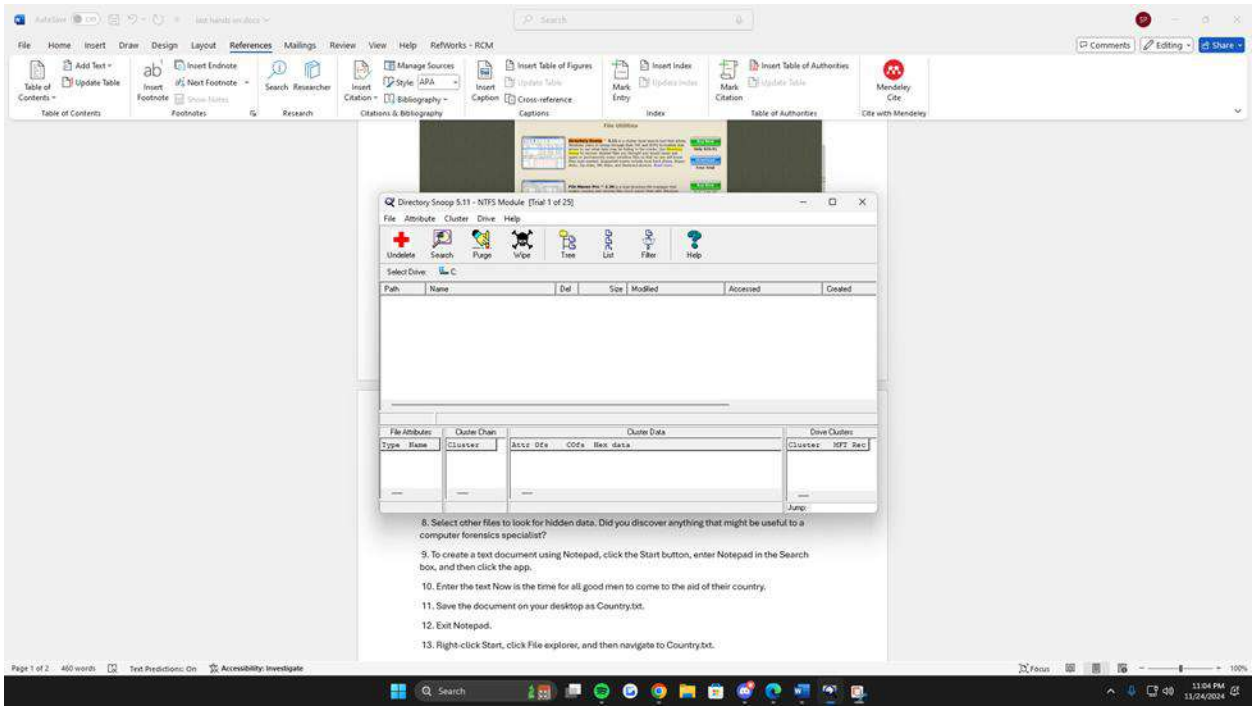
INTRODUCTION

Digital forensics is the practice of uncovering, analyzing, and preserving electronic data for use in investigations or legal proceedings (Badman & Forrest, 2024). A critical aspect of digital forensics involves identifying and recovering hidden or residual data that may provide vital evidence. This includes analyzing RAM slack (unused space at the end of a file in a memory block), drive slack (unused space between the logical end of a file and the physical end of its storage cluster), and other types of hidden or deleted data.

1. Use your web browser to go to www.briggsoft.com. (The location of content on the Internet may change without warning. If you are no longer able to access the program through the above URL, use a search engine and search for "Directory Snoop.")
2. Scroll down to the current version of directory Snoop and click download above Free Trial.

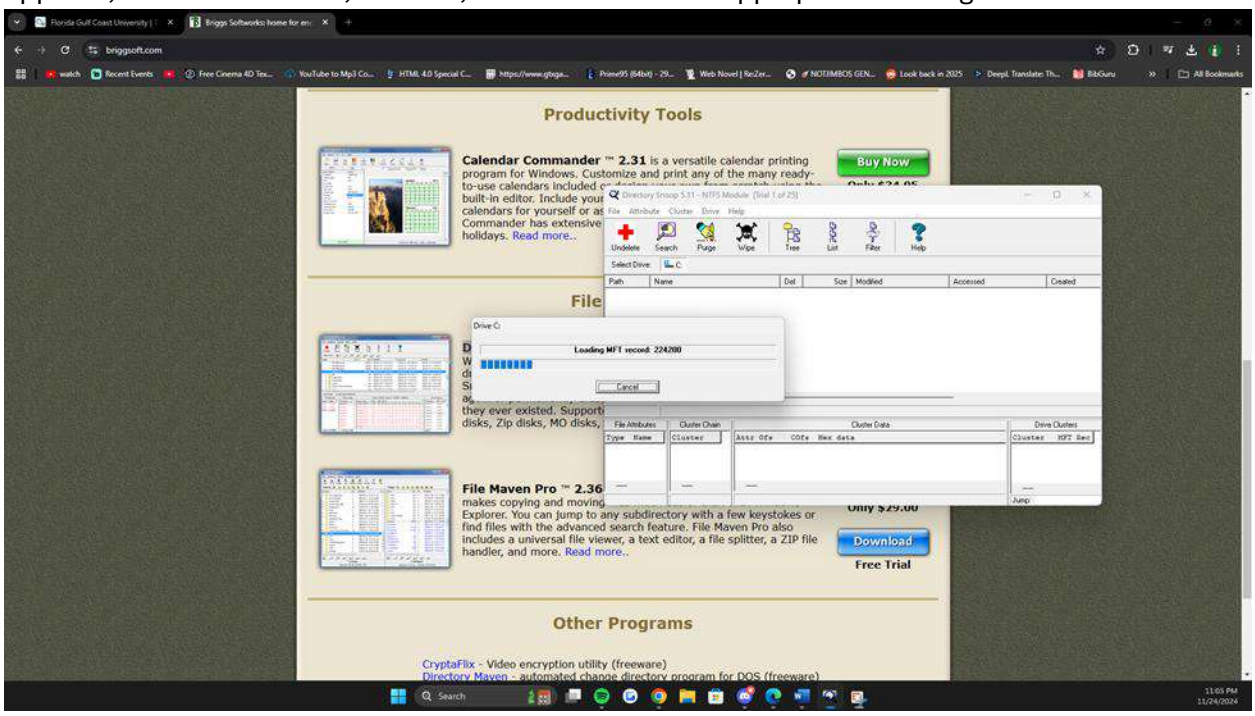


3. Follow the default installation procedures to install Directory Snoop.
4. Launch Directory Snoop.

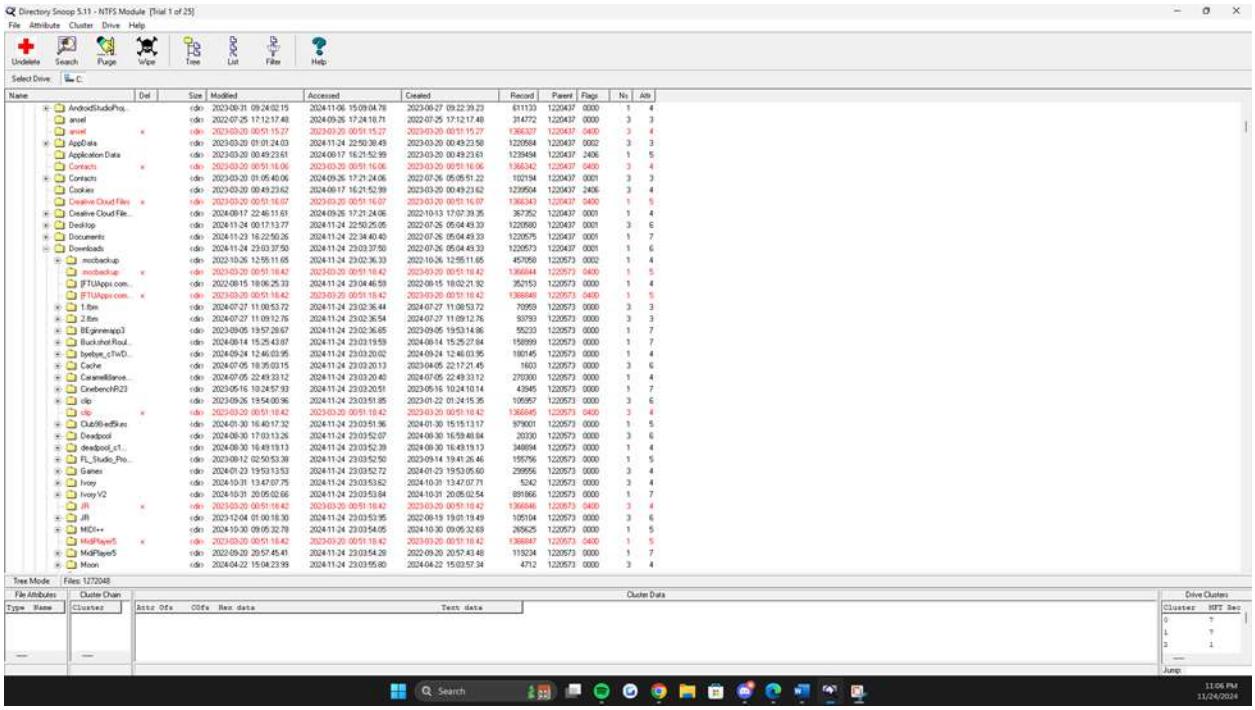


5. Depending on the filesystem on your computer, click FAT Module or NTFS Module.

6. Under Select Drive, click C:\ or the drive letter of your hard drive. If the RawDisk Driver dialog box appears, click Install driver, click Ok, and then select the appropriate drive again.



7. Click to select a file and display its contents, preferably a user-created document (such as a Microsoft Word file).Scroll down under Text data to view the contents that you can read.

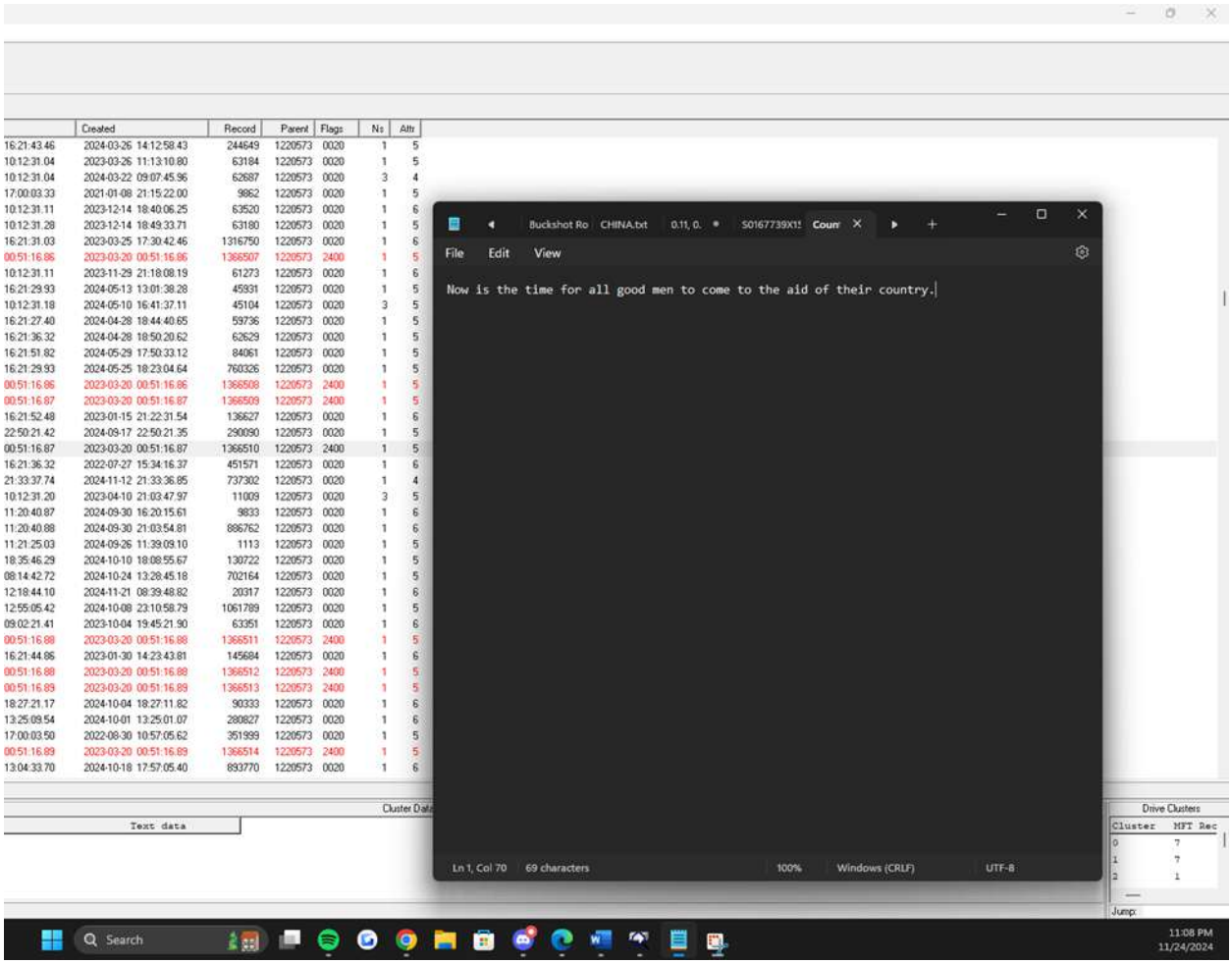


8. Select other files to look for hidden data. Did you discover anything that might be useful to a computer forensics specialist?

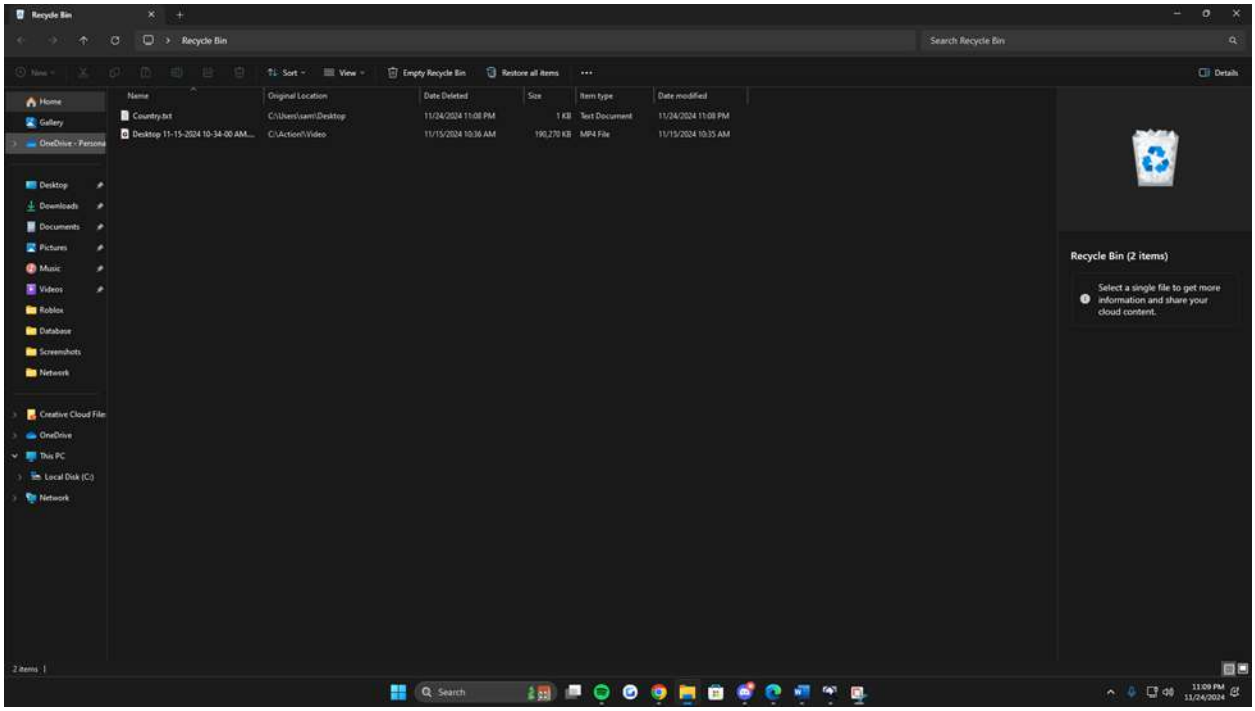
I am able to view deleted items.

9. To create a text document using Notepad, click the Start button, enter Notepad in the Search box, and then click the app.

10. Enter the text Now is the time for all good men to come to the aid of their country.

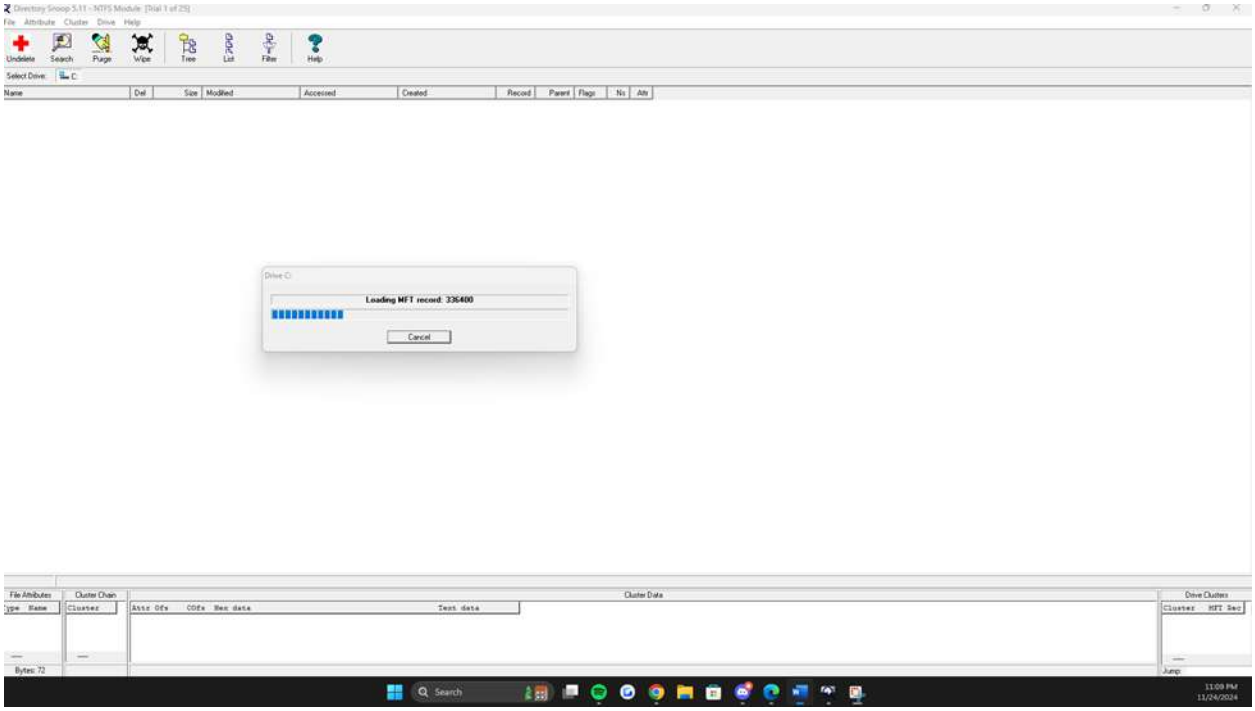


11. Save the document on your desktop as Country.txt.
12. Exit Notepad.
13. Right-click Start, click File explorer, and then navigate to Country.txt.
14. Right-click Country.txt and then click delete to delete the file.

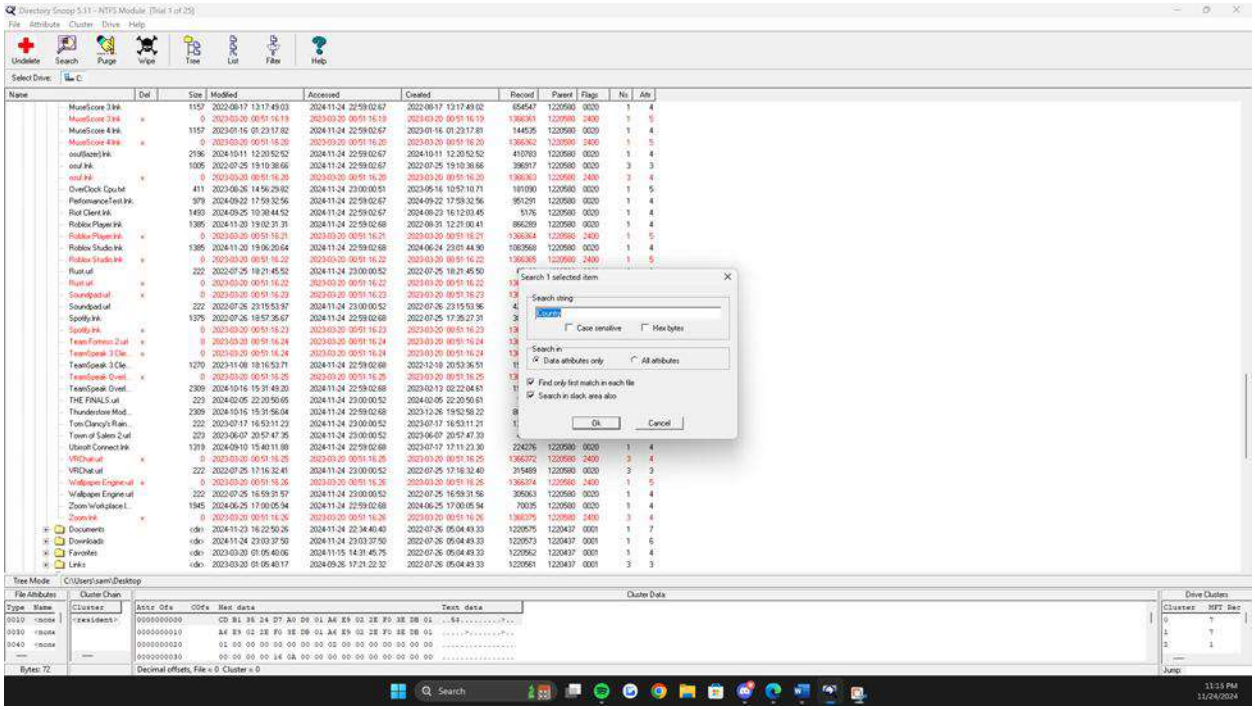


15. Search for information contained in the file you just deleted. Return to directory Snoop, click the top-

level node for the C:\ drive, and then click the Search icon.



16. Click Files.
17. Enter country as the item that you are searching for.
18. Click Search in slack area also.



19. Click Ok. Did the program find this data? Why or why not?

When you delete items, they aren't actually being deleted. It takes multiple disk clears to remove the slack.

20. Close all windows.

Case project 12-1: testing password strength
How strong are your passwords? various online tools can provide information on password strength, but not all feedback is the same. First, assign the numbers 1 through 3 to three passwords that are very similar (but not identical) to passwords you are currently using, and write down the number (not the password) on a piece of paper. Then, enter those passwords into these three online password testing services:

- how secure is My Password (howsecureismypassword.net/)
- Password checker online (password-checker.online-domain-tools.com)
- Password Meter (www.passwordmeter.com/)

Record next to each number the strength of that password as indicated by these three online tools. Then use each online password tester to modify the password by adding more random numbers or letters to increase its strength. How secure are your passwords? Would any of these tools encourage someone to create a stronger password? Which provided the best information? Create a one-paragraph summary of your findings.

1. 1 trillion years, 143 billion years
2. 200 years, 3 years
3. 1 trillion years, 143 billion years

INTRODUCTION
Passwords are the first line of defense against unauthorized access to our sensitive information. A strong password can significantly deter cyberattacks, while a weak one can leave you vulnerable to data breaches (California State University Northridge, n.d.). To assess the strength of your passwords, you can utilize various online tools. It's crucial to understand that not all password strength assessments are created equal. By comparing the feedback from different tools, you can gain a more comprehensive understanding of your password's security.

I would agree that these tools would motivate people to create stronger passwords. I compared my old password (#2) to my new password styles (#1 and #3) and found a significant improvement in security. While my old password could be cracked in a mere 3 years, my new passwords boast an estimated cracking time of billions of years. The second website provided a detailed breakdown of brute force methods, revealing that even with a medium botnet, it would take an astonishing 143 billion years to crack my new passwords. However, it's important to remember that the strength of a password is only one layer of security. If a database containing your password is compromised, attackers can bypass the cracking

process entirely, highlighting the need for robust security measures beyond strong passwords such as two-factor authentication.

References

Badman, A., & Forrest, A. (2024, February 24). *What is digital forensics?* Retrieved from IBM: https://www.ibm.com/topics/digital-forensics

California State University Northridge. (n.d.). *Week 1 - Use Strong Passwords & a Password Manager*. Retrieved from CSUN: https://w2.csun.edu/it/information-security/2024-cybersecurity-awareness-month/week-1-use-strong-passwords-password

IEEE. (n.d.). *WPA3 standard overview*. IEEE Xplore. https://ieeexplore.ieee.org

Krebs, B. (n.d.). *Wi-Fi security and WPA3*. Krebs on Security. https://krebsonsecurity.com

National Institute of Standards and Technology (NIST). (n.d.). *Wireless security guidelines*. NIST. https://csrc.nist.gov/publications/detail/sp/800-153/final

Netgear. (n.d.). *Support*. Netgear. https://www.netgear.com/support/

Wi-Fi Alliance. (n.d.). *WPA3 security*. Wi-Fi Alliance. https://www.wi-fi.org/discover-wi-fi/security